

TLP:CLEAR · Public, Unrestricted Distribution

CYBERSECURITY NOTE

Technical Assessment of Project Glasswing's Initial Update (22 May 2026)

How Today's Frontier AI Will Transform Cybersecurity

Mozilla Firefox 150 · Palo Alto Networks PSIRT · Microsoft May 2026 Patch Tuesday
wolfSSL CVE Cluster · XBOW Offensive Evaluation · ExploitBench
ExploitGym · SCONE-bench

Authored by: Douglas Mun with AI Assistance

Published date: 23 May 2026 (Initial Release)

Document Classification: TLP:CLEAR — Public, Unrestricted Distribution

Primary sources: Anthropic Project Glasswing; Frontier Red Team CVD dashboard and exploit-evals blog; Mozilla MFSA2026-30 and Mozilla Hacks; PAN PSIRT; Microsoft MSRC; wolfSSL 5.9.1 release notes (oss-sec); XBOW; Tenable; UK AISI; ExploitBench (CMU / Bugcrowd); ExploitGym (arXiv:2605.11086); SCONE-bench

Table of Contents

Table of Contents	2
Disclaimer	5
Executive Summary	6
1. Management Summary	7
1.1 The Wider Partner Landscape	7
1.2 Major Case Study Highlights	7
1.3 Independent Verification	8
2. The Frontier AI Inflection Point: Context and Background	10
2.1 Project Glasswing and the Trusted Access for Cyber Programme	10
2.2 A Changed Threat Equation	11
2.3 The May 22 Update in Aggregate	11
3. Mozilla Firefox 150: Anatomy of a 12× Discovery Multiplier	13
3.1 The Opus 4.6 → Mythos Preview Inflection: from 22 to 271	13
3.2 Mozilla Severity Distribution and CVE Reconciliation	14
3.3 Vulnerability Class Analysis	15
3.3.1 Multi-Process / IPC Use-After-Free and Sandbox Escape (4+ disclosed)	15
3.3.2 Type Confusion in JIT and IPC Serialisation (2 disclosed)	16
3.3.3 In-Process Sandbox (RLBox) Bypass (1 disclosed)	16
3.3.4 Layout-Engine Integer / Bitfield Overflow (1 disclosed)	16
3.3.5 Network Protocol Buffer Over-Read in Edge Path (1 disclosed)	16
3.3.6 Trust-Boundary Reasoning Across Process Layers (1 disclosed)	16
3.3.7 Long-Dormant Defects (2 disclosed, 15 and 20 years)	17
3.3.8 Class Summary	17
3.4 Preconditions Analysis: What the Harness Provided	18
3.5 What Mythos Preview Did Not Find — Validation of Defense-in-Depth	18
4. PAN PSIRT May 2026 Advisory: Technical Breakdown	20
4.1 Advisory Summary Statistics	20
4.2 Complete CVE Registry	20
4.3 Vulnerability Class Analysis	22
4.3.1 Memory Corruption / Buffer Overflow (3 CVEs — 1 Critical, 2 High)	22
4.3.2 Certificate Validation Failures (3 CVEs)	23
4.3.3 Authentication Bypass (3 CVEs: CVE-2026-0265, 0257, 0247)	23
4.3.4 Injection Vulnerabilities (2 CVEs)	23
4.3.5 Privilege Escalation in Endpoint Agents (2 CVEs: CVE-2026-0251, 0246)	23
4.3.6 Supply-Chain Reach: Trust Protection Foundation, Chronosphere, and Broker VM	24
4.4 Attack Vector Distribution and Exploitation Complexity	24
5. Microsoft May 2026 Patch Tuesday: AI-Discovery Across the Windows and Cloud Estate	26
5.1 Release Overview and the Zero-Day Anomaly	26
5.2 The MSRC Position: A Multi-Model AI-Driven Scanning Harness	27
5.3 Critical-Severity CVE Registry	27
5.4 Vulnerability Class Analysis	29
5.4.1 Identity and Authentication Bypass (CVE-2026-41103)	29
5.4.2 Pre-Auth Network RCE in Core Windows Services (CVE-2026-41089, CVE-2026-41096)	29
5.4.3 Office Document RCE via Preview Pane (CVE-2026-40361, 40364, 40366, 40367)	30
5.4.4 Hypervisor Escape — Hyper-V Use-After-Free (CVE-2026-40402)	30

5.4.5 Windows Kernel Elevation of Privilege (CVE-2026-33841, 35420, 40369)	30
5.4.6 Cloud Service RCE — Azure Managed Instance for Apache Cassandra (CVE-2026-33109, 33844)	31
5.4.7 Secure Boot and Security-Feature Bypass	31
5.5 Discovery Attribution and the AI Signature	31
6. wolfSSL: A Cryptographic Library Comprehensively Audited	33
6.1 Background: What wolfSSL Is and Why It Matters	33
6.2 Summary Statistics	34
6.3 Complete CVE Registry	34
6.4 Vulnerability Class Analysis	35
6.4.1 Signature Bypass / Improper Certificate Validation (3 CVEs: CVE-2026-5194, 5466, 5501)	36
6.4.2 AEAD / Authenticated Encryption Failure (2 High + 1 Info: CVE-2026-5479, 5500, 5446)	36
6.4.3 Integer Overflow Enabling Cryptographic Bypass (1 CVE: CVE-2026-5477)	37
6.4.4 Heap Buffer Overflow in Certificate and Protocol Parsing (3 CVEs: CVE-2026-5447, 5448, 5503)	37
6.4.5 Class Summary	38
6.5 Attack Vector Distribution and Exploitation Complexity	39
6.6 Discovery Attribution: Open Source, Public Repository, and End-to-End AI Exploit	40
6.7 Patch Status, Blast Radius, and the Remediation Challenge	40
6.8 What wolfSSL Tells Us About AI and Cryptographic Code	41
7. Independent Evaluation: XBOW's Offensive Security Assessment of Mythos Preview	43
7.1 Methodology	43
7.2 Benchmark Performance: Quantitative Findings	43
7.3 Source Code Plus Live-Site Access: The Full Offensive Pipeline	43
7.4 Judgment, False Positives, and the Conservative-Literal Tradeoff	44
7.5 Strengths in Native Code, Reverse Engineering, and Visual Acuity	44
7.6 Cost Efficiency: A Balanced Assessment	45
8. The Wider Glasswing Ecosystem	47
8.1 Cloudflare: Exploit Chaining, Refusal Inconsistency, and the Edge-AI Counter-Threat	47
8.1.1 Scan Scope	47
8.1.2 Exploit Chaining: The Most Operationally Significant Finding	47
8.1.3 Inconsistent Model Refusals: A Reliability Concern in Production Pipelines	48
8.1.4 The C/C++ Memory-Safety Triage Burden	48
8.1.5 "Resilience by Default": Cloudflare's Policy Response	49
8.1.6 Indirect Prompt Code Injection (IDPI): Edge AI as a New Attack Surface	49
8.2 Open-Source Scan: The Triage Bottleneck Becomes the Story	50
8.2.1 Severity Agreement: Where Claude Over-Rates and Where It Doesn't	51
8.2.2 Representative Disclosed CVEs and GHSA's	52
8.3 Industry-Wide Patch Velocity Effects: Oracle and Cisco	53
8.4 External Benchmarks: AISI, ExploitBench, ExploitGym, SCONE	54
8.4.1 UK AI Security Institute (AISI) Cyber Ranges	54
8.4.2 ExploitBench: V8 End-to-End Exploit Capability	54
8.4.3 ExploitGym: Cross-Domain Exploitation at Scale	55
8.4.4 SCONE-bench: Smart Contract Exploitation	56
9. Synthesis: Ten Convergent Findings Across All Case Studies	58
9.1 Source-Code Analysis Is the Dominant Strength (Confirmed Across All Five Case Studies)	58
9.2 The Discovery / Patching Asymmetry Has Inverted	58
9.3 Horizontal Coverage Spans Every Product Class	59

9.4 Long-Dormant Defects Surface At Unprecedented Rates	59
9.5 Defense-in-Depth Still Matters — More, Not Less	59
9.6 The Harness Is As Important As The Model	59
9.7 Logic-Level Cryptographic Reasoning Is Structurally Different from Fuzzing	60
9.8 Exploit Chaining Multiplies the Risk Surface Beyond Headline Counts	60
9.9 Judgment Remains a Human Responsibility	60
9.10 Adversarial Implications: The Offensive Mirror	61
10. Strategic Implications for Enterprise Security	62
10.1 The Defender's Dilemma Has Structurally Changed	62
10.2 Patching Velocity Must Increase — And Architectural Investment Must Increase Faster	62
10.3 Attack Surface Reduction Is Urgent	63
10.4 Security Operations Must Achieve Machine-Speed Response	63
10.5 The Bank Fraud Case: AI-Assisted Defence Beyond Vulnerability Discovery	63
10.6 AI-as-Security-Control Is Itself a New Attack Surface (IDPI)	64
10.7 The 0.7-Month Doubling Time and the Compression of the Planning Horizon	64
10.8 The Competitive Landscape: What We Do Not Know	65
11. Prioritised Recommendations	66
Sector Risk Matrix	66
Immediate (0–30 days)	66
Near-term (30–90 days)	67
Strategic (90–180 days)	68
12. Conclusion	69
13. What to Watch	70
References	72
Appendix A: Source Coverage Audit	74
A.1 Substantive Sources — Integrated into Analysis	74
A.2 Supporting Sources — Context and Corroboration	75
A.3 Procedural / Product Links — Cited in References, Not Analysed	76
A.4 Links from the Glasswing Update Deliberately Not Cited	76
A.5 Completeness Statement	77
Appendix B: Limitations and Source Independence	78
B.1 Primary Source Concentration	78
B.2 Independent Corroboration — What Is and Is Not Confirmed	78
B.3 Model Scope and Capability Limits	79
B.4 Assessment Scope Limitations	79
B.5 Analytical Quality Self-Assessment	79
B.5.1 Confidence Ratings for the Five Key Judgements	80
B.5.2 Dimension-Level Assessment	80

Disclaimer

Disclaimer: This report is an open-source intelligence (OSINT) product prepared for informational, research, and educational purposes. It is based exclusively on publicly available materials, including the Anthropic Project Glasswing initial update (22 May 2026), the Anthropic Frontier Red Team CVD dashboard and exploit-evals blog, Mozilla MFSA2026-30 and Mozilla Hacks technical post-mortem, Palo Alto Networks PSIRT May 2026 advisory, Microsoft MSRC blog and May 2026 Security Update release notes, wolfSSL 5.9.1 release notes (oss-sec mailing list), the XBOW research report, and academic benchmarks (ExploitGym arXiv:2605.11086; ExploitBench CMU/Bugcrowd; SCONE-bench; UK AISI). This document does not constitute legal advice and does not represent the official position of any government agency or employer. Organisations should conduct their own risk assessments and consult appropriate legal and technical counsel before taking action. References to specific vendors, products, or services are informational only and do not imply endorsement or criticism. All statistics and findings are traceable to cited primary sources; where sources disagree, the discrepancy is noted.

Executive Summary

Confidence ratings apply to each judgement: High = independently corroborated by multiple primary sources; Moderate = primary source with limited independent corroboration; see Appendix B.5.1 for full rationale.

Five Key Judgements

1. [High Confidence] Frontier AI has produced a measured 12× per-target vulnerability-discovery gain at Mozilla Firefox and an estimated 5× monthly advisory volume increase at Palo Alto Networks — a qualitative, not merely quantitative, change in vulnerability economics and corroborated by Mozilla MFSA2026-30, Mozilla Hacks, PAN PSIRT directly, and CCCS AV26-425.
2. [High Confidence] Seven of ten wolfSSL CVEs are logic-level correctness failures invisible to fuzzing. This is the clearest evidence that frontier AI contributes a structurally new capability class, not just faster scanning of the kind that prior tools could do. Corroborated by NVD, Red Hat CVE tracker, wolfSSL oss-sec release notes, and Tenable analysis.
3. [High Confidence] The bottleneck has inverted. The binding constraint in the AI era is no longer finding vulnerabilities but patching them. Open-source maintainers are formally requesting slower disclosure because they cannot absorb the current volume. Corroborated by Mozilla, Cloudflare, and open-source maintainer pacing requests, the 97-of-1,596-patched ratio is directly verifiable from the Anthropic CVD dashboard.
4. [Moderate Confidence] Adversaries will gain comparable capability within an estimated 3–5 months of this writing (Palo Alto Networks, 13 May 2026). A measured 0.7-month doubling time for exploit capability means that capability equivalent to today's Mythos Preview will be broadly accessible by Q4 2026. The 3–5-month window is a single-analyst estimate; the 0.7-month figure is from the Anthropic-associated SCONE-bench and has not yet been independently replicated. See §13 Indicator 3.
5. [High Confidence] Architectural defence-in-depth — sandboxing, isolation, prototype freezing — produces permanent capability deficits for AI scanners. It is the highest-leverage long-term investment available to defenders. The Mozilla prototype-freezing finding directly demonstrates this; the principle is supported by Section 6's wolfSSL analysis of which bug classes AI cannot detect.

Horizon	Priority action
0–30 days	Patch CVE-2026-0300 (PAN-OS RCE, CISA KEV, already exploited), CVE-2026-41089 (Netlogon RCE, CVSS 9.8), CVE-2026-5194 (wolfSSL, CVSS 9.3/10.0), and the Word Preview Pane RCE cluster (CVE-2026-40361/40364/40366/40367). Verify SBOM for statically-linked wolfSSL instances. Deploy Firefox 150.0.2 or later.
30–90 days	Initiate an AI-assisted code audit with reproducer infrastructure on internally developed applications and key supply-chain dependencies. Redesign patch-SLA policies to handle AI-era advisory volumes (current baselines are calibrated for 1–5 CVEs/month; a single AI-assisted advisory now routinely produces 75+).
90–180 days	Prioritise architectural hardening — sandboxing, isolation, prototype freezing — above per-bug patching. Establish a frontier AI programme for continuous internal security research. Plan detection-and-response capabilities for machine-speed attack timelines.

1. Management Summary

On 22 May 2026, Anthropic published its first major progress update on Project Glasswing, the controlled-access programme that places Mythos Preview — its frontier model not yet released to the public — in the hands of approximately fifty vetted defensive partners. The update reports that in roughly six weeks, Glasswing partners have collectively identified more than 10,000 critical- or high-severity vulnerabilities in some of the most systemically important software in the world. Anthropic's own characterisation captures the inflection: progress on software security is no longer rate-limited by how quickly defenders can find new vulnerabilities; it is now rate-limited by how quickly the ecosystem can verify, disclose, and patch them.

This assessment expands the 14 May 2026 analysis — which focused on the Palo Alto Networks PSIRT advisory and the XBOW evaluation — to incorporate the full May 22 Glasswing update. The five major case studies covered in Sections 3–7 are: Mozilla Firefox 150 (the primary per-model capability benchmark), PAN PSIRT May 2026 advisory (75 issues across 130+ products), Microsoft May 2026 Patch Tuesday (118 CVEs, first zero-day-free release in 22 months), wolfSSL (ten CVEs in four cryptographic-library classes, including an AI-constructed end-to-end exploit), and the XBOW independent offensive evaluation. Using essentially the same harness, target, and team as the prior Opus 4.6 collaboration, Mozilla shipped fixes for 271 vulnerabilities in Firefox 150 — over ten times the 22 fixes Firefox 148 produced. Of those 271, 180 carry Mozilla's sec-high rating, 80 are sec-moderate, and 11 are sec-low. They are distributed across three internal rollup CVEs (CVE-2026-6784, 6785, and 6786), covering 316 total internally reported defects in the Firefox 150 cycle.

1.1 The Wider Partner Landscape

Other Glasswing partners have reported comparable findings. Cloudflare reports more than 2,000 bugs across its critical-path systems, of which roughly 400 are high- or critical-severity, with a false-positive rate the team judges to be better than that of human testers. An Anthropic-led scan of more than one thousand open-source projects has produced 23,019 candidate findings; per the 22 May dashboard snapshot, 1,900 have now been reviewed by six external security research firms with a 90.8% true-positive rate, and 1,596 have been disclosed across 281 open-source projects (97 patched upstream, 88 with CVE or GHSA records). The disclosed pool includes a striking horizontal cluster of ten CVEs in the wolfSSL cryptographic library alone (CVE-2026-5194 plus CVE-2026-5446 through 5503) spanning signature bypass, AEAD forgery, certificate-validation, and heap-buffer-overflow classes; CVE-2026-5194, discovered by Nicholas Carlini (Anthropic) in collaboration with Thai Duong and Bronson Yen of Calif.io (all via PR #10102), is the most-publicised single instance and enables forged ECDSA certificates across an estimated five billion devices. Separately, the Frontier Red Team's SCONE-bench smart-contract exploitation benchmark shows Mythos Preview exploiting USD 35 million in post-knowledge-cutoff smart-contract vulnerabilities in simulation — 75% more than the next-closest model, with the year-over-year doubling time for model exploit capability now compressed from 1.1 months to 0.7 months.

1.2 Major Case Study Highlights

Palo Alto Networks, the first major Glasswing partner to disclose publicly, published its May 2026 PSIRT advisory on 13 May covering 26 advisory entries (25 CVEs and one monthly rollup) representing 75 distinct vulnerability instances across more than 130 products. The advisory includes one Critical

(CVE-2026-0300, CVSS-BT 9.3, confirmed to have been exploited before disclosure) and three High-rated PAN-OS CVEs — network-protocol memory-corruption flaws, certificate-validation bypasses, authentication bypasses, and injection vulnerabilities across PAN-OS, GlobalProtect, Prisma Access, Prisma SD-WAN, WildFire, and supply-chain components. PAN's Chief Product Officer, Lee Klarich, stated publicly that the capabilities demonstrated were not overstated in initial communications and may have been understated, and estimated a three-to-five-month window before these capabilities would flow broadly to adversarial actors — a timeline this assessment treats as a planning constraint.

wolfSSL, analysed in Section 6, represents a qualitatively distinct case study: a single cryptographic library in an estimated five billion devices, audited in one AI-driven pass to produce ten CVEs across four vulnerability classes. Three of those classes — signature bypass, AEAD authentication failure, and integer overflow enabling cryptographic bypass — produce no crash or fuzzer signal and are detectable only by reasoning about the cryptographic specification's requirements. CVE-2026-5194 (CVSS 9.3 / 10.0), discovered by Nicholas Carlini (Anthropic) in collaboration with Thai Duong and Bronson Yen of Calif.io, enables certificate forgery across any wolfSSL-authenticated TLS session. Mythos Preview constructed the working exploit.

Microsoft's 12 May 2026 Patch Tuesday is the fifth major case study in this assessment. The release addresses 118 CVEs (16 critical and 102 important, by Tenable's count). Notably, it contains zero actively exploited or publicly disclosed zero-days — the first such release since June 2024, ending a 22-month streak. MSRC's accompanying blog explicitly attributes a greater-than-usual share of internal discovery to a new multi-model, AI-driven scanning harness, with Anthropic researchers credited by name for at least one critical Windows RCE. The release spans the entire enterprise estate: a pre-auth Netlogon RCE on domain controllers (CVE-2026-41089, CVSS 9.8), a Hyper-V use-after-free guest-to-host escape (CVE-2026-40402, CVSS 9.3), four Word RCEs reachable via the Preview Pane (CVE-2026-40361/40364/40366/40367), an SSO Plugin authentication bypass (CVE-2026-41103, CVSS 9.1), two Azure Managed Cassandra RCEs (CVE-2026-33109 at CVSS 9.9 and CVE-2026-33844 at CVSS 9.0), and three Windows Kernel elevation-of-privilege flaws — exactly the cross-portfolio, cross-class horizontal sweep that has now become the AI-discovery signature.

1.3 Independent Verification

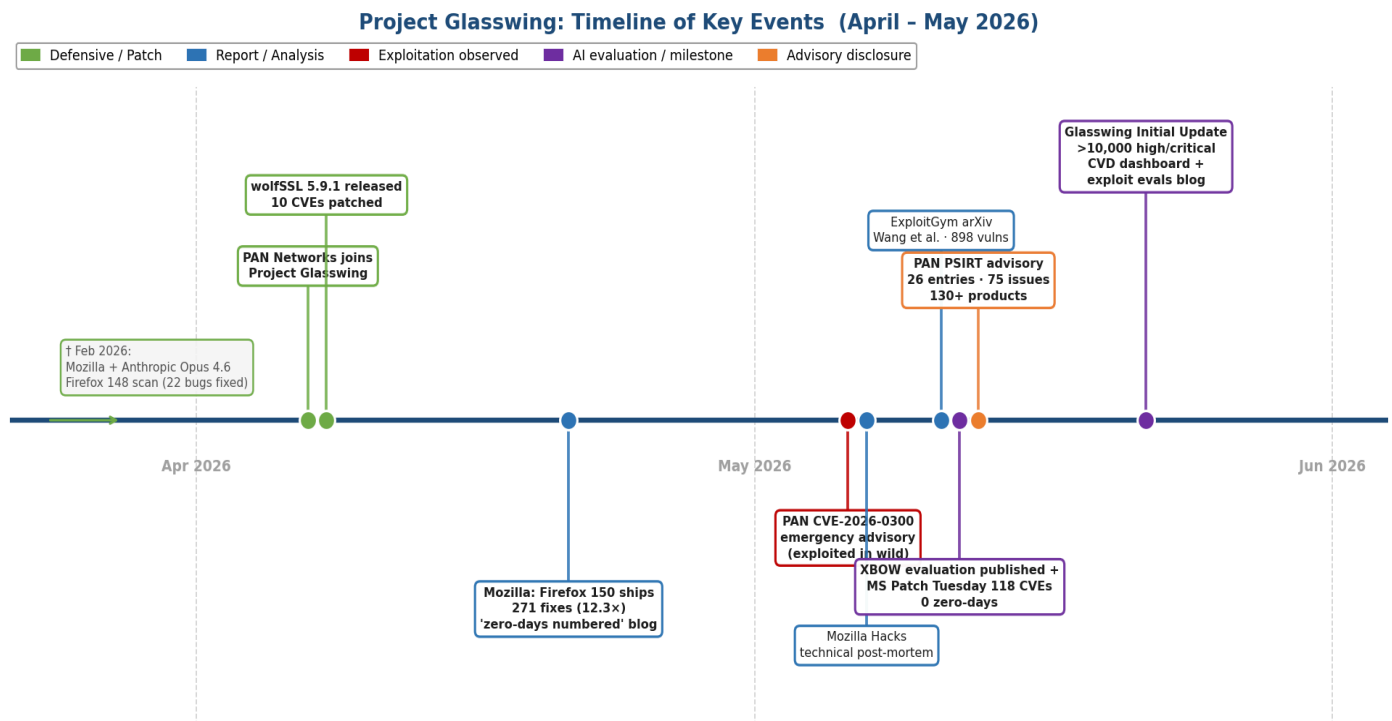
Independent external benchmarks have ratified the partner reports. The UK's AI Security Institute states that Mythos Preview is the first model to solve both of its cyber-range simulations end-to-end. XBOW's web-exploit benchmark places it well ahead of Opus 4.6 and GPT-5.5-Cyber on a token-for-token basis, and ExploitBench and ExploitGym — two newly released academic benchmarks for exploit development — both rank Mythos Preview the strongest performer to date.

The convergent picture across these seven independent evaluations is unambiguous: frontier AI has crossed a capability threshold that makes it qualitatively superior to prior tooling for the identification of vulnerability candidates in source code, and approaching the capability of experienced human vulnerability researchers for end-to-end exploit construction in structured, code-accessible settings — the first AI model to reach this level on published independent benchmarks. Palo Alto Networks' three-to-five-month window estimate for defensive action, published 13 May 2026, remains the operative planning horizon. It now appears, if anything, conservative.

Key Judgment: The combined May 2026 evidence — Mozilla Firefox 150 (271 fixes, 12× over Opus 4.6 at the same target, Section 3), PAN PSIRT (75 distinct issues across 130+ products, Section 4), Microsoft Patch Tuesday (118 CVEs with zero zero-days for the first time in 22 months and AI-attribution surfacing on critical RCEs, Section 5), wolfSSL (10 CVEs in four cryptographic-library classes including end-to-end AI-constructed exploit, Section 6), XBOW ("unprecedented precision", Section 7), the open-source scan (~1,596 disclosures across 281 projects, Section 8.2), and the ExploitBench / ExploitGym / SCONE-bench academic benchmarks (Section 8.4) — together mark not an incremental upgrade but a phase change in the economics of vulnerability discovery. Every security organisation should treat this as a forcing function to accelerate patching velocity, reduce attack surface, and stand up AI-assisted defensive capabilities. The bottleneck in fixing has now visibly overtaken the bottleneck in finding.

2. The Frontier AI Inflection Point: Context and Background

The term 'frontier AI' refers to the most capable models at any given moment — those operating at or near the boundary of what current systems can achieve. In the cybersecurity domain, frontier model capabilities translate directly into the ability to reason about complex codebases, trace multi-step exploit paths, identify subtle logic flaws, and generate proof-of-concept exploits with precision and speed that no human researcher or automated scanner can match at scale.



2.1 Project Glasswing and the Trusted Access for Cyber Programme

Project Glasswing is Anthropic's structured early-access programme. It provides vetted defenders with controlled access to Mythos Preview — a model withheld from public release because Anthropic has concluded that its current safeguards are not yet sufficient to prevent misuse at scale. Partners operate under coordinated vulnerability disclosure principles: findings must be remediated before adversaries can exploit them, and the model is used only for defensive purposes.

As of the May 22 update, the programme spans approximately fifty partners. The cohort visible in public disclosures includes Palo Alto Networks (whose May 13 PSIRT cycle was the first large-scale public artefact of the programme), Mozilla, Cloudflare, Cisco, Oracle, Microsoft, and a Glasswing partner bank not named in the update. Anthropic separately runs an open-source scanning campaign in which Mythos Preview is applied to widely-used open-source projects, with disclosure through Anthropic's coordinated disclosure process and external triage by six independent security research firms.

2.2 A Changed Threat Equation

Before this generation of frontier models, vulnerability discovery operated under an implicit assumption: the difficulty of finding bugs created a natural buffer between the presence of bugs in code and their exploitation. That assumption no longer holds for the class of vulnerabilities that AI-assisted code audits can address — specifically, software whose source code or binary is available for static analysis. Within that class, the buffer has collapsed. Organisations that have not incorporated AI-driven proactive scanning must now treat any internet-facing system as potentially exploitable by an adversary who gains access to these models — and plan their defensive posture accordingly.

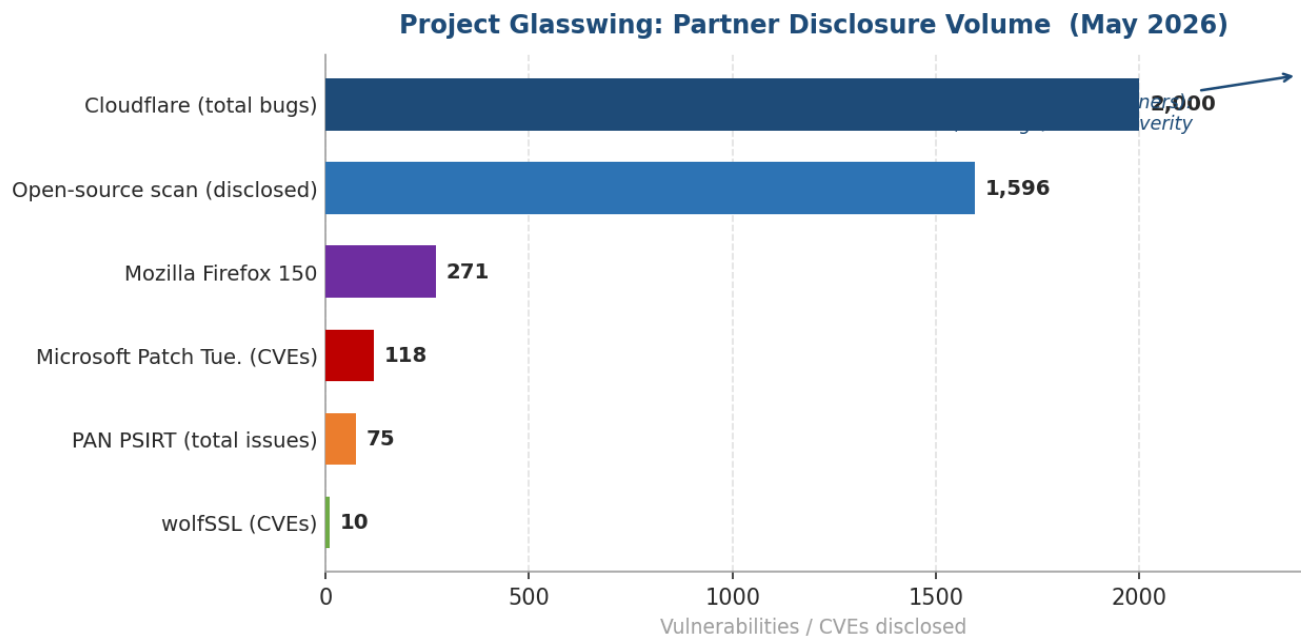
Palo Alto Networks' public estimate of a three-to-five-month window for defensive action before these capabilities flow more broadly to adversarial actors should be treated as a planning constraint, not a guarantee. Mozilla's engineering team frames the same dynamic more bluntly in their 21 April 2026 announcement: until now, the industry had fought security to a draw; closing the gap between machine- and human-discoverable bugs erodes the attacker's structural advantage. The Mozilla framing matters because it identifies precisely what has changed — not the ceiling of what can be found, but the cost and parallelism with which it can be found.

2.3 The May 22 Update in Aggregate

The May 22 Anthropic update reports the following partner-level aggregates after roughly six weeks of Glasswing operation:

- **More than 10,000** high- or critical-severity vulnerabilities identified across ~50 partners.
- **Several partners** report a more than 10× increase in bug-finding rate over their prior baseline.
- **Cloudflare:** 2,000 total bugs across critical-path systems; 400 high- or critical-severity; false-positive rate judged better than human testers.
- **Mozilla:** 271 vulnerabilities fixed in Firefox 150, against 22 in Firefox 148 with Opus 4.6 — an order-of-magnitude per-target multiplier.
- **Palo Alto Networks:** approximately five times the usual volume in PAN's May 'Patch Wednesday' cycle (PAN's monthly security release, scheduled on the Wednesday following Microsoft's Patch Tuesday). For context, PAN's historical monthly advisory cadence averaged 12–18 CVEs; the May 2026 cycle, with 75+ distinct issues across 130+ products, is a roughly fivefold departure.
- **Open-source scan (as of 22 May 2026 dashboard snapshot):** 1,000+ projects scanned; 23,019 total candidate findings; 1,900 reviewed by external security research firms; 1,726 confirmed valid (90.8% true-positive rate); 1,596 disclosed to maintainers across 281 open-source projects (467 via external triage + 1,129 direct at maintainers' request); 97 patched upstream of which 88 have a published CVE or GHSA record.
- **Microsoft:** May 12 Patch Tuesday addresses 118 CVEs (16 critical and 102 important, by Tenable's count). MSRC publicly attributes a greater-than-usual share of internal discovery to its new multi-model AI-driven scanning harness, with Anthropic researchers credited by name on at least one critical Windows RCE. The release is the first since June 2024 to ship with no actively exploited or publicly disclosed zero-days. Microsoft forecasts that monthly patch volume will continue to trend upward for some time. Full analysis in Section 5.

- **Oracle:** vulnerability detection and remediation now reportedly runs multiple times faster than before.
- **Use beyond vulnerability discovery:** at a Glasswing partner bank, Mythos Preview helped to detect and prevent a fraudulent USD 1.5 million wire transfer following compromise of a customer email account.



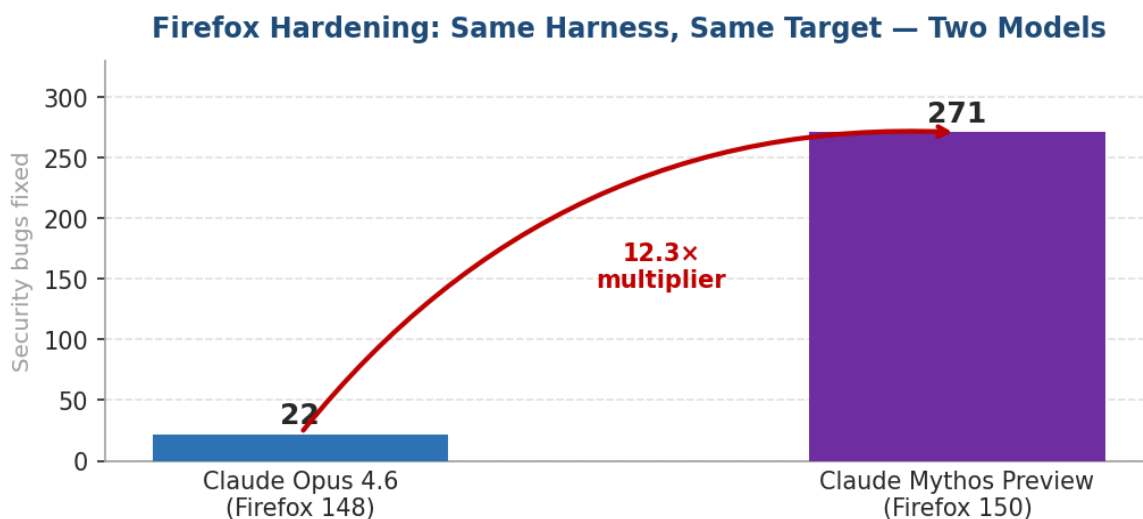
3. Mozilla Firefox 150: Anatomy of a 12× Discovery Multiplier

Mozilla's hardening of Firefox 150 is the single most important comparative data point in the May 22 update. Unlike the PAN PSIRT cycle (which lacks a prior-model baseline at a comparable scale) or the open-source scan (where target heterogeneity makes per-model attribution difficult), Mozilla provides something approximating a controlled experiment: the same harness pipeline, the same internal security team, the same target codebase (a hardened browser), and a clear before-and-after generational delta between Claude Opus 4.6 and Mythos Preview.

3.1 The Opus 4.6 → Mythos Preview Inflection: from 22 to 271

In February 2026, Mozilla's first publicly described AI-assisted hardening pass used Claude Opus 4.6 against Firefox 148. That work produced fixes for 22 security-sensitive bugs, consistent with Mozilla's pre-AI monthly security-fix rate of approximately 20–30 fixes per Firefox release based on MFSA release history through 2024–2025. In the second pass, against Firefox 150 and using essentially the same harness pipeline, Mythos Preview produced fixes for 271 vulnerabilities — a 12.3× per-target increase. Mozilla itself reports a total of 423 security bugs fixed across April releases, of which 271 came from Mythos Preview through the new pipeline, 41 were externally reported, and the remaining 111 came from a mix of fuzzing, manual inspection, and runs of the same pipeline with other models or in releases other than Firefox 150.

Three structural points qualify the comparison without diminishing it. First, the harness itself was substantially improved between the two passes; Mozilla credits both model capability and harness engineering for the increase. Second, the harness becomes a force multiplier that compounds with model capability — model upgrades make the entire pipeline more effective at finding bugs, building reproducer test cases, and articulating impact. Third, the comparison is genuinely controlled in the dimensions that matter most: same target, same team, same broad methodology. The order-of-magnitude delta is therefore best read as a joint pipeline-and-model effect, with the Mythos upgrade as the dominant variable Mozilla has publicly surfaced.



3.2 Mozilla Severity Distribution and CVE Reconciliation

Mozilla's severity ratings differ from CVSS-BT in important ways. Their sec-critical and sec-high ratings are assigned to vulnerabilities that can be triggered through ordinary user behaviour (e.g., browsing to a page), with sec-critical reserved for issues that are either publicly disclosed or known to be exploited in the wild. The sec-moderate rating applies to bugs that would otherwise be sec-high but require unusual interaction with the victim. Sec-low covers low-impact issues such as safe crashes.

Of the 271 Mythos Preview-identified Firefox 150 fixes, the severity distribution is as follows:

Severity rating	Count (of 271)	Operational meaning
sec-high	180	Triggerable via normal browsing; assumed exploitable with sufficient effort under Mozilla's threat model
sec-moderate	80	Would otherwise be sec-high but requires unusual or complex victim action
sec-low	11	Annoying or correctness issues far from user harm (e.g. safe crash)

Mozilla aggregates internally reported bugs into roll-up CVEs rather than assigning per-bug CVE identifiers (a practice they describe as more transparent than that of some browser vendors, which issue no CVE at all for internal findings). The Firefox 150 cycle produced three internal rollups, summarised below:

CVE	Underlying bugs	Nature of rollup
CVE-2026-6784	154	Internally-reported security bugs, Firefox 150
CVE-2026-6785	55	Internally-reported security bugs, Firefox 150
CVE-2026-6786	107	Internally-reported security bugs, Firefox 150
Total in rollups	316	Mythos Preview = 271 of these; remaining 45 from other internal sources (fuzzing, manual inspection, other models)
CVE-2026-6746 / 6757 / 6758	3	Separately credited to Anthropic's Frontier Red Team from a February 2026 pre-Glasswing pass; not part of the 271 Firefox 150 count.

The 271 figure, therefore, reflects only Mythos Preview's contribution to the Firefox 150 release. Throughout April, Mozilla shipped 423 security fixes in total — a volume the Mozilla Hacks team's own bug-fix chart shows is roughly an order of magnitude above the 20–30-bug-per-month baseline that prevailed throughout 2025. A meaningful share of the gap between the rollup total (316) and the Mythos count (271) is precisely the kind of dual-source confirmation a sceptical reader should want: independent fuzzers and human inspectors continued to find bugs in parallel and largely did not duplicate the Mythos findings.

3.3 Vulnerability Class Analysis

Mozilla released 12 illustrative bug descriptions (with Bugzilla IDs) on 7 May 2026 as part of its commitment to public transparency. These cannot be treated as a statistically representative sample of all 271 — Mozilla acknowledges the selection process was somewhat arbitrary — but they were drawn from a range of browser subsystems and are sufficient to characterise the dominant defect classes the model surfaced. They also map cleanly onto Mozilla's longstanding architectural concerns and to the limits of pre-AI dynamic analysis techniques.

The taxonomy below applies the same analytical lens used in Section 4 of the PAN PSIRT advisory: classify by root cause and exploitation precondition, then assess what the discovery reveals about the model's capability profile.

3.3.1 Multi-Process / IPC Use-After-Free and Sandbox Escape (4+ disclosed)

The most prominent class in the disclosed sample is use-after-free (UAF) in cross-process code paths, almost always with sandbox-escape implications. Mozilla's threat model for these bugs is explicit: they presume that a separate bug has already compromised the sandboxed content process and that the attacker is running arbitrary code inside it, attempting to escalate privileges into the privileged parent process. Discovery of this class is notoriously hostile to fuzzing — Mozilla's own snapshot-based IPC fuzzing techniques are pioneering precisely because the class resists conventional approaches.

Disclosed instances include:

- Bug 2021894: a race condition over IPC that manipulates IndexedDB refcounts in the parent process, triggering a UAF and potential sandbox escape from a compromised content process.
- Bug 2022733: a parent UAF achieved by flooding WebTransport with thousands of certificate hashes to stretch a race condition in a refcount-heavy copy loop, then exploited over IPC.
- Bug 2024653: an intricate testcase weaving nested event loops, pagehide listeners, and garbage collection to trigger a UAF in the <object> element's attribute setter.
- Bug 2027298: a content-process UAF in which the harness patches the color picker to simulate non-automatable user selection, then uses a synchronous input event to spin a nested event loop that re-enters actor teardown and frees a callback mid-unwinding.

Two features of these descriptions warrant attention. First, the testcases are constructive — the model writes a working reproducer that demonstrably triggers the bug, not merely descriptive. Mozilla's harness explicitly requires reproducibility for a finding to be accepted, which is the principal defence against the unverifiable, high-volume AI-generated bug reports that have overwhelmed open-source projects in recent months. Second, in bug 2027298, the harness is permitted to patch the Firefox source under defined rules (the modified code must be restricted to the sandboxed process) to simulate compromise scenarios — exactly mirroring the rules that Mozilla's bug bounty programme applies to human researchers.

3.3.2 Type Confusion in JIT and IPC Serialisation (2 disclosed)

Two of the most architecturally significant disclosed bugs sit at the boundary between the JavaScript engine and the IPC layer:

- Bug 2024918: an incorrect equality check causes the JIT to optimise away the initialisation of a live WebAssembly GC struct, yielding a fake-object primitive with potential arbitrary read/write. Mozilla notes this bug survived extensive fuzzing by both internal and external researchers.
- Bug 2022034: a raw NaN crossing an IPC boundary masquerades as a tagged JS object pointer; double deserialisation in the parent process produces a parent-side fake-object primitive enabling sandbox escape.

These represent the model's capacity to reason about non-local correctness properties — invariants that hold only when JIT optimisation, GC, and IPC serialisation interact in a specific order. Fuzzing struggles with this class because the trigger requires a precisely-ordered sequence of high-level operations rather than malformed input data; static analysis struggles because the invariant violation is only detectable when the dynamic semantics of three subsystems are simulated together.

3.3.3 In-Process Sandbox (RLBox) Bypass (1 disclosed)

Bug 2029813 escapes Firefox's in-process sandboxing technology for third-party libraries (RLBox) by exploiting a gap in the verification logic that copies values from the untrusted side of the sandbox boundary to the trusted side. This is a class of vulnerability that Mozilla itself has invested years in mitigating; the model's identification of a verification-logic gap in a defence-in-depth control is a direct illustration of why no single layer can be assumed bulletproof.

3.3.4 Layout-Engine Integer / Bitfield Overflow (1 disclosed)

Bug 2026305 is an extremely small testcase that exploits the special HTML rowspan=0 semantics by appending more than 65,535 rows to a table, bypassing a clamping check and overflowing a 16-bit layout bitfield. The bug had escaped fuzzers for years. The pattern — a documented HTML edge case interacting with an internal layout invariant — is characteristic of what code-reasoning can find that input-mutation fuzzers cannot.

3.3.5 Network Protocol Buffer Over-Read in Edge Path (1 disclosed)

Bug 2023958 simulates a malicious DNS server by intercepting glibc DNS function calls to reproduce a UDP-to-TCP fallback edge case, triggering a buffer overflow during HTTPS Resource Record and Encrypted Client Hello parsing — resulting in a parent-process stack memory leak. The bug requires both the constructed network scenario and reproduction of a transport-layer fallback, which the harness handles via library interception. This is a class of bug that is theoretically discoverable by network fuzzing, but requires the fuzzer to model both DNS-server behaviour and a transport fallback path together — an integration challenge that has historically left this corner of the network stack under-tested.

3.3.6 Trust-Boundary Reasoning Across Process Layers (1 disclosed)

Bug 2023817 is a class apart. A compromised content process is permitted to send an arbitrary wallpaper image for the parent process to decode; paired with a hypothetical image-decoder

vulnerability, this would enable sandbox escape. Mozilla's own commentary on this finding is instructive: it required difficult-to-automate reasoning about the trust level of inputs in the parent process. The bug demonstrates the model's ability to reason about the architectural boundary separating trusted and untrusted contexts — not just to find a memory-corruption primitive, but to identify code paths where the trust boundary itself has been misdrawn.

3.3.7 Long-Dormant Defects (2 disclosed, 15 and 20 years)

Two of the disclosed bugs are remarkable for their age:

- Bug 2024437: a 15-year-old bug in the <legend> element, triggered by the orchestrated interaction of recursion stack-depth limits, expando properties, and the cycle collector.
- Bug 2025977: a 20-year-old XSLT bug in which reentrant key() calls cause a hash-table rehash that frees its backing store while a raw entry pointer is still in use. Mozilla notes this is one of several sec-high XSLT bugs they fixed.

Long-dormant bugs are emblematic of what the discovery cost curve has done. Bugs of this age survive precisely because the cost of finding them — meticulous reasoning across distant parts of the codebase, with no obvious input-shape signal to guide a fuzzer — exceeded the available investment for two decades of professional security review. The collapse in discovery cost surfaces the entire latent backlog at once. Any browser, kernel, or long-lived runtime should expect a comparable dormant-defect tail to surface in its first serious Mythos-class scan.

3.3.8 Class Summary

Consolidated across the 12 disclosed Firefox 150 examples, the class distribution is broadly as follows. (The disclosed sample is illustrative, not statistically representative of the full 271, but it covers the breadth of subsystems Mozilla highlighted.)

Vulnerability class	Examples	Why pre-AI tooling missed it
IPC / cross-process UAF and sandbox escape	4	Multi-process race conditions and refcount manipulation are extremely hostile to fuzzing; they require state-aware reasoning
JIT / IPC type confusion (fake-object primitives)	2	Requires reasoning across JIT optimisation, GC, and IPC serialisation invariants simultaneously
In-process sandbox (RLBox) verification bypass	1	The verification logic gap requires reasoning about the sandbox boundary semantics, not the sandboxed code
Layout-engine integer/bitfield overflow	1	Trigger requires HTML edge-case semantics interacting with internal layout invariant; documented but rarely chained
Network protocol buffer over-read on fallback paths	1	Network fuzzing rarely models a server-side adversary plus a transport-layer fallback together
Trust-boundary misdrawing across processes	1	Requires architectural reasoning about which inputs ought to be considered untrusted in the parent process
Long-dormant defects (15+ years)	2	Survived decades of human and fuzzing review because trigger sequences cross distant subsystems

3.4 Preconditions Analysis: What the Harness Provided

The discovery preconditions matter as much as the bugs themselves. Mozilla's harness, which they describe in technical detail in the 7 May 2026 Mozilla Hacks post, provides Mythos Preview with the following: full source code access; the ability to spin up reproducer test cases dynamically against the live Firefox build infrastructure; library-interception capabilities (illustrated in bug 2023958, where the harness intercepts glibc DNS calls to simulate a malicious resolver); permission to patch Firefox source under defined sandbox-rule constraints (illustrated in bug 2027298); and a deduplication layer that prevents the model from re-reporting bugs already in Mozilla's tracker.

These preconditions are a crucial context for the 271 figure. They establish that the comparison with traditional fuzzing is not apples-to-apples; Mythos is operating with both code visibility and a write-and-execute reproduction environment. They also establish that the comparison with Opus 4.6 is broadly apples-to-apples because the same harness was used in the prior pass with iterative refinement. The 12.3× delta is therefore a model-generation effect against a constant pipeline scaffold, not a methodology effect.

Two preconditions also bear directly on the model's relative success against different bug classes. For UAF in IPC paths, the harness must be able to build the multi-process reproducer; without that, the model would generate plausible-sounding speculation that the maintainer would need to either confirm or dismiss manually — i.e. precisely the unverifiable speculation that previously made AI-generated security reports a liability for maintainers. For trust-boundary reasoning (bug 2023817), the harness must surface code paths that cross the boundary; the model then identifies which input the boundary fails to validate. Each precondition is a piece of pipeline engineering that compounds with model capability.

3.5 What Mythos Preview Did Not Find — Validation of Defense-in-Depth

Mozilla's most underappreciated finding is what the model failed to do, and why. In a defensive context, this is at least as important as the successful discoveries.

During an audit of the harness logs, Mozilla observed numerous attempts by Mythos Preview to exploit prototype pollution as a sandbox-escape vector — the same class of attack that a series of human researchers had successfully used against Firefox in prior years. All such attempts in the observed runs were thwarted by an architectural change Mozilla had previously made: freezing the parent-process JavaScript prototypes by default. The model's repeated failed attempts in the log served as an automated penetration-test confirmation that the architectural mitigation was working as intended.

This finding has two implications for defenders. First, it falsifies a casual reading of the headline numbers as 'AI can find everything'. The model could not find what the architecture had pre-empted; the actual exploit surface was strictly constrained. Second, it elevates the value of architectural defence-in-depth investments above per-bug patching. Every defence-in-depth control that pre-empted a bug class produces a permanent capability deficit for AI scanners, whereas every per-bug patch closes only one finding. Investments in architectural hardening — sandboxing, prototype freezing, address-space layout randomisation, control-flow integrity, RLBox-style in-process isolation — yield compounding returns in the AI-assisted attack era.

Implication for Defenders: The Firefox 150 result is not principally a story about AI finding bugs. It is a story about a sufficiently good harness applied to a hardened, mature codebase, exposing the long-latent tail of bugs that the prior cost curve had protected. The same outcome should be expected by every long-lived browser, kernel, runtime, language toolchain, and embedded OS in the next twelve months. Plan patch capacity accordingly, and treat architectural defence-in-depth as your highest-leverage long-term investment.

Chapter Findings — Mozilla Firefox 150

1. The 12.3× per-target multiplier (22 → 271 fixes) reflects a joint model-upgrade and harness-improvement effect. The comparison is broadly controlled for methodology, making the model generation the dominant variable — the single clearest published measurement of a frontier model capability step-change on a real production codebase.
2. Seven of the eight disclosed vulnerability classes are structurally hostile to fuzzing: multi-process UAF under race conditions, JIT type confusion requiring cross-component state reasoning, in-process sandbox boundary misdrawing, and trust-boundary violations across process layers. The AI's advantage is not the speed of fuzzing — it is its analytical capability in domains that fuzzing cannot structurally reach.
3. The model's repeated failed prototype-pollution attempts, all thwarted by architectural prototype-freezing, independently validate that the architectural mitigation works as intended. This is the first documented case of AI-generated failure logs serving as automated penetration-test confirmation.
4. Two dormant bugs of 15 and 20 years confirm the principal mechanism: frontier AI collapses the discovery-cost curve that previously made these bugs economically unviable to find. Every organisation with a long-lived codebase should plan for the same surfacing event when a Mythos-class scan reaches its target.

4. PAN PSIRT May 2026 Advisory: Technical Breakdown

On May 13, 2026, Palo Alto Networks' Product Security Incident Response Team published its largest-ever single advisory, comprising 26 advisories (25 CVEs and one monthly security advisory, PAN-SA-2026-0007) representing 75 distinct vulnerability instances across more than 130 products. The advisory was the first large-scale public artefact of the Project Glasswing collaboration; Lee Klarich, PAN's Chief Product Officer, framed it as a watershed for defensive use of frontier AI.

4.1 Advisory Summary Statistics

26 May 13 Patch Wednesday batch	75 Distinct issues across 130+products	0 May 13 batch: exploited in the wild
9.3 Highest CVSS-BT score	1 Critical-severity CVE	3 High-severity CVEs

An important structural point: CVE-2026-0300 (Captive Portal buffer overflow, CVSS-BT 9.3) is NOT among the 26 CVEs in the May 13 Patch Wednesday batch. It was published as a separate emergency advisory on May 6, eight days earlier. It had already been confirmed to be exploited in the wild and listed in CISA's Known Exploited Vulnerabilities catalog before the May 13 advisory was released. The blog's statement that none of the 26 are being exploited in the wild is therefore accurate — it refers exclusively to the May 13 AI-scan discoveries. CVE-2026-0300 is included in this document's registry because it is part of the same May 2026 advisory cycle and the same frontier AI scanning effort. Still, it sits in a distinct category: a previously exploited vulnerability whose patch timeline was accelerated by the broader advisory release.

Additionally, the blog explicitly notes that the 26 CVEs exclude CyberArk vulnerabilities found by the same AI scan, which are being disclosed through CyberArk's own advisory process. The true scope of the Frontier AI scanning effort is therefore larger than the 26 disclosed through PAN PSIRT channels.

4.2 Complete CVE Registry

The table below lists the 26 entries in the May 2026 advisory cycle: the 25-entry May 13 Patch Wednesday batch (24 CVEs + PAN-SA-2026-0007) plus CVE-2026-0300, published separately on May 6 as an emergency advisory and updated on May 13. The Discovery column reflects the 'Discovered internally' field, confirmed by direct examination of security.paloaltonetworks.com. CyberArk product vulnerabilities identified by the same AI scan are excluded because they are disclosed through CyberArk's advisory process.

CVE / Advisory	Severity	CVSS	Product	Vulnerability class	Discovery
CVE-2026-0300	CRITICAL	9.3	PAN-OS	Buffer overflow — User-ID Captive Portal; unauthenticated root RCE on PA-Series/VM-Series	In production use
CVE-2026-0265	HIGH	7.2	PAN-OS	Authentication bypass when Cloud Authentication Service (CAS) is enabled	Externally

CVE / Advisory	Severity	CVSS	Product	Vulnerability class	Discovery
CVE-2026-0264	HIGH	7.2	PAN-OS	Heap buffer overflow in DNS proxy/server; unauthenticated RCE on PA-Series hardware	Externally
CVE-2026-0263	HIGH	7.2	PAN-OS	Buffer overflow in IKEv2 processing; unauthenticated RCE with elevated privileges or DoS	Internal
CVE-2026-0262	MEDIUM	6.6	PAN-OS	Multiple DoS vulnerabilities in network traffic parsing	Internal
CVE-2026-0248	MEDIUM	6.2	Prisma Access Agent	Improper certificate validation — MitM VPN interception on Android/ChromeOS	Internal
CVE-2026-0261	MEDIUM	6.1	PAN-OS	Authenticated administrator command injection via CLI/Web UI — arbitrary commands as root	Internal
CVE-2026-0242	MEDIUM	6.1	Trust Protection Foundation	SQL injection — database read/modify; privilege escalation to full administrative control	Internal
PAN-SA-2026-0007	MEDIUM	6.1	Prisma Browser	Chromium May 2026 monthly vulnerability bundle (multiple upstream CVEs)	Externally
CVE-2026-0251	MEDIUM	5.9	GlobalProtect App	Local privilege escalation — untrusted search path (CWE-426); non-admin to SYSTEM/root	Internal
CVE-2026-0247	MEDIUM	5.9	Prisma Access Agent	Authorization bypass in Endpoint DLP component; privileged operations on macOS/Windows	Internal
CVE-2026-0246	MEDIUM	5.9	Prisma Access Agent	Local privilege escalation to root/SYSTEM via privilege management flaw	Internal
CVE-2026-0259	MEDIUM	5.0	WildFire WF-500 / WF-500-B	Arbitrary file read and delete (non-FIPS mode)	Internal
CVE-2026-0250	MEDIUM	5.2	GlobalProtect App	Buffer overflow via MitM during portal/gateway exchange; SYSTEM RCE — Windows/macOS/Linux/Android/ChromeOS (not iOS)	Internal
CVE-2026-0244	MEDIUM	5.2	Prisma SD-WAN ION	Improper certificate validation — MitM attacker can impersonate the SD-WAN controller	Internal
CVE-2026-0241	MEDIUM	5.1	Trust Protection Foundation	Multiple authorization bypass vulnerabilities — unauthorized access to restricted resources	Internal
CVE-2026-0249	MEDIUM	4.9	GlobalProtect App	Certificate validation bypass — MitM on macOS/Android/ChromeOS; traffic interception	Internal

CVE / Advisory	Severity	CVSS	Product	Vulnerability class	Discovery
CVE-2026-0243	MEDIUM	4.9	Prisma SD-WAN ION	Denial of service via a crafted IPv6 packet, causing system disruption	Internal
CVE-2026-0239	MEDIUM	4.9	Chronosphere Chronocollector	Unauthenticated information disclosure via collector service exposure	Internal
CVE-2026-0258	MEDIUM	4.8	PAN-OS	SSRF in IKEv2 certificate URL fetching; firewall requests to unintended destinations or DoS	Internal
CVE-2026-0257	MEDIUM	4.7	PAN-OS	Authentication bypass — GlobalProtect portal/gateway (auth override cookies)	Internal
CVE-2026-0240	MEDIUM	4.5	Trust Protection Foundation	Sensitive information disclosure from the vault; credential theft enabling user impersonation	Internal
CVE-2026-0256	MEDIUM	4.4	PAN-OS	Stored XSS in the management web interface	Internal
CVE-2026-0245	MEDIUM	4.3	Prisma Access Agent	Information disclosure — sensitive config data and credentials on macOS/Windows	Internal
CVE-2026-0238	LOW	1.1	Broker VM 30.0	Improper input validation — arbitrary content injection in certificate and key fields	Internal

4.3 Vulnerability Class Analysis

Examining the advisory through a vulnerability-taxonomy lens reveals several significant patterns that speak directly to AI's capability profile and the gaps it fills relative to traditional methods. Comparison with the Mozilla Firefox 150 class distribution in Section 3 is illuminating: the PAN advisory is dominated by network-protocol parsing flaws and supply chain endpoint agent issues. In contrast, Firefox is dominated by browser-specific multi-process UAF — different attack surfaces but the same underlying capability that brings the latent backlog to light.

4.3.1 Memory Corruption / Buffer Overflow (3 CVEs — 1 Critical, 2 High)

The highest-severity cluster comprises three PAN-OS vulnerabilities involving memory corruption in low-level network-protocol handlers: CVE-2026-0300 (Captive Portal buffer overflow, CVSS-BT 9.3, CRITICAL), CVE-2026-0264 (DNS heap overflow RCE, 7.2), and CVE-2026-0263 (IKEv2 RCE, 7.2). Note that CVE-2026-0265, also HIGH-rated, is an authentication bypass in the CAS management interface and is classified separately in Section 4.3.3. This class is historically resistant to traditional discovery approaches: triggering the vulnerable code path requires constructing precise protocol state sequences that are difficult to enumerate using standard fuzzing or static analysis alone.

AI models capable of reasoning over full codebases can hypothesise multi-step state sequences, trace memory allocation and deallocation across complex call graphs, and identify the specific inputs that

would overflow a buffer without executing the code. This capability gap explains why three of these four vulnerabilities appear to have remained undiscovered for years of product development and external security research.

4.3.2 Certificate Validation Failures (3 CVEs)

CVE-2026-0249 (GlobalProtect App — macOS/Android/ChromeOS), CVE-2026-0248 (Prisma Access Agent — Android/ChromeOS), and CVE-2026-0244 (Prisma SD-WAN ION) collectively indicate a systemic failure to enforce certificate validation across endpoint agents and SD-WAN products. All three enable a man-in-the-middle attacker to intercept encrypted communications or impersonate a trusted server. The pattern across three distinct product families suggests the AI model performed a horizontal portfolio sweep — auditing all certificate-validation code paths simultaneously rather than reviewing products in isolation.

This horizontal audit capability is one of the most distinctive advantages of AI-assisted review, and Section 6 below shows that the same capability surfaced the wolfSSL CVE-2026-5194 certificate-forgery flaw in open-source code through an identical pattern of cross-product cryptographic-validation auditing.

4.3.3 Authentication Bypass (3 CVEs: CVE-2026-0265, 0257, 0247)

CVE-2026-0265 (CAS-enabled management interface), CVE-2026-0257 (GlobalProtect portal/gateway with authentication override cookies), and CVE-2026-0247 (Prisma Access Agent Endpoint DLP authorisation bypass) represent failures in authentication controls across multiple layers of the product stack. Authentication bypass vulnerabilities are particularly dangerous because they remove the prerequisite credential requirement for subsequent exploitation, thereby elevating the effective severity of any secondary vulnerability that requires authentication.

4.3.4 Injection Vulnerabilities (2 CVEs)

CVE-2026-0261 (authenticated administrator command injection via CLI/Web UI, CVSS-BT 6.1) and CVE-2026-0242 (SQL injection in Trust Protection Foundation, CVSS-BT 6.1) together highlight that even post-authentication attack surfaces contain exploitable code paths. The SQL injection in Trust Protection Foundation is particularly noteworthy: successful exploitation grants full administrative control of the platform, enabling an attacker to read sensitive data, modify database contents, and escalate privileges — all from an adjacent network position.

4.3.5 Privilege Escalation in Endpoint Agents (2 CVEs: CVE-2026-0251, 0246)

Two CVEs target local privilege escalation across the GlobalProtect and Prisma Access Agent endpoint products: CVE-2026-0251 (GlobalProtect App — Windows/macOS/Linux) and CVE-2026-0246 (Prisma Access Agent). Note that CVE-2026-0247 (Endpoint DLP component) is classified under Authentication Bypass (Section 4.3.3) because its root cause is a missing authorisation check; its impact of enabling privileged operations makes it borderline between the two classes. CVE-2026-0251 is distinguished by its CWE-426 (Untrusted Search Path) root cause: it enables a non-administrative user to escalate to NT AUTHORITY\SYSTEM on Windows and to root on macOS and Linux by exploiting how the application resolves executable or library paths — a class of flaw subtle enough to survive years of standard code review.

4.3.6 Supply-Chain Reach: Trust Protection Foundation, Chronosphere, and Broker VM

Three CVEs affect products at the periphery of Palo Alto Networks' portfolio: Trust Protection Foundation (three CVEs), Chronosphere Chronocollector (one CVE), and Broker VM (one CVE). The inclusion of these products reflects the breadth of the AI scan's coverage across 130+ products — a scope that would be operationally infeasible for a human red team to audit comprehensively within a comparable timeframe. Organisations deploying these ancillary components should not treat them as lower priority simply because they lack PAN-OS branding; the SQL injection in Trust Protection Foundation ranks among the most impactful findings in the entire advisory.

4.4 Attack Vector Distribution and Exploitation Complexity

Of the 24 CVEs (excluding PAN-SA-2026-0007), 10 (42%) are exploitable over the network without adjacency requirements, 9 (38%) require an adjacent network position (subnet access or MitM), and 5 (21%) require local access. Using CVSS-BT scores as published by PAN PSIRT: 1 Critical (CVE-2026-0300, 9.3), 3 High (CVE-2026-0263/0264/0265, all 7.2), 19 Medium, and 1 Low (CVE-2026-0238, 1.1). All network-reachable Critical and High CVEs have Attack Complexity: Low, meaning that once a functional exploit is developed, it can be automated across reachable targets without credential prerequisites.

This attack-complexity profile makes AI-generated exploit tooling particularly dangerous in the hands of adversaries: low-complexity vulnerabilities can be automated at scale, enabling campaign-style exploitation across internet-facing PAN-OS deployments worldwide.

Chapter Findings — PAN PSIRT May 2026

1. The advisory's horizontal portfolio sweep — 75 distinct issues across 130+ products, including components (Trust Protection Foundation, Chronosphere Chronocollector, Broker VM) that human red teams rarely audit in a single engagement — is the clearest illustration of AI's scale advantage over any prior discovery model. The scope is not incremental; it is structurally different.
2. Ten of the 24 CVEs are network-accessible with no adjacency requirement and low attack complexity — an unusually high proportion of immediately weaponisable findings. Combined with the already-exploited CVE-2026-0300 (CISA KEV since 6 May), the advisory represents a high-priority remediation backlog with a short adversary response window.
3. The certificate-validation cluster (three distinct product families: GlobalProtect, Prisma Access Agent, Prisma SD-WAN ION) mirrors the wolfSSL cluster pattern: an AI model sweeping horizontally across every certificate-validation code path simultaneously. Cryptographic validation is the highest-signal target class for frontier model auditing, and the pattern will repeat wherever validation code has been written without systematic cross-portfolio review.
4. CVE-2026-0300's pre-disclosure exploitation changes the risk framing for the entire advisory: it confirms that adversaries are already in the same code-surface territory, not waiting for the AI capabilities to reach them. The 3–5 month planning window is already in effect.

5. Microsoft May 2026 Patch Tuesday: AI-Discovery Across the Windows and Cloud Estate

On 12 May 2026, Microsoft shipped one of the landmark security events of the AI-discovery era. Tom Gallagher, Corporate Vice President at the Microsoft Security Response Center, accompanied the release with a blog post that, for the first time, publicly described an internal multi-model, AI-driven scanning harness as a material contributor to the release, alongside continued human review and external researcher submissions. The release carries three structural signatures of the new era — anomalous volume, anomalous attribution, and an anomalous absence.

5.1 Release Overview and the Zero-Day Anomaly

The release count itself varies across major analyst trackers due to differing inclusion criteria, posing a reconciliation challenge analogous to the PAN cycle. Tenable's Research Special Operations team reports 118 CVEs, omitting the AMD-issued CVE-2025-54518 (an AMD CPU Op Cache corruption issue). CrowdStrike reports 130, including additional Microsoft Edge upstream items and several third-party CVEs that Microsoft surfaces in its tracker. Other trackers (Cybersecurity News, Vulert) cite counts ranging from 120 to 138, depending on whether the count includes upstream items for Microsoft Edge Chromium, Mariner/Linux components, and reissued advisories. This assessment uses Tenable's 118 as the primary count, since it most closely aligns with the set of Microsoft-issued CVEs that include technical advisory content.

118 CVEs in the May 2026 release (Tenable count)	16 Critical-severity CVEs	0 Zero-days exploited or publicly disclosed (first since June 2024)
9.9 Highest CVSSv3 (CVE-2026-33109, Azure Cassandra RCE)	48.3% Elevation of Privilege share	24.6% Remote Code Execution share

The release count of 118 CVEs is within the upper end of the historical Patch Tuesday range — Microsoft's monthly releases averaged approximately 80–110 CVEs across 2024–2025 by Tenable's count, with occasional months reaching 120–130. What makes May 2026 anomalous is not the volume but the attribution pattern and the zero-day absence. The zero-day absence is genuinely anomalous.

For 22 consecutive months — from July 2024 through April 2026 — every Microsoft Patch Tuesday release included at least one CVE that was either actively exploited in the wild at the time of publication or publicly disclosed before the patch was available, with most months carrying two to five such designations and several carrying seven or more. The May 2026 release breaks that streak. This is a single data point and may revert in subsequent months. Two non-exclusive hypotheses are worth considering. The first is that defenders' AI-assisted discovery rate is now competitive with the adversarial research pipeline that has historically produced the steady drumbeat of zero-day exposures: more bugs are being found and patched before any adversary independently rediscovers and weaponises them. The second is that adversaries are conserving high-value exploits for targeted campaigns rather than burning them in opportunistic operations, reducing their visibility in the

in-the-wild telemetry that drives the zero-day designation. The two hypotheses have very different defensive implications, and the data do not yet discriminate between them. Still, the first is at minimum consistent with the broader pattern of AI-accelerated defensive discovery this assessment documents.

5.2 The MSRC Position: A Multi-Model AI-Driven Scanning Harness

Gallagher's blog post is, by Microsoft's typically conservative standards, an unusually direct statement about a change in methodology. The relevant operational claims are: a greater share than usual of issues addressed in the May release were discovered by Microsoft internally rather than externally reported; many of these were surfaced through what Microsoft now describes as its new multi-model AI-driven scanning harness; several externally credited issues were also discovered by researchers working in collaboration with AI; and all such findings moved through the same MSRC validation, prioritisation, and disclosure workflows applied to every report.

The phrase "multi-model" is consequential. It signals a deliberate cadre approach analogous to PAN's combined deployment of Mythos Preview, Claude Opus 4.7, and OpenAI's GPT-5.5-Cyber, and to XBOW's explicit cadre-of-models strategy. The harness is described as part of Microsoft's Secure Future Initiative, which includes expanded validation capacity, automation, and AI-driven prioritisation alongside continued human review. Microsoft has not publicly disclosed which models comprise the harness. Still, third-party reporting (Automox) credits Anthropic researchers by name on at least one critical Windows RCE in this release — a public attribution pattern consistent with the Project Glasswing collaboration model rather than with purely internal tooling.

Three further elements of Gallagher's position warrant defenders' attention. First, Microsoft is not changing its bug bar; severity continues to be grounded in real-world impact and exploitability rather than CVSS in isolation, and the Exploitability Index remains the principal prioritisation signal alongside observed exploitation. Second, Microsoft expects releases to continue trending larger for some time and warns customers to expect more frequent out-of-band updates when warranted. Third, the customer-facing recommendations are the conventional fundamentals — patch cadence, exposure reduction, identity hygiene, segmentation, detection and response — but are explicitly elevated in priority due to the changed discovery rate. The asymmetric implication is that the value of the fundamentals has not changed; the speed at which they must be applied has.

5.3 Critical-Severity CVE Registry

The table below catalogues the critical-severity CVEs in the May 2026 release for which public technical details have been published in MSRC advisories and the analyst tracker community. It is not a claim of completeness for all 16 critical CVEs — several critical entries had not received detailed third-party analysis at the time of this assessment. Still, it covers the highest-impact items defenders should prioritise.

CVE	Severity	CVSS	Product	Vulnerability class/vector	Surface
CVE-2026-33109	CRITICAL	9.9	Azure Managed Instance for Apache Cassandra	Improper access control — low-privileged remote RCE, no user interaction	Cloud
CVE-2026-41089	CRITICAL	9.8	Windows Netlogon	Stack-based buffer overflow — pre-auth network RCE against domain controllers; class echo of SigRed/Zerologon	Internal
CVE-2026-40402	CRITICAL	9.3	Windows Hyper-V	Use-after-free — guest-to-host escape; SYSTEM privileges on the Hyper-V host	Internal
CVE-2026-41103	CRITICAL	9.1	Microsoft SSO Plugin for Jira & Confluence	Authentication bypass — forged sign-in identity without Entra ID authentication; "Exploitation More Likely"	Internal
CVE-2026-33844	CRITICAL	9.0	Azure Managed Instance for Apache Cassandra	Improper input validation — low-privileged remote RCE (user interaction required)	Cloud
CVE-2026-40365	CRITICAL	8.8	Microsoft SharePoint Server	Remote code execution; high-value enterprise data target	Internal
CVE-2026-40361	CRITICAL	8.4	Microsoft Word	Memory corruption via crafted document; Preview Pane attack vector; "Exploitation More Likely"	Internal
CVE-2026-40364	CRITICAL	8.4	Microsoft Word	Memory corruption via crafted document; Preview Pane attack vector; "Exploitation More Likely"	Internal
CVE-2026-40366	CRITICAL	8.4	Microsoft Word	Memory corruption via crafted document; Preview Pane attack vector	Internal
CVE-2026-40367	CRITICAL	8.4	Microsoft Word	Memory corruption via crafted document; Preview Pane attack vector	Internal
CVE-2026-41096	CRITICAL	9.8	Windows DNS Client	Remote code execution in the Windows name-resolution stack	Internal
CVE-2026-33841	HIGH	7.8	Windows Kernel	Local elevation of privilege to SYSTEM or Medium/High integrity; "Exploitation More Likely"	Internal
CVE-2026-35420	HIGH	7.8	Windows Kernel	Local elevation of privilege	Internal
CVE-2026-40369	HIGH	7.8	Windows Kernel	Local elevation of privilege; "Exploitation More Likely"	Internal

Across the 118 release, Tenable's analysis identifies privilege elevation as the dominant exploitation technique (48.3%), followed by remote code execution (24.6%). The Windows kernel alone accounts for three of the EoP items disclosed in the May release, bringing the year-to-date 2026 total to 13. Microsoft Windows received 66 patches in total this month, Office 24, and Azure 16.

5.4 Vulnerability Class Analysis

Applying the same taxonomy method used for the PAN PSIRT and Mozilla Firefox 150 advisories surfaces six dominant defect classes in the May release. The pattern is informative: where PAN was dominated by network-protocol parsing and certificate-validation flaws in network appliances, and Firefox was dominated by multi-process UAF in browser architecture, Microsoft's release is dominated by identity-and-authentication surface, hypervisor-boundary integrity, and document-processing memory corruption — exactly the classes that should be expected from a sweep across a heterogeneous enterprise estate spanning operating system, productivity software, cloud services, and developer tooling.

5.4.1 Identity and Authentication Bypass (CVE-2026-41103)

CVE-2026-41103, the highest-CVSS critical in the SSO Plugin for Jira and Confluence cluster (9.1), is rated "Exploitation More Likely" by Microsoft. An unauthorised attacker can sign in using a forged identity without going through Microsoft Entra ID authentication by sending a specially crafted response message during the login process. The accessible information is limited to what is available to the authorised user on the targeted servers. Still, for organisations using the SSO plugin to bridge Atlassian collaboration tools to their corporate identity provider, this is a direct identity-perimeter breach. The class of bug — a missing or incorrect identity-claim validation in a federated-authentication path — is consistent with the wolfSSL CVE-2026-5194 root cause in Section 6: both are validation-omission flaws in code that nominally enforces a cryptographic or identity invariant. The horizontal-portfolio audit pattern that AI scanners produce surfaces both.

5.4.2 Pre-Auth Network RCE in Core Windows Services (CVE-2026-41089, CVE-2026-41096)

Two CVEs in this class warrant the highest-priority defensive response from any organisation operating Windows infrastructure:

- **CVE-2026-41089 (Windows Netlogon, CVSS 9.8)** is a stack-based buffer overflow in the Netlogon authentication process. A remote, unauthenticated attacker can exploit it by sending a crafted network request to a Windows Server running as a domain controller, resulting in code execution on the DC. Microsoft has assessed this as "Exploitation Less Likely" despite the near-perfect CVSS score. Still, multiple analyst trackers explicitly compare its impact class to SigRed (CVE-2020-1350) and Zerologon (CVE-2020-1472) — both of which became major incident drivers within weeks of disclosure once practical exploit chains were published.
- **CVE-2026-41096 (Windows DNS Client)** is a remote code execution vulnerability in the Windows name-resolution stack. Microsoft has not published a CVSS score in the publicly summarised material. Still, the surface — name resolution, touched by every Windows client and server during normal operation, makes this a high-priority enterprise patch regardless of the headline score.

Pre-auth network RCE in core OS-level services is the highest-impact CVE class in the May release. Both flaws sit in code paths that have been audited for decades; their identification at this scale reflects the same dormant-defect surfacing pattern documented in the Mozilla 15- and 20-year-old bugs in Section 3.

5.4.3 Office Document RCE via Preview Pane (CVE-2026-40361, 40364, 40366, 40367)

Four critical Word RCEs (all CVSS 8.4) form the largest single-product critical cluster in the release. All four are exploitable through the Office Preview Pane — meaning the user does not need to open the malicious document for code execution; rendering the message in Outlook is sufficient. Microsoft has assessed CVE-2026-40361 and CVE-2026-40364 specifically as "Exploitation More Likely". The Preview Pane attack vector is the canonical click-to-open shape that drives high-volume initial-access campaigns; mass-mail delivery of a single crafted document can compromise any recipient whose Outlook is configured to preview attachments by default.

The class signature here — multiple closely related memory-corruption flaws surfaced in the same Office release — is the document-parser equivalent of the PAN advisory's certificate-validation cluster: a horizontal sweep across a single semantic surface (in this case, Word document parsing) that yields multiple findings simultaneously. The defensive implication is identical: where one such flaw exists in a parser, others are likely present and may be discoverable by adversaries applying the same pattern post-disclosure.

5.4.4 Hypervisor Escape — Hyper-V Use-After-Free (CVE-2026-40402)

CVE-2026-40402 (CVSS 9.3) is a use-after-free vulnerability in Windows Hyper-V that enables a guest-to-host escape, allowing an attacker who has compromised a guest virtual machine to gain SYSTEM privileges on the Hyper-V host. The host's tenant footprint determines the blast radius. In a multi-tenant private cloud or Azure Stack environment, a single guest compromise via this CVE compromises every co-located workload on the same host. The class is structurally analogous to the Mozilla in-process RLBox sandbox bypass (Section 3.3.3) — both target an isolation boundary that the architecture treats as a primary defence — but the consequences are commensurately larger because the Hyper-V boundary separates independent tenants rather than processes within a single application.

This class of bug is among the most operationally significant findings in the entire May 2026 cycle for enterprises running virtualised infrastructure. The Mozilla finding that architectural prototype-freezing thwarted observed Mythos prototype-pollution attempts (Section 3.5) is directly relevant: Hyper-V hardening investments — VM-level network segmentation, separation of the management plane from tenant workloads, attestation-gated host updates — provide the kind of architectural mitigation leverage that no per-bug patch can substitute for.

5.4.5 Windows Kernel Elevation of Privilege (CVE-2026-33841, 35420, 40369)

Three Windows Kernel elevation-of-privilege CVEs (all CVSS 7.8, all rated Important) ship in the May release. CVE-2026-33841 and CVE-2026-40369 are rated "Exploitation More Likely". The kernel EoP class is the standard ingredient in post-compromise exploit chains — a sandbox escape, browser RCE, or initial access foothold is paired with a kernel EoP to escalate from user-level to SYSTEM, thereby enabling durable persistence and lateral movement. Including these three, Microsoft has now disclosed 13 Windows Kernel EoP vulnerabilities in 2026 year-to-date — a cadence consistent with the broader pattern of horizontal AI-driven sweeps across mature codebases.

5.4.6 Cloud Service RCE — Azure Managed Instance for Apache Cassandra (CVE-2026-33109, 33844)

Two critical RCE vulnerabilities affect Azure Managed Instance for Apache Cassandra: CVE-2026-33109 (CVSS 9.9) is an improper access control flaw that enables low-privileged remote code execution without user interaction; CVE-2026-33844 (CVSS 9.0) is an improper input validation flaw that enables low-privileged remote code execution with user interaction required. Microsoft has confirmed that it proactively remediated these vulnerabilities within its cloud infrastructure, so the principal customer-side action is verification rather than patching. Operationally, the cluster illustrates that the AI discovery pattern extends beyond Microsoft's on-premises products into the cloud services portfolio — and that the same multi-model harness applied to first-party cloud code will continue to surface critical findings that customers will only see as proactively remediated advisories rather than patch deployments.

5.4.7 Secure Boot and Security-Feature Bypass

The May release includes multiple Secure Boot and security-feature bypass items, surfacing in TCP/IP, Secure Boot itself, and related components. The class signature is consistent with what AI-assisted reasoning surfaces well: code paths where a security control is technically present but does not enforce the invariant that a developer presumed. The Secure Boot context is further complicated by ongoing UEFI certificate expiration and revocation management; organisations running environments with third-party bootloaders should treat Secure Boot policy review alongside the May patches as a single workstream.

5.5 Discovery Attribution and the AI Signature

Three attribution patterns in the May release distinguish it from prior cycles and warrant explicit observation:

- Microsoft's blog explicitly attributes a greater-than-usual share of internal discovery to its new multi-model, AI-driven scanning harness — the first time MSRC has publicly named AI tooling as a material contributor to a Patch Tuesday cycle.
- Third-party reporting credits Anthropic researchers by name on at least one critical Windows RCE in this release, indicating the same partner-disclosure pattern visible in the Mozilla, PAN, and wolfSSL cases is now present in Microsoft's pipeline.
- Externally-credited researchers are increasingly described as working in collaboration with AI — paralleling Mozilla's observation that the technique is no longer rare and that defenders without an AI-augmented pipeline are increasingly disadvantaged.

The combination — internal multi-model harness, partner-credited external discovery, and AI-augmented external researchers all contributing simultaneously — is the clearest single-cycle illustration that AI-assisted vulnerability discovery has moved from a frontier capability to a standard component of mature vendor security pipelines. Microsoft, by virtue of its release scale and ecosystem reach, makes this transition visible in a way that any single-vendor case study cannot.

Implication for Defenders: The Microsoft May 2026 release establishes three planning baselines. First, expect every major vendor to be running a comparable AI-driven scanning pipeline by the end of 2026, with corresponding increases in Patch Tuesday volume. Second, prioritise pre-auth network RCE in identity infrastructure (Netlogon-class) and hypervisor-boundary integrity (Hyper-V-class) above the headline CVSS sort — these are the classes where a single bug enables campaign-scale compromise. Third, treat the zero-day absence as a one-month signal, not a trend, but plan capacity for the case where AI-driven discovery is in fact outpacing the adversarial pipeline; the upside is real, but the patch and detection bottleneck must be ready to absorb the volume.

Chapter Findings — Microsoft May 2026 Patch Tuesday

1. The first zero-day-free Patch Tuesday in 22 months is a single data point, not a trend. Still, it is the first empirical signal that defenders' AI-assisted discovery is temporarily outpacing the adversarial research pipeline. Two hypotheses are live: AI is closing the discovery gap, or adversaries are conserving high-value exploits. The defensive implications differ, and both should be planned for.
2. Microsoft's multi-model harness description, Anthropic researcher attribution on critical Windows RCEs, and explicit forward guidance of continued volume growth together confirm this is a permanent architecture change, not a single-cycle anomaly. Every enterprise should update its expectations for Patch Tuesday absorption capacity accordingly.
3. The 118-CVE horizontal sweep — spanning Windows kernel, Hyper-V, Netlogon, DNS Client, Office, Azure managed services, .NET, ASP.NET Core, Visual Studio Code, and Teams — establishes the breadth baseline for AI-era Patch Tuesdays. Portfolio breadth, not just severity depth, is now a standard feature of vendor patch cycles.
4. The Hyper-V use-after-free (CVE-2026-40402, CVSS 9.3) is the highest-impact finding for virtualised infrastructure. A guest-to-host escape in a multi-tenant environment compromises every co-located workload. Architectural segmentation — not just patching — is the correct long-horizon response.

6. wolfSSL: A Cryptographic Library Comprehensively Audited

wolfSSL is the fourth major case study in this assessment and the only one drawn entirely from Anthropic's open-source scanning programme rather than from a Glasswing commercial partner engagement. It earns standalone treatment for three reasons: it is the case in which Mythos Preview went furthest end-to-end — from code analysis through to a working exploit that was validated by the vendor and patched — the ten CVEs it produced span the widest range of cryptographic-library vulnerability classes of any single target in this assessment, and its blast radius reaches an estimated five billion devices including categories of embedded hardware (automotive infotainment, military systems, industrial controllers) that receive essentially no other AI-assisted security coverage. The analysis applies the same PAN-taxonomy method used in Sections 3 through 5.

6.1 Background: What wolfSSL Is and Why It Matters

wolfSSL (formerly CyaSSL) is a compact, portable TLS/SSL library written in C, designed specifically for resource-constrained environments where OpenSSL would be too large or too slow. According to the wolfSSL project's own estimates, the library is deployed in more than five billion devices and applications worldwide. That estimate spans an extraordinary range of deployment contexts:

- Consumer IoT: smart home sensors, smart thermostats, home routers, network-attached storage
- Automotive: infotainment systems, telematics units, over-the-air update infrastructure
- Industrial and operational technology: industrial controllers, SCADA communication components, embedded PLCs
- Aerospace and defence: mission-critical systems requiring export-compliant cryptography
- Mobile and server software: applications, cloud services, and middleware using wolfSSL for embedded TLS

wolfSSL is also open-source, audited, and FIPS 140-2 validated for specific builds — meaning it occupies an unusual position in the security ecosystem: it is a security library, explicitly designed and marketed based on cryptographic correctness, with a well-resourced vendor team whose primary obligation is to ensure that the library's cryptographic guarantees hold. The finding of ten CVEs spanning four vulnerability classes in a single AI-driven audit pass is therefore not merely notable for the quantity; it directly falsifies a prior implicit assumption that wolfSSL's explicit security focus and FIPS validation processes had exhausted the latent defect backlog. For scale of reference: Heartbleed (CVE-2014-0160) affected approximately 17% of HTTPS web servers at the time of disclosure, making it the canonical large-scale TLS library vulnerability. wolfSSL's five-billion-device footprint is an order of magnitude larger in raw device count, though predominantly in embedded and non-browser contexts where per-device credential exposure and exploitability prerequisites differ. The more relevant comparison is that Heartbleed also sat undiscovered in a professionally maintained, frequently audited security library for over two years — and a comparable latency applies to at least two of the wolfSSL CVEs.

6.2 Summary Statistics

10 CVEs across 4 vulnerability classes	9.3 / 10.0 NVD / Red Hat CVSS for anchor CVE-2026-5194	~5 billion Devices in the blast radius
1 Critical, 7 High, 1 Low, 1 Info 1 Critical · 7 High · 1 Low · 1 Info (wolfSSL/NVD classification)	0 Known exploited in the wild at disclosure	wolfSSL 5.9.1 Patch version (released 8 April 2026)

6.3 Complete CVE Registry

The following ten CVEs were identified by the Mythos Preview scan of the wolfSSL codebase and are published on the Frontier Red Team coordinated-disclosure dashboard; all are past their disclosure window as of the 22 May snapshot. CVSS scores are published only for CVE-2026-5194 in the sources available to this assessment; severity ratings for the remainder reflect the dashboard's classifications. All ten share a single patch baseline — wolfSSL version 5.9.1, released 8 April 2026.

CVE	Severity	CVSS	Vulnerability class	Technical summary and attack context	Discovery
CVE-2026-5194	CRITICAL	9.1 (NVD)	Signature bypass — improper cert validation	ECDSA/DSA/ML-DSA/Ed25519/Ed448: missing hash-size and OID checks allow undersized digest acceptance; Mythos Preview constructed working certificate-forgery exploit; ~5 billion devices	Anthropic +Calif.io *
CVE-2026-5503	CRITICAL	9.1 (NVD)	Heap buffer overflow	TLSX_EchChangeSNI: attacker-controlled publicName pollutes shared WOLFSSL_CTX extensions; TLSX_SNI_Write copies 255 bytes past allocation boundary; inner ClientHello sized before pollution but written after	Calif.io *
CVE-2026-5466	HIGH	8.1 (NVD)	Signature bypass — ECCSI	wc_VerifyEccsiHash: r and s scalars decoded with no check, they lie in [1, q-1]; crafted forged signature verifies against any message for any identity using only public constants	Calif.io *
CVE-2026-5501	HIGH	8.1 (NVD)	Improper cert validation	wolfSSL_X509_verify_cert (OpenSSL compat layer): leaf signature not checked when attacker supplies untrusted intermediate with CA:FALSE. Free DV cert suffices to forge any domain. Native TLS handshake path unaffected.	Calif.io *
CVE-2026-5479	HIGH	8.1 (NVD)	AEAD auth failure	EVP ChaCha20-Poly1305 decrypt path: Poly1305 authentication tag computed but never verified; wolfSSL_EVP_CipherFinal returns plaintext regardless of MAC validity	Calif.io *

CVE	Severity	CVSS	Vulnerability class	Technical summary and attack context	Discovery
CVE-2026-5477	HIGH	7.5 (NVD)	Integer overflow → AES-EAX / CMAC bypass	AES-EAX AEAD and CMAC: 32-bit totalsz counter wraps at 4 GiB; attacker who observes one valid (ciphertext, tag) pair for a >4 GiB message can replace the first 4 GiB arbitrarily while tag still verifies	Calif.io *
CVE-2026-5447	HIGH	7.5 (NVD)	Heap buffer overflow	CertFromX509: heap buffer overflow via AuthorityKeyIdentifier size confusion in certificate parsing path	Anthropic *
CVE-2026-5446	HIGH	7.1 (NVD)	Crypto failure — nonce reuse (limited scope)	ARIA-GCM nonce reuse in TLS 1.2 / DTLS 1.2. Affects only non-default opt-in builds using --enable-aria and the proprietary MagicCrypto SDK (Korean regulatory deployments). AES-GCM is unaffected. NVD CVSS 0.	Anthropic *
CVE-2026-5500	MEDIUM	5.9 (NVD)	AEAD auth failure — GCM tag truncation	wc_PKCS7_DecodeAuthEnvelopedData: accepted attacker-controlled GCM tag lengths down to 1 byte, reducing integrity from 128-bit to 8-bit; MitM can forge with 1-in-256 probability per attempt	Calif.io *
CVE-2026-5448	MEDIUM	4.3 (NVD)	Heap buffer overflow (compat API only)	wolfSSL_X509_notAfter / wolfSSL_X509_notBefore: 2-byte heap overflow parsing malformed X.509 date fields via OpenSSL compat layer. wolfSSL notes: only triggered by calling these APIs directly; TLS and certificate verify operations in wolfSSL are not affected.	Anthropic *

* All CVEs attributed to PR #10102: Calif.io (Thai Duong, Bronson Yen) in collaboration with Nicholas Carlini (Anthropic). See Section 6.6 for individual commit attribution.

† CVSS scores are shown where published by NVD or the assigning CNA. wolfSSL's 5.9.1 release notes assigned High/Low severity labels to most cluster members without numerical CVSS scores. CVE-2026-5194 (NVD: 9.3; Red Hat: 10.0) and CVE-2026-5501 (CVSSv4: 8.6, sourced from Anonhaven technical analysis) are the two exceptions with confirmed numerical scores.

6.4 Vulnerability Class Analysis

Applying the same taxonomy framework used for the PAN PSIRT and Firefox 150 advisories, the ten wolfSSL CVEs resolve into four structurally distinct defect classes. The class distribution is analytically important: three of the four classes (signature bypass, AEAD failure, integer overflow) are logic-level correctness errors — not memory-safety bugs. They produce no crash, no sanitizer alert, and no fuzzer signal. They are detectable only by reasoning about what the code should guarantee cryptographically and then identifying the code path where that guarantee is not enforced. This is precisely the capability that sets code-reasoning AI apart from all prior automated security tooling.

6.4.1 Signature Bypass / Improper Certificate Validation (3 CVEs: CVE-2026-5194, 5466, 5501)

The highest-severity class groups three CVEs in which the library performs a cryptographic signature verification operation but omits or misapplies a required validation check, allowing a maliciously crafted certificate to be accepted as legitimate.

CVE-2026-5194 (Critical, CVSS-NVD 9.3 / Red Hat 10.0) is the anchor finding. wolfSSL accepted ECDSA certificate signatures whose hash digest was smaller than the algorithm requires. The library checked whether the signature was mathematically consistent, but never confirmed that the digest was the right size for the relevant key type. The flaw affects ECDSA/ECC, DSA, ML-DSA, Ed25519, and Ed448. A Mythos Preview exploit constructed a forged certificate with a deliberately truncated digest; wolfSSL accepted it as cryptographically valid. An attacker positioned between a vulnerable device and a server it trusts — via same-network MitM, BGP-level traffic redirection, or control of a network gateway — can present this forged certificate to impersonate any server, including banking domains, firmware update services, or cloud platforms. The device accepts the connection as legitimate.

CVE-2026-5466 (High) is an ECCSI signature-forgery primitive. The ECCSI (Elliptic Curve-based Certificateless Signatures for Identity-Based Encryption) verification function accepted a forged signature when s was zero, missing, or equal to r — a boundary condition that the verification logic was required to reject but did not check. ECCSI is used in identity-based cryptographic protocols that underpin authenticated communications in certain military and enterprise contexts, making this an important-class finding even though it is less widely deployed than the ECDSA path.

CVE-2026-5501 (High, CVSSv4 8.6) is a bypass of wolfSSL's own X.509 certificate chain verification function (`wolfSSL_X509_verify_cert`), specifically in the leaf-certificate signature check. A certificate chain that should fail verification due to an invalid leaf signature instead passes it. This bug affects any wolfSSL deployment that performs certificate-chain validation at the application layer using the high-level API.

The unifying root cause across all three CVEs is a validation-omission pattern: the cryptographic math runs, but a required pre-check or post-check on the inputs or outputs is absent. These bugs share a structural signature — the code does most of what it should, but a specific mandatory invariant is never enforced. This is precisely the class of bug that reasoning over the cryptographic specification reveals, but differential execution (fuzzing) cannot detect, because the library returns success rather than crashing.

6.4.2 AEAD / Authenticated Encryption Failure (2 High + 1 Info: CVE-2026-5479, 5500, 5446)

Authenticated Encryption with Associated Data (AEAD) is the standard by which modern TLS ensures that the ciphertext cannot be tampered with: decryption should fail if the authentication tag does not match. Three wolfSSL CVEs represent failures in this guarantee — the authentication tag is either never checked, accepted in truncated form, or the nonce that ensures uniqueness is reused.

CVE-2026-5479 (High) is the most direct implementation failure: in the EVP (high-level OpenSSL-compatible API) implementation of ChaCha20-Poly1305, the Poly1305 authentication tag is computed during encryption but never verified during decryption. The decrypt operation succeeds and returns plaintext regardless of whether the ciphertext has been tampered with. An attacker who intercepts a TLS session using this cipher suite can modify the ciphertext without detection.

CVE-2026-5500 (High) is a GCM tag-truncation attack in the CMS (Cryptographic Message Syntax) AuthEnvelopedData path. GCM mode requires a full 128-bit authentication tag; wolfSSL's CMS implementation accepted truncated tags, substantially reducing the cryptographic work an attacker must perform to produce a valid forgery. An attacker who can supply crafted CMS content can forge authenticated messages.

CVE-2026-5446 (NVD: Info / CVSS 0) is a nonce-reuse flaw restricted to a non-default opt-in build configuration. It is in ARIA-GCM within TLS 1.2 record encryption. GCM's security model requires that nonces never be reused under the same key; nonce reuse enables an attacker to recover the XOR of two plaintext blocks and, with enough reused-nonce observations, recover keys. This is a state-management error rather than an omitted check, but the impact class — violation of authenticated confidentiality — is the same.

The class pattern is structurally distinct from Class 6.4.1 (signature bypass) but analytically similar. In each case, a specific cryptographic guarantee is undermined not by breaking the underlying mathematics but by failing to enforce a protocol-level invariant. AEAD authentication should be a hard invariant in any TLS implementation; all three CVEs represent paths where that invariant was misimplemented in wolfSSL's specific API layer. Finding these requires reasoning about the guarantee the API is supposed to provide and then auditing every implementation path for gaps — a task well-suited to code reasoning and invisible to fuzzers because no crash occurs.

6.4.3 Integer Overflow Enabling Cryptographic Bypass (1 CVE: CVE-2026-5477)

CVE-2026-5477 (High) is a 32-bit integer overflow affecting both AES-EAX AEAD mode and CMAC operations in wolfSSL. The vulnerability is in the internal tracking of the total accumulated input byte count (totalsz): once this 32-bit counter wraps at 4 GiB, the MAC computation restarts from a state that does not reflect the full input. The practical attack is a prefix-substitution forgery: an attacker who observes a single valid (ciphertext, tag) pair for a message longer than 4 GiB can arbitrarily replace the first 4 GiB of the ciphertext, and the authentication tag will still verify. The impact on AES-EAX AEAD is the most severe because AES-EAX provides both confidentiality and integrity guarantees that are entirely undermined at the 4 GiB boundary.

The root cause is a length counter that was never declared with sufficient width for the data volumes that the code might process. This is a class of bug that static analysis tools often flag but frequently miss in practice because the overflow condition requires specific large-input scenarios. AI-driven code reasoning can identify the wrap condition by reasoning about the type and likely data volumes without triggering overflow during execution.

6.4.4 Heap Buffer Overflow in Certificate and Protocol Parsing (3 CVEs: CVE-2026-5447, 5448, 5503)

Three CVEs are memory-safety bugs in certificate-field and TLS-extension parsing — the class that traditional fuzzing is specifically designed to catch.

CVE-2026-5448 (Low — wolfSSL classification; scope-limited to OpenSSL compat API only, not TLS operations) is a 2-byte heap overflow in the certificate date-field parsing functions (wolfSSL_X509_notAfter / wolfSSL_X509_notBefore). A malformed certificate with out-of-bounds date fields triggers a 2-byte write past the heap allocation boundary. Small heap overflows can often be exploited for memory-corruption primitives, depending on the heap layout.

CVE-2026-5503 (High) is a heap overflow in wolfSSL's Encrypted Client Hello (ECH) extension parsing, triggered by a length miscalculation in PublicName or SNI policy handling. ECH is a relatively recent TLS extension for encrypting the SNI field; its implementation in wolfSSL is newer code that may have had less fuzzing coverage than the core certificate path.

CVE-2026-5447 (High — wolfSSL release notes) is a heap buffer overflow in CertFromX509 via AuthorityKeyIdentifier size confusion in the certificate-parsing path available at the time of this assessment.

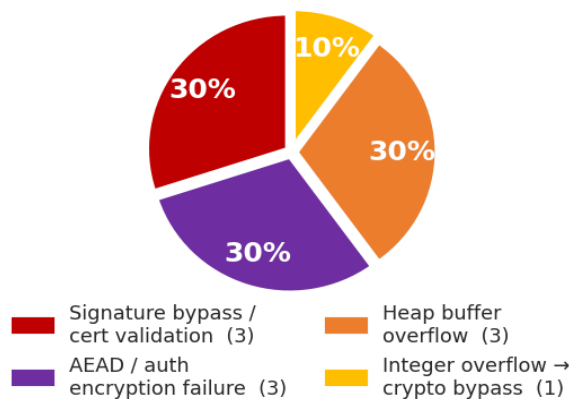
The presence of heap-overflow bugs in a library that has presumably been exposed to fuzzing for years indicates either incomplete fuzz coverage of the specific ECH and certificate-date code paths, or that the trigger conditions require a specific protocol context that available fuzzers did not generate. This is consistent with the pattern observed in the Mozilla Firefox 150 disclosure: memory-safety bugs in code paths that require specific protocol state sequences to trigger, and that resist standard mutation-based fuzzing, even in heavily fuzzed codebases.

6.4.5 Class Summary

Vulnerability class	CVEs	Why AI found it / why prior tooling missed it
Signature bypass / improper cert validation	3	Logic-level omission in validation path; produces no crash, no sanitizer alert, invisible to fuzzers; detectable only by reasoning about the cryptographic guarantee
AEAD / authenticated encryption failure(2 High + 1 Info/limited scope)	3	Missing or bypassed MAC check (CVE-2026-5479, 5500: High); nonce reuse in non-default Korean regulatory builds only (CVE-2026-5446: NVD Info/CVSS 0). No crash; requires reasoning about the authentication invariant
Integer overflow → AES-EAX/CMAC bypass	1	32-bit totalsz wraps at 4 GiB boundary; prefix-substitution forgery on AES-EAX and CMAC; requires reasoning about data-volume edge cases invisible to static analysis
Heap buffer overflow (cert/protocol parsing)(2 High + 1 Low)	3	CVE-2026-5447/5503 (High): CertFromX509 and ECH extension parsing. CVE-2026-5448 (Low, compat API only): X.509 date fields. Memory-safety class fuzzing should have caught it; it was missed due to incomplete coverage of ECH and cert-date paths.

wolfSSL Vulnerability Cluster — Why AI Finds What Fuzzers Miss

wolfSSL: 10 CVEs by Vulnerability Class



6.5 Attack Vector Distribution and Exploitation Complexity

The wolfSSL attack vector profile differs fundamentally from the PAN PSIRT and Microsoft advisory profiles. Where those advisories include a mix of network-remote, adjacent, and local-access vulnerabilities, every wolfSSL CVE operates in the TLS handshake and record-layer context — meaning all are network-exploitable in principle, and the attacker position and preconditions are defined by the protocol role (client versus server) and whether a MitM position is required.

CVE cluster	Attacker position required	Attack complexity and exploitation path
CVE-2026-5194, 5466, 5501 (cert forgery/chain bypass)	MitM (network-adjacent or BGP-level)	Craft forged cert; intercept outbound TLS connection and present forged cert in server role. No user interaction required. Complexity: Low once an exploit is developed.
CVE-2026-5479, 5500, 5446 (AEAD failure)	MitM or malicious server/client	Intercept and modify ciphertext (5479); supply crafted CMS content (5500); observe nonce-reused sessions (5446). No user interaction required. Complexity: Low to Medium.
CVE-2026-5477 (CMAC integer overflow)	Attacker controls input data volume	Requires the ability to supply >2 GB of data to a CMAC-based verification function. Scenario-dependent; more relevant in long-session or bulk-transfer contexts.
CVE-2026-5447, 5448, 5503 (heap overflow)	Malicious certificate or TLS extension	Deliver a malformed certificate or a crafted ECH extension to a wolfSSL client or server. The exploitation path depends on heap layout; it likely requires additional stabilisation work.

A structural observation holds across the entire cluster: every CVE affects code that runs before TLS connection establishment completes. All occur in the handshake or early record-processing paths, before any application-layer authentication or session protection has been negotiated. This means that applications which assume their TLS library provides a secure channel before they begin exchanging credentials or sensitive data have that assumption violated at the library level. The blast radius of the

signature-bypass and AEAD-failure classes is therefore as large as the set of applications and devices that rely on wolfSSL for TLS without independent certificate pinning or MAC verification at the application layer — which, in most embedded deployments, describes the entire attack surface.

6.6 Discovery Attribution: Open Source, Public Repository, and End-to-End AI Exploit

Three features of discovery attribution are of practical importance to defenders planning their own AI-assisted audit programmes.

First, the primary discovery precondition is public: wolfSSL's source code is available on GitHub under an open-source license. No confidential access, no partner relationship, and no live-system access were required for the initial vulnerability discovery phase. Mythos Preview performed a pure source-code analysis of publicly accessible code. This means that any adversary with access to a Mythos-class model can run an identical scan against the same public repository at any time. There is no proprietary access barrier protecting this attack surface.

Second, the exploit construction for CVE-2026-5194 was performed by Mythos Preview itself, not by a separate human researcher using the model as a tool. Nicholas Carlini (Anthropic) and Thai Duong (Calif.io) validated the finding and managed coordinated disclosure; the model constructed the working exploit that forged a certificate accepted by a vulnerable wolfSSL instance. wolfSSL's 5.9.1 release credits PR #10102 to Calif.io in collaboration with Claude and Anthropic Research. At the individual commit level, the X.509 fix is attributed to Carlini and Thai Duong; the ECCSI and ChaCha20-Poly1305 commits credit Carlini with Bronson Yen (Calif.io); the AES-EAX/CMAC and ECH commits carry both Thai Duong and Carlini. This is the closest publicly available example of a frontier model independently completing the full discovery-through-weaponisation chain without human exploit-development assistance, with the joint team managing disclosure rather than constructing the exploit.

Third, the other nine CVEs in the cluster are attributed to the same Mythos Preview open-source scanning programme rather than to a specific named researcher. This is consistent with an automated sweep of the full wolfSSL codebase, in which the model identified all ten issues in a single pass. The pattern of multi-class, multi-instance findings from a single automated run is itself a capability demonstration — it confirms that the ten CVEs are not the product of a focused researcher who knew to look in the signature-verification code, but of a model that systematically audited the entire library and surfaced all detectable issues simultaneously.

6.7 Patch Status, Blast Radius, and the Remediation Challenge

wolfSSL version 5.9.1, released 8 April 2026, addresses all known CVEs in the cluster. For software that dynamically links wolfSSL via a system package manager, the remediation path is straightforward: update the package. For the vast majority of affected devices, however, the path is substantially more complex.

wolfSSL is overwhelmingly deployed via static linking — embedded directly into vendor firmware images, appliance binaries, or application bundles rather than as a shared system library. A static-linked wolfSSL instance does not benefit from system-level package updates. The fix must be incorporated into a vendor rebuild of the firmware or application, distributed to the device, and applied

through whatever update mechanism (if any) the device supports. For each category in wolfSSL's five-billion-device deployment footprint, the remediation timeline looks different:

- **Consumer routers and IoT devices:** Firmware update availability depends on the vendor's support lifetime. Many consumer devices will never receive an update addressing CVE-2026-5194 or any cluster member because the vendor has ended support or the device lacks an update mechanism entirely.
- **Automotive infotainment systems:** Firmware updates require OEM validation and dealership service visits or OTA infrastructure. Update cycles are typically measured in months to years, not days.
- **Industrial and OT systems:** Firmware updates in safety-critical environments require change-management processes and system downtime; many operators will delay patching indefinitely or accept compensating controls instead.
- **Military and aerospace systems:** Qualification and certification requirements may prevent the rapid redeployment of patched firmware, even when a patch is available.
- **Server and application software:** If wolfSSL is dynamically linked, package updates are fast. If statically compiled into an application binary, the application must be rebuilt and redeployed — a process that varies from hours (for cloud services with CI/CD) to months (for enterprise software with formal release cycles).

The practical consequence is that CVE-2026-5194 and its cluster siblings will remain active on a substantial fraction of in-scope devices for years, even though the vendor patch has been available since April 2026. This is not a failure of the Glasswing programme or Anthropic's disclosure process — the bugs were found and patched months before any known exploitation — but it is a reminder that vulnerability discovery and patch availability are only the first two steps of a remediation pipeline whose last step (widespread deployment) can take arbitrarily long in embedded hardware contexts.

Implication for Defenders: For any device, application, or service that uses wolfSSL: (a) verify the wolfSSL version against the full cluster, not just CVE-2026-5194; (b) if statically linked, identify the vendor firmware rebuild status, not the OS package version; (c) where firmware updates are unavailable or delayed, apply network isolation, TLS interception monitoring, and certificate-pinning at the application layer as compensating controls; (d) review wolfSSL-using services that perform AEAD decryption — CVE-2026-5479 means the Poly1305 tag was never verified pre-patch, meaning all data received over those sessions should be treated as potentially unverified.

6.8 What wolfSSL Tells Us About AI and Cryptographic Code

The wolfSSL case is analytically distinct from the other four major case studies in this assessment due to the nature of its target. PAN PSIRT, Firefox 150, and Microsoft Patch Tuesday all involve large, multi-component codebases, in which the AI's breadth of horizontal coverage is the primary demonstration of its capability. wolfSSL is a single, focused library with a well-defined security purpose, a small, expert development team, and an established audit history. The ten CVEs found in a single pass, therefore, speak directly to the depth of reasoning, not the breadth of coverage.

Three of the four vulnerability classes (signature bypass, AEAD failure, integer overflow) produce no observable crash and generate no fuzzer signal. They are detectable only by reasoning about what the cryptographic specification requires and then identifying the code paths where that requirement is not enforced. This is not a task that pattern-matching or mutation testing can reliably perform. It requires the same kind of careful reading a human expert would apply to a code review — but applied simultaneously to every relevant function in the library, without the attention drift or scope limitation that constrains a human audit.

The wolfSSL cluster, therefore, provides the clearest evidence available in this assessment for the specific mechanism by which Mythos Preview adds value over prior automated tools: it is not primarily about faster, more parallel fuzzing. It is a qualitatively different analytical capability applied to a class of bugs that fuzzing cannot structurally find. This distinction matters for defenders planning AI-assisted audit programmes: the investment case is strongest for codebases — cryptographic libraries, authentication modules, certificate verification code, session management — where logic-level correctness is the security requirement and memory safety is secondary. In retrospect, wolfSSL was exactly the right kind of target.

Chapter Findings — wolfSSL CVE Cluster

1. Seven of ten CVEs are logic-level cryptographic correctness failures that produce no crash, no sanitiser alert, and no fuzzer signal. These are detectable only by reasoning about what the cryptographic specification requires and identifying where the code fails to enforce it. This is a qualitatively new capability — not faster fuzzing, but a structurally different analysis mode that prior automated tools cannot replicate.
2. Mythos Preview completed the full discovery-through-weaponisation chain for CVE-2026-5194: code analysis, exploit construction, and working proof-of-concept, before any known adversarial exploitation. This is the clearest documented case of an AI model independently closing the gap between vulnerability discovery and the weaponisation of an exploit.
3. The blast radius — an estimated five billion devices, including automotive, military, industrial, and consumer IoT — is the largest of any single finding in this assessment. wolfSSL's predominant static-linking deployment model means the patch exists, but most affected embedded devices will never receive it. This is the longest-horizon risk item in the May 2026 disclosure cycle.
4. Cryptographic libraries, authentication modules, and certificate-verification code are the highest-signal target class for frontier model auditing. Defenders should prioritise these regions for initial AI-assisted coverage — logic-level failure modes are both more detectable by AI and more impactful when found than general memory-safety bugs.

7. Independent Evaluation: XBOW's Offensive Security Assessment of Mythos Preview

XBOW, an AI-native offensive security firm, received early access to Mythos Preview and conducted a structured two-month evaluation published on 12 May 2026. Their methodology is independent of and complementary to PAN's Project Glasswing work, in which PAN assessed Mythos as a defensive scanning tool applied to its own codebase. XBOW evaluated Mythos as an offensive capability applied to external targets — specifically, live websites and open-source applications with known vulnerabilities. Their findings illuminate both the model's genuine capabilities and its practical limitations.

7.1 Methodology

XBOW assembled a team of ten security experts. It evaluated Mythos Preview through several distinct lenses: standardised benchmarks (the same as those used for Opus 4.6 and GPT-5.5-Cyber evaluations), interactive use with open-source applications and XBOW's own codebase, judgment assessment across threat modelling and command safety, and specialist analysis of native-code and reverse-engineering tasks.

An important definitional distinction: XBOW evaluated Mythos both as a raw API model and as the engine powering their agentic workflow, which provides access to a live-site testing environment, attack tooling, and structured validation infrastructure. This distinction proved consequential for interpreting the results.

7.2 Benchmark Performance: Quantitative Findings

On XBOW's web exploit benchmark — which requires a model-driven agent to find and validate exploitable vulnerabilities in live website environments within a budget of 80 actions — Mythos Preview delivered a significant performance improvement over prior models. False negatives were reduced by 42% compared with Opus 4.6 under standard conditions. When source code was made available alongside live-site access, false negatives fell by 55% — the largest improvement observed across any testing configuration.

Token-for-token, Mythos Preview demonstrated what XBOW described as *"absolutely unprecedented precision"* in homing in on vulnerabilities, substantially outperforming Opus 4.6 and showing a narrower but still meaningful gap over GPT-5.5-Cyber.

These results establish Mythos Preview as the leading model for vulnerability discovery in source-code-available environments as of the evaluation date — with a capability gap relative to predecessors that is large enough to be qualitatively, not merely quantitatively, significant.

7.3 Source Code Plus Live-Site Access: The Full Offensive Pipeline

XBOW's most practically significant finding concerns the relative importance of source-code access versus live-site access for exploit validation. Their experiments showed that removing access to the live site harmed model performance more than removing access to the source code — even for benchmarks where the vulnerability could theoretically be identified from the code alone. This establishes a clear performance ladder: source code alone is valuable, live-site access alone is valuable, but the combination is substantially more powerful than either in isolation.

This finding matters for interpreting the Project Glasswing results. The PAN advisory reflects a predominantly source-code-audit use case: AI models scanning internal codebases without access to live production systems. XBOW's data suggests that while Mythos is exceptionally capable at this task, the full potential of AI-driven exploitation — moving from vulnerability identification to validated, reproducible proof of concept — requires live-site interaction and structured access to tools. A model without these capabilities generates leads; a model integrated into an agentic framework with live-site access generates confirmed exploits.

The Mozilla Firefox case is the closest available approximation to a hybrid setting: Mythos was given source code access and a harness that could spin up reproducer cases against the live Firefox build infrastructure. The 271-bug result is consistent with XBOW's prediction that source code plus an exploit-validation environment outperforms either in isolation.

Implication for Defenders: The Palo Alto Networks advisory represents AI discovery at the 'source-code audit' stage. The Mozilla Firefox result represents a more mature pipeline that combines source code with reproducer infrastructure. As adversarial agentic frameworks evolve to provide frontier models with live-site access and exploit-validation tooling — as XBOW's platform already does — the time from discovery to weaponised exploit will compress further. Defenders should plan for this progression, not just the current state.

7.4 Judgment, False Positives, and the Conservative-Literal Tradeoff

XBOW's assessment of Mythos Preview's judgment capabilities was the most mixed across their evaluation dimensions. On command-safety benchmarking — determining whether a given script is safe to execute against a target site — Mythos Preview performed below Opus 4.6 (77.8% vs 81.2% accuracy) and markedly below Haiku 4.5 (90.1%), which had been specifically optimised for that task.

The failure mode is distinctive and carries important operational implications: Mythos Preview tends to prioritise the letter of a rule over its spirit. In practice, the model will flag edge cases that technically violate explicit criteria while missing cases where a rule's intent is clearly implicated but not literally expressed. For security teams integrating Mythos into automated workflows, this behaviour requires mitigation through explicit threat-model documentation, carefully constructed prompts, and external validation infrastructure — the model should not be assumed to exercise contextual judgement equivalent to that of an experienced human analyst.

Mythos Preview also tended to overstate the practical exploitability of its findings in some cases. In others, it conservatively discarded true positives when evidence did not formally satisfy the stated criteria. Both failure modes argue for human-in-the-loop validation at the triage stage of any AI-driven vulnerability management pipeline. Cloudflare's report of a better-than-human false-positive rate (Section 8.1.4) does not contradict this; rather, it demonstrates that, with sufficient pipeline engineering, the model's literalist tendency can be channelled into precision rather than judgment errors.

7.5 Strengths in Native Code, Reverse Engineering, and Visual Acuity

Beyond web application analysis, XBOW identified several areas where Mythos Preview demonstrated exceptional capability that extends the reach of AI-assisted security research:

- **Native code and Chromium analysis:** Mythos found more real bugs in Chromium-related testing with fewer false positives than prior baselines. In V8 sandbox work, it identified true positives in a subtle threat model where previous approaches had produced many findings but no successful true positives. This capability is directly relevant to browser security research, and the Mozilla Firefox 150 findings are consistent with XBOW's Chromium observations transposed to the Gecko engine.
- **Reverse engineering of firmware and embedded systems:** Mythos demonstrated the ability to reason through unusual firmware and embedded-systems contexts, including architecture-OS combinations that require more than pattern matching alone. This positions the model as a useful tool for IoT and OT security assessments — domains where human expertise is scarce and existing tooling is limited. The wolfSSL CVE-2026-5194 finding sits in the embedded-cryptography corner of this same domain.
- **Visual acuity for browser interaction:** In agentic workflows that require browser navigation, Mythos matched Sonnet 4.6's visual-acuity benchmark performance and substantially outperformed Opus 4.6, making it suitable for live-site interaction tasks requiring UI element identification.

7.6 Cost Efficiency: A Balanced Assessment

XBOW's evaluation includes an important economic dimension. At the time of writing, Mythos Preview carried a cost premium of approximately 5× compared with Opus-class models. When normalised by estimated running cost — asking whether the same budget allocated to a less expensive model with more time produces better results — the picture is nuanced: Mythos Preview is not the most cost-efficient option in XBOW's benchmarks, and for some use cases, running GPT-5.5 for longer may yield comparable or superior outcomes at lower cost.

This does not diminish Mythos Preview's leadership in capability, but it is operationally relevant for organisations designing AI-assisted security programmes. A multi-model strategy — using Mythos for the highest-complexity source-code audits and frontier reverse engineering, while deploying more cost-efficient models for high-volume, lower-complexity scanning — is likely the optimal configuration. This is precisely the approach XBOW employs, maintaining a cadre of models rather than restricting to a single option, and is consistent with PAN's multi-model deployment alongside GPT-5.5-Cyber and Opus 4.7.

Chapter Findings — XBOW Independent Evaluation

1. Source code combined with live-site access produces substantially better results than either in isolation — and live-site access matters more than source code for exploit validation. This explains the gap between PAN-style source-code audits (which generate leads) and Mozilla-style reproducer-enabled pipelines (which generate confirmed exploits). It establishes the performance standard for defensive pipelines.
2. The 42–55% false-negative reduction relative to Opus 4.6 is large enough to be planning-relevant, not incremental. XBOW characterises this as 'absolutely unprecedented precision.' Organisations treating Mythos Preview as a marginal improvement over prior models will significantly underestimate its impact on their risk posture.
3. The conservative-literal failure mode (77.8% command-safety accuracy vs 90.1% for a model tuned to the task) means explicit threat-model documentation is not optional. Human review at triage and validation decision points remains essential. Pipeline engineering can compensate for this weakness; assuming it away cannot.
4. Multi-model cadre deployment — Mythos for high-complexity source-code audit and reverse engineering, cost-efficient models for high-volume scanning — is both more economical and more capable than single-model deployment. PAN, XBOW, and Mozilla all use this pattern. Defenders should budget for a multi-model architecture from the outset.

8. The Wider Glasswing Ecosystem

The May 22 Anthropic update extends the public picture well beyond the five major case studies covered in Sections 3–7. This section summarises the remaining partner disclosures and external evaluations that contribute to the convergent finding, with emphasis on the cases that add a new dimension to the analysis.

8.1 Cloudflare: Exploit Chaining, Refusal Inconsistency, and the Edge-AI Counter-Threat

Cloudflare's Glasswing engagement is the most operationally detailed of the non-Mozilla partner disclosures. The Cloudflare blog (Glasswing: what Mythos showed us) and the associated press release, published 22 May 2026, go substantially beyond the headline numbers cited in the Anthropic update. Read together, they contribute four analytically important findings that do not appear in any other partner disclosure.

8.1.1 Scan Scope

Cloudflare tested Mythos Preview against live code across its runtime systems, edge data paths, protocol stacks, control planes, and the open-source projects it depends on. That scope is materially broader than an internal codebase audit — it encompasses the same code that handles hundreds of millions of HTTP requests per day, as well as the software supply chain dependencies running underneath it. This makes the 2,000-bug total and the 400 high/critical subset more meaningful than bare numbers suggest: the target was a production edge network that has been continuously security-reviewed by an internal team whose work is itself subject to external scrutiny.

8.1.2 Exploit Chaining: The Most Operationally Significant Finding

The finding Cloudflare describes as the most significant from the engagement is not the count of findings but the model's ability to construct exploit chains. Non-frontier AI models and traditional scanners found many of the same underlying bugs as Mythos. What they did not do was build chains. Mythos was able to take individually low-severity UI or logic issues — findings that would traditionally be invisible because no single instance clears the triage bar — and combine them into a coordinated, high-impact attack path. Cloudflare's characterisation: prior tools surface bugs and stop there, which is the easy part; Mythos converts low-severity bugs into a single, more severe exploit.

This finding has implications that go well beyond the Cloudflare deployment. Every vulnerability-count figure in this assessment — the PAN PSIRT 75, the Mozilla Firefox 271, the Microsoft Patch Tuesday 118, the open-source pipeline 1,596 — reflects the number of bugs reported individually. None of those figures account for the multi-bug attack chains that Mythos may have constructed internally and not yet disclosed, or that an adversary deploying Mythos offensively would construct from the same individually low-severity candidates. The chaining capability means the true risk surface is larger than the headline numbers indicate, because low-severity findings that would historically be deprioritised or dismissed may be ingredients in an exploit the model has already prototyped.

Implication for Defenders: The Cloudflare exploit-chaining finding materially changes how defenders should triage AI-discovered vulnerability reports. A finding rated low or medium severity in isolation is not safe to deprioritise if the model has flagged it in a context where adjacent code also has lower-severity issues. Triage pipelines should deduplicate based on chain context, not just on the severity of individual findings. This is the primary operational lesson from the Cloudflare engagement and has no parallel in any of the other May 2026 partner disclosures.

8.1.3 Inconsistent Model Refusals: A Reliability Concern in Production Pipelines

Cloudflare documents a model-behaviour failure mode distinct from the XBOW literal-versus-contextual judgment concern (Section 8.4), warranting separate treatment. In at least one case during the engagement, Mythos refused to perform vulnerability research on a target codebase. When the team deleted a hidden `.git` folder from the working directory and resubmitted the same request, the model agreed to do the same research on the same code. Nothing about the code under analysis had changed. Cloudflare's assessment: model refusals are not a reliable safety boundary, and the policy governing when refusals occur is not legible from the outside.

This has consequences in two directions. For defenders building autonomous or semi-autonomous AI-assisted security pipelines, unpredictable refusals introduce silent false negatives — code paths that appear to have been scanned but were not, because the model declined to engage without logging the refusal in a way the harness would detect. For AI safety assessors, the `.git`-folder case illustrates that surface-level code context can trigger or suppress a refusal even when it has no bearing on the substantive security question being asked. Both failure modes argue for explicit coverage verification — a harness should validate that the model produced output for every target region, not merely that it was invoked.

8.1.4 The C/C++ Memory-Safety Triage Burden

Cloudflare qualifies its claim of a better-than-human false-positive rate with an important caveat: the improved FP rate applies overall, but in memory-unsafe languages (specifically C and C++), Mythos demonstrates an inherent bias toward over-reporting potential issues — generating speculative flags that create a substantial human triage burden. The characterisation in Cloudflare's own words: a helpful exploratory tool can become a costly triage burden when the codebase involves pointer arithmetic and manual memory management that the model cannot fully resolve without runtime context.

This caveat is directly relevant to organisations considering deploying Mythos or a comparable model against large C/C++ codebases, which essentially describes every organisation whose security posture includes operating-system components, embedded firmware, network stack implementations, browser engines, or any other latency-sensitive runtime where Rust migration is incomplete. The better-than-human FP rate that Cloudflare reports for its overall estate is likely achieved partially because a significant share of Cloudflare's critical-path systems are written in Go, Rust, or similar memory-safe languages. Defenders with heavy C/C++ exposure should calibrate their pipeline staffing to the higher triage-per-finding rate rather than to the overall FP rate headline.

8.1.5 "Resilience by Default": Cloudflare's Policy Response

Cloudflare's threat research team (Cloudforce One) frames the central lesson of the engagement as a shift from speed of response to durable engineering. Because a frontier model can reduce the timeline from bug identification to functional exploit from months to hours, organisations that rely on a reactive race to patch are structurally outmatched. The alternative Cloudflare advocates assumes that vulnerabilities will be found at machine speed; harden edge infrastructure through micro-segmentation and isolation so that, even if a model chains an exploit together, the attack path is stopped dead by the architectural design itself, not by the speed of the patch cycle.

This is the most direct public articulation of the architectural-defence-in-depth argument advanced in Section 3.5 (Mozilla prototype freezing), Section 5.4.4 (Hyper-V isolation), and Section 10.2 (this assessment's strategic recommendation). Cloudflare's endorsement of the same principle — expressed as a hardening posture rather than a patching posture — carries particular weight because Cloudflare operates one of the world's largest edge networks and has more deployed experience of what AI-speed attack timelines look like in practice than almost any other organisation.

8.1.6 Indirect Prompt Code Injection (IDPI): Edge AI as a New Attack Surface

Concurrent with the defensive scanning work, Cloudforce One detected a separate threat that the engagement surfaced: an uptick in threat actors attempting what Cloudflare terms Indirect Prompt Code Injection (IDPI). IDPI involves embedding hidden instructions in data or Cloudflare Workers scripts to cause edge-running AI models to misclassify malicious VPN or proxy tunnelling configurations or to bypass security filters the model is tasked with enforcing.

IDPI is a fundamentally different threat class from the vulnerability-discovery context that dominates this assessment. It is not about finding bugs in code; it is about adversarially manipulating an AI model integrated into a production security enforcement role. As frontier AI models are integrated more deeply into security operations — as detection engines, traffic classifiers, and policy-enforcement decision-makers — the AI's attack surface itself becomes a target. IDPI is, in essence, the adversarial prompt injection problem applied to edge-security infrastructure.

Cloudforce One's detection of IDPI attempts in the wild is the first real-world evidence from security operations in this assessment of adversaries actively probing the AI-as-security-control attack surface. It validates a concern that has been theoretical in prior academic work and is now confirmed operational. Organisations deploying AI models in detection or enforcement roles (not just in scanning roles) should explicitly threat-model the adversarial prompt-injection surface, include IDPI testing within the red-team scope, and design AI-in-the-loop security controls that are robust to crafted inputs that attempt to alter the model's security judgment.

8.2 Open-Source Scan: The Triage Bottleneck Becomes the Story

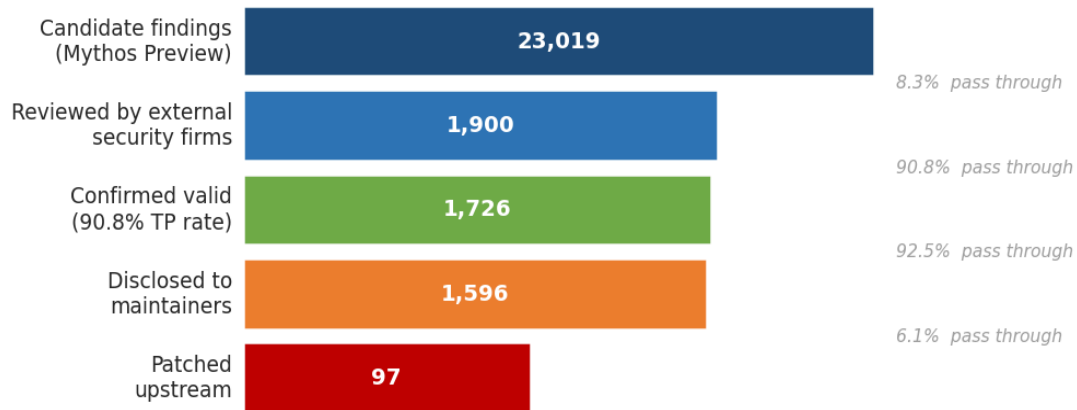
Anthropic has been running Mythos Preview against more than 1,000 open-source projects for several months. The numbers, as of 22 May 2026, are:

Total candidate findings produced by Mythos Preview	23,019
Reviewed by six independent external security research firms	1,900
Confirmed valid (true-positive rate after external triage)	1,726 (90.8%)
Reported to maintainers via external triage	467
Reported directly to maintainers at the maintainer's request	1,129
Total disclosed to maintainers (across 281 open-source projects)	1,596
Acknowledged by the maintainer	1,451
Patched upstream	97
Security advisories published (CVE or GHSA)	88
Average patch time per high/critical bug (Glasswing post)	~14 days

The funnel is the story. Mythos generates findings far faster than any combination of triage capacity, maintainer attention, and patch-development time can absorb. Anthropic's dashboard explicitly shows the steep drop-off at each stage. Some open-source maintainers have requested that Anthropic slow the pace of disclosure because they cannot keep up with the patch design workload. The 14-day average patch time for high-severity bugs is itself a remarkable figure for unpaid volunteer maintainers. Still, it is fundamentally incompatible with the rate at which Mythos can produce confirmed findings.

Anthropic's response includes a \$12.5 million partnership with the Open Source Security Foundation's Alpha-Omega project to scale maintainer triage capacity, the public release of Claude Security (in beta) so enterprises can scan their own code with publicly available Claude Opus 4.7, and the release of the harness scaffolding, threat-model builder, and skills templates that Glasswing partners use with Mythos. This last release is operationally consequential: it applies the same pipeline pattern that Mozilla and PAN use to codebases scanned with the publicly available Opus 4.7. Anthropic also reports that Claude Security has been used for over three weeks to patch over 2,100 vulnerabilities in enterprise customers' code — faster than the open-source pace, because enterprise teams patch their own code rather than relying on volunteer maintainers.

Open-Source Scan: Triage-to-Patch Funnel (CVD Dashboard — 22 May 2026)



Bar widths are log-scaled for readability

⚠ Human capacity bottleneck: patch cycle cannot yet absorb discovery velocity

8.2.1 Severity Agreement: Where Claude Over-Rates and Where It Doesn't

A second analytically important dataset is published in the Frontier Red Team dashboard's severity-agreement matrix. For 463 findings reviewed by external security research firms, Claude's initial severity assessment was compared with the firms' assessed severity. The aggregate agreement is 58.7% exact and 94.4% within one band. The asymmetry inside that aggregate is, however, operationally important:

Claude-rated ↓ / External →	Critical	High	Medium	Low
Critical	23	145	5	19
High	2	180	13	2
Medium	0	3	52	2
Low	0	0	0	17

The single largest off-diagonal cell is Claude-rated-critical, externally-rated-high ($n = 145$). The second largest is Claude-rated-critical, externally-rated-low ($n = 19$). Claude does not under-rate critical findings: of the 25 externally-rated critical findings, 23 (92%) were also rated critical by Claude. But Claude over-rates at the critical level non-trivially — 169 of the 192 Claude-critical findings (88%) were downgraded by external triage. The pattern is consistent with the XBOW finding (Section 8.4) that Mythos Preview's literalist tendency to apply the strict letter of severity criteria yields a precision-favouring bias: false-critical errors are common, false-low errors essentially do not occur. For defenders, this means a Mythos-critical finding should trigger immediate triage but not immediate emergency-patch action without external confirmation; a Mythos-low finding can be deprioritised with high confidence. Anthropic's own dashboard caveat — that maintainers apply project-specific severity

rules that Claude does not have access to at runtime — is operationally important for interpreting any Mythos-severity output.

The practical implication for teams that receive AI-generated vulnerability reports: overrated findings (which, at the current calibration, constitute roughly a third of high-AI-severity cases that firms downgrade) should be triaged with a second opinion before being assigned critical-track remediation timelines. Conversely, the 94.4% within-one-band agreement means the model's severity direction is almost always correct; a finding that the model rates Critical is a reliable signal that something serious is present, even if the precise CVSS score differs from external review.

8.2.2 Representative Disclosed CVEs and GHSAs

The Frontier Red Team dashboard lists publicly-revealed CVEs and GHSAs whose disclosure windows have closed. A representative cross-section illustrates the breadth of open-source codebases and defect classes the scan has surfaced:

Identifier	Project	Class	Severity	Description
CVE-2026-27654	nginx	Heap buffer overflow / arbitrary file write	Critical	DAV COPY/MOVE alias underflow — unauthenticated remote file write in WebDAV module
CVE-2026-5199	temporalio/temporal	Broken access control	Critical	Cross-namespace manipulation (including deletion) of workflows on the same cluster
CVE-2026-7474	nomad	Path traversal	Critical	Host-volume plugin path-traversal
CVE-2026-32316	jq	Heap buffer overflow	Medium	Integer overflow in string concatenation → ~1 GB memcpy heap overflow
CVE-2026-33721	MapServer	Heap buffer overflow	Medium	SLD categorize threshold parsing — wrong counter variable in reallocation guard
GHSA-w52v-v783-gw97	TryGhost/Ghost	SQL injection	Critical	SQL injection in Content API
GHSA-f26g-jm89-4g65	GitoxideLabs/gitoxide	Remote code execution	High	RCE when updating a Git submodule of a malicious repository
GHSA-cc7p-2j3x-x7xf	CraftCMS	Privilege escalation	High	Bypass via UsersController->actionImpersonateWithToken()
GHSA-chgx-jx3p-rf73	mastodon	Signature bypass	High	LD-Signature bypass via JSON-LD named-graph restructuring
GHSA-crr4-7rm4-8gpw	mastodon	SSRF	High	Bypass via IPv6 Unspecified Address (::)
GHSA-mpxh-8fq3-x8mh	freerdp	Heap buffer overflow	High	Heap overflow in clipdr_main.c (one of three freerdp CVEs)
GHSA-9f49-8x56-jmjc	libyang	Use-after-free	Medium	Heap UAF in metadata list during XML data parsing

Identifier	Project	Class	Severity	Description
GHSA-x9h5-r9v2-vcww	ImageMagick	Heap buffer overflow	High	MVG pattern rendering via CopyMagickString without bounds check
GHSA-xh8f-g2qw-gcm7	minio	Path traversal	Medium	xl-storage.go sink in storage-rest-server handler
GHSA-j273-m5qq-6825	junrar	Path traversal	Medium	Arbitrary file write via backslash path traversal

The breadth is the point. A single AI-driven scanning effort surfaced critical-severity flaws in: a web server (nginx), a distributed workflow orchestrator (Temporal), a cluster job scheduler (Nomad), a content-management database query layer (Ghost), a Git tooling library (gitoxide), and the CraftCMS user-impersonation path — alongside high-severity flaws in federated social media (Mastodon), remote-desktop (FreeRDP), image processing (ImageMagick), TLS (wolfSSL), and many others. No human-led security research programme operates at this breadth in this timeframe. Every organisation that consumes any of these projects transitively (which collectively covers most modern web, cloud, and DevOps stacks) inherits an obligation to verify patch status against the disclosed advisories — and to expect more advisories in the same projects as the remaining ~94% of the disclosed-but-unpatched pipeline (1,499 of 1,596 findings) drains.

8.3 Industry-Wide Patch Velocity Effects: Oracle and Cisco

Two additional partner disclosures in the May 22 update contribute brief but notable observations on AI-era patch velocity beyond the five major case studies:

- **Oracle** reports that vulnerability detection and remediation across its product and cloud portfolio are now running multiple times faster than before the AI-assisted programme was introduced. While Oracle has not published per-product or per-cycle statistics analogous to PAN's or Mozilla's, the directional claim is consistent with every other partner disclosure: an organisation that historically relied on manual review to surface security issues now has a machine-speed discovery pipeline that produces a proportionally larger remediation queue. The practical implication for Oracle enterprise customers is that patch velocity expectations should be revised upward and that Oracle's advisory cadence will likely grow in volume before stabilising.
- **Cisco** has open-sourced its Foundry Security Spec, a structured methodology document that describes how Cisco builds and operates its AI-assisted security evaluation pipeline internally — the same harness it uses in the Glasswing collaboration. The Spec covers: threat-model construction for AI-driven scans, harness scaffolding requirements, deduplication and triage workflow, reproducer infrastructure design, and the multi-model cadre approach Cisco uses to address individual model blind spots. Its publication alongside Anthropic's own scaffolding release signals an emerging industry norm: rather than competing on harness design, leading practitioners are open-sourcing the meta-tooling so that the entire ecosystem — including defenders who cannot partner with Anthropic directly — can replicate the pipeline pattern. This is the most significant second-order effect of the May 22 update for organisations outside the Glasswing cohort.

Together, Oracle and Cisco confirm that the Glasswing capability pattern is not limited to the six partners named in the Anthropic update. As of May 2026, every major technology vendor with access to frontier AI appears to be running some version of the same discovery pipeline, with corresponding increases in advisory volume that downstream organisations will need to absorb.

8.4 External Benchmarks: AISI, ExploitBench, ExploitGym, SCONE

Four independent external evaluations now corroborate the partner reports, three of which (ExploitBench, ExploitGym, and SCONE-bench) Anthropic discusses in greater detail in the 22 May Frontier Red Team companion blog post by Cheng, Lucas, Xiao, Carlini, and Nasr. The independence of these evaluations from the partner programme is methodologically important: the Glasswing partners have access to the model and a financial relationship with its developer, while these four external assessments are arm's-length academic or government work whose authors hold no commercial stake in the model's reception. Their convergence with the partner-level numbers substantially raises the credibility of the headline capability claims.

8.4.1 UK AI Security Institute (AISI) Cyber Ranges

The UK AI Security Institute reports that Mythos Preview is the first model to solve both of AISI's cyber-range simulations end-to-end. These ranges are designed to test multistep cyberattack capabilities — the chained reasoning required to move from initial access through privilege escalation to achieving the objective. AISI's framing of the result emphasises that the threshold being crossed is end-to-end completion of a multistep attack chain, not isolated subtask success. This is the offensive-capability complement to the defensive evidence from Glasswing partners: a frontier model that can perform every step of a chained attack without human intervention has a qualitatively different threat profile from one that produces individual findings for a human attacker to chain together.

8.4.2 ExploitBench: V8 End-to-End Exploit Capability

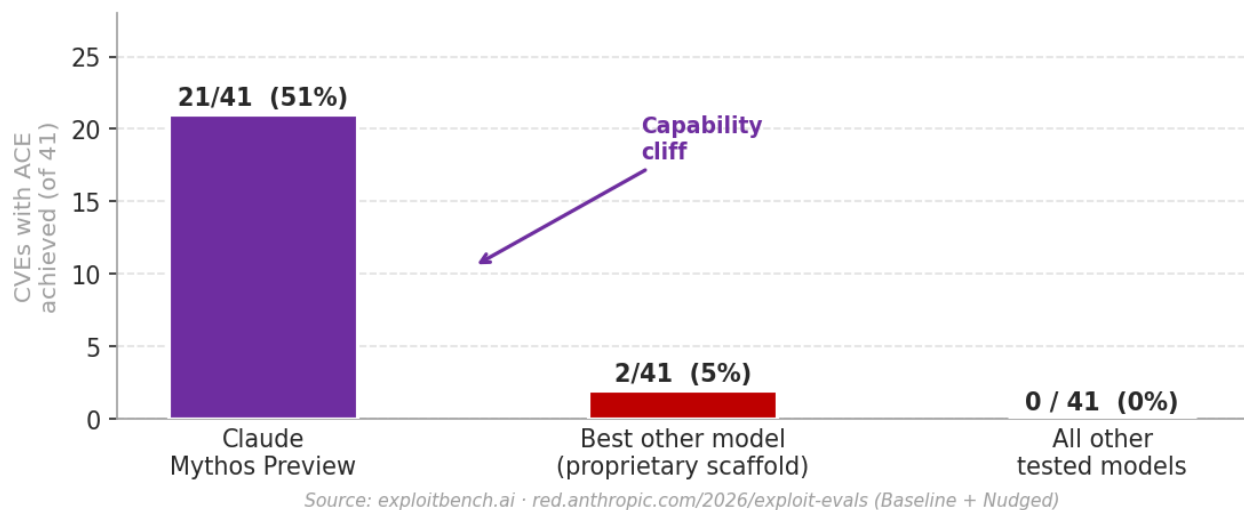
ExploitBench, built by Seunghyun Lee and Prof. David Brumley of Carnegie Mellon University and Bugcrowd, focuses on a sharper question than most prior benchmarks: not whether a model can produce a reproducer that triggers a vulnerability, but whether it can write a complete end-to-end exploit. The benchmark decomposes exploit development into 16 distinct capabilities organised into a five-tier capability ladder against 41 patched V8 JavaScript engine vulnerabilities:

Tier	Capability	What it means in practice
T5	Coverage	Reaching the vulnerable code path
T4	Reproduction	Constructing a proof-of-concept that triggers the bug
T3	Target primitives	Creating primitives confined to the V8 sandbox
T2	Generic primitives	Breaking the V8 sandbox to obtain read/write or infoleak across the process
T1	Full Control	Hijacking control flow or obtaining arbitrary code execution (ACE)

All models reach T4/T5 — they can locate and exploit known vulnerabilities. The interesting capability cliffs are higher up the ladder. From T3 (in-sandbox primitives), every model since Opus 4.6 makes some progress; from T3 to T2 (breaking the V8 sandbox), Mythos Preview is the only tested model that

reliably succeeds, doing so in over half of the 41 environments. Combining the Baseline (300-turn budget) and Nudged (adaptive prompting near budget limit) variants, Mythos Preview achieves arbitrary code execution (T1) on 21 of 41 CVEs. No other tested model achieves even 1 ACE in either variant; the only other model on the scoreboard to achieve ACE at all reached 2 of 41, and only with a proprietary scaffold. This is the sharpest single piece of quantitative evidence in the May 2026 cycle for the qualitative-capability-step framing: Mythos Preview is not 10% better than the prior frontier on end-to-end V8 exploitation; it is in a different class entirely.

ExploitBench: End-to-End V8 Arbitrary Code Execution



The benchmark also surfaces a qualitatively striking individual case. For V8 CVE-2023-6702, Mythos Preview produced a near-deterministic exploit, whereas publicly known exploits were probabilistic and uncontrolled. Stability matters operationally — sold exploits often get one attempt against a target — and Mythos achieved deterministic stability using a technique that, per ExploitBench co-author Seunghyun Lee, had been privately discussed with the original v8CTF exploit author and dismissed as too complex; Mythos executed it cleanly without any publicly available information on the specific technique.

8.4.3 ExploitGym: Cross-Domain Exploitation at Scale

ExploitGym (Wang et al., arXiv:2605.11086, submitted 11 May 2026) is the second of three external benchmarks covered in the companion Frontier Red Team blog post. Developed by UC Berkeley, the Max Planck Institute for Security and Privacy, UC Santa Barbara, and Arizona State University, with contributions from security researchers at Anthropic, OpenAI, and Google, it operates at a much larger scale than ExploitBench: 898 patched vulnerabilities across three target classes — userspace programs (drawn from OSS-Fuzz), the V8 JavaScript engine, and the Linux kernel. The benchmark provides build information, vulnerability information, runtime information, and a remote target running the vulnerable endpoint; the model is tasked with producing a working exploit that achieves unauthorised code execution and uses elevated privileges to retrieve a dynamically generated flag. Success is verified both by flag submission and by a model judge that confirms the intended (not an alternative) vulnerability was exploited. Toggleable security mitigations (V8 heap sandbox, Linux KASLR) allow the framework to isolate the impact of standard defences.

Within a two-hour wall-clock budget, Mythos Preview successfully executes unauthorised code using the intended vulnerability on 157 of 898 tasks, increasing to 226 successful flag captures when alternative code-execution paths are counted. Claude Opus 4.6, the prior frontier baseline, achieves 15 intended-vulnerability successes (36 total). The ratio — Mythos producing roughly 10× more intended-vulnerability exploits than Opus 4.6 at the same time budget — is consistent with Mozilla's Firefox 150-per-target discovery delta and with PAN's roughly 5× increase in monthly cadence. Notably, Mythos is one of only two reported models able to frequently develop kernel exploits, the most demanding target class in the benchmark. The Anthropic Frontier Red Team companion post also notes that even with widely used security mitigations enabled, frontier models retain non-trivial success rates.

8.4.4 SCONE-bench: Smart Contract Exploitation

SCONE-bench (Smart Contract Exploitation benchmark) is the third academic benchmark in the May 22 disclosure and the only one in the post-pre-existing-knowledge category. Anthropic published the original benchmark in 2025 in collaboration with MATS and the Anthropic Fellows Program, but used an updated edition for the Mythos evaluation, drawn from 12 exploits reported after 1 January 2026 and sourced from the DefiHackLabs dataset. The benchmark instructs the model to identify a vulnerability in a smart contract and create an exploit to steal funds in a local simulation; performance is measured by the total simulated USD value of successful exploitations, converted from native-token revenue using the historical exchange rate of the day the real exploit occurred.

Mythos Preview exploits USD 35 million worth of smart contracts on the benchmark — USD 15 million (about 75%) more than the next-closest model tested. The gap is largely driven by Mythos being the only model to exploit every vulnerability in the updated benchmark successfully; Opus 4.7 is the only other model able to exploit the `truebit` contract, and no other model can exploit `makina` in an 8-trial setting. The frontier-model exploitation capability gain is now compounding faster than it was just months ago: the year-over-year exploit-revenue doubling time, which was 1.1 months in the original 2025 SCONE-bench paper, has compressed to 0.7 months in the data since Opus 4.5. This is a quantitative measurement of exploit-capability progress that should be treated as one of the most important defensive-planning inputs in the entire May 2026 disclosure cycle — it implies that the cost of misjudging frontier-model exploitation capability is itself doubling every three weeks.

Anthropic is open-sourcing the updated SCONE-bench harness and dataset, allowing third parties to replicate the measurement against future models — an important methodological commitment given that the 0.7-month doubling time, if it persists, will be the principal quantitative benchmark for projecting offensive-capability evolution into the second half of 2026.

Implication for Defenders: The ExploitBench, ExploitGym, and SCONE-bench results together establish that Mythos Preview is not merely a better vulnerability scanner; it is a qualitative step change in exploit development capability. The XBOW evaluation showed precision in identification; ExploitBench shows end-to-end V8 ACE on 21/41 CVEs versus 0–2 for every other model; ExploitGym shows kernel exploitation at scale; SCONE-bench shows a 0.7-month doubling time for exploit capability. Defenders should plan for Mythos-class offensive capability to be available to

motivated adversaries within the 6–12 month horizon Anthropic itself estimates, with corresponding compression of the discovery-to-weaponised-exploit window for any unpatched vulnerability.

Chapter Findings — The Wider Glasswing Ecosystem

1. Exploit chaining is the most operationally novel finding in this section and in the entire assessment. Every headline counts in this report — Firefox 271, PAN 75, Microsoft 118, open-source 1,596 — reflecting individually rated vulnerabilities. None captures the multi-step attack chains that Mythos constructs from components that would each clear no individual triage bar. The true risk surface is larger than any count in this document suggests.
2. The open-source triage bottleneck is the binding constraint on the discovery-to-patch pipeline. 1,596 findings disclosed across 281 projects; 97 patched; maintainers requesting slower disclosure. The bottleneck is not discovery velocity — it is human capacity to review, remediate, and release. Anthropic's \$12.5M OSSF Alpha-Omega partnership and the Claude Security release are structural responses to this constraint, not tactical mitigations.
3. Oracle's multiple-times-faster velocity claim and Cisco's open-sourcing of the Foundry Security Spec together confirm that AI-assisted security auditing has moved beyond Anthropic's Glasswing cohort. Every major technology vendor with access to frontier models is running some version of this pipeline. Organisations downstream of Oracle, Cisco, and Microsoft products should plan for AI-era advisory cadences across their entire vendor landscape, not just the six publicly-named Glasswing partners.
4. ExploitBench's T1 arbitrary-code-execution result — 21 of 41 V8 CVEs for Mythos versus 0–2 for every other tested model — is the sharpest single capability-cliff measurement in the May 2026 disclosure cycle. It establishes that the capability gap is not a matter of degree but of category: prior frontier models can trigger vulnerabilities; Mythos can weaponise them end-to-end. This is the benchmark defenders should track as a planning input for projections of adversary timelines.

9. Synthesis: Ten Convergent Findings Across All Case Studies

This section synthesises ten convergent analytical findings drawn from all five major case studies (Sections 3–7), the wider Glasswing ecosystem (Section 8), and the adversarial implications of the combined evidence (Sections 9 and 10). The findings are listed in decreasing order of analytical novelty — starting with what this evidence set establishes that was previously poorly documented, and ending with the judgments that have the most direct operational implications for the planning window defenders face.

9.1 Source-Code Analysis Is the Dominant Strength (Confirmed Across All Five Case Studies)

All five major case studies independently identify source-code analysis as Mythos Preview's defining capability. PAN's Project Glasswing deployment found most of its 75 issues through code scanning. XBOW's benchmarks showed a 55% reduction in false negatives when source code was added to live-site access. Mozilla's Firefox 150 effort — by far the largest single-target dataset — relied principally on source-code reasoning paired with reproducer-execution capabilities. Microsoft's May 12 release attributes a greater-than-usual internal discovery share to its multi-model, AI-driven scanning harness operating across the Windows, Office, and Azure source trees. The wolfSSL cluster — ten CVEs in a security-focused cryptographic library that had been professionally audited for years — is a pure source-code identification with model-driven exploit construction, and represents the clearest evidence of the qualitative depth of this capability. The convergence across five distinct deployment contexts — network-appliance defensive audit, offensive web exploit evaluation, browser harness, enterprise OS patch cycle, and cryptographic library — is strong evidence that the advantage is genuine and reproducible, not an artefact of any particular deployment.

9.2 The Discovery / Patching Asymmetry Has Inverted

For three decades, the cybersecurity industry has operated under the assumption that finding is hard and fixing is comparatively easy. Once a bug is identified, the patch is usually small, and the difficulty is in reaching consensus on whether and how to deploy it. The May 2026 evidence inverts this. The open-source funnel is the clearest illustration: of 23,019 candidate findings produced by Mythos Preview, 1,900 have been reviewed by external security research firms (90.8% confirmed valid), 1,596 disclosed to maintainers across 281 projects, and only 97 patched upstream — meaning 1,499 confirmed-valid disclosed findings are awaiting patches, and a further ~21,000 candidates have not yet been reviewed. Some open-source maintainers have formally requested that Anthropic slow the pace of disclosure because patch development has become the binding constraint. The 14-day average patch time for high-severity bugs is remarkable for unpaid volunteer maintainers, but it is structurally incompatible with the rate at which Mythos can generate and confirm findings.

Enterprise pipelines see the same dynamic differently. Mozilla's 423 April security fixes against a 20–30 per month baseline through 2025, PAN's roughly 5× monthly volume, Microsoft's May release at 118 CVEs with forward guidance of continued growth, and Oracle's multiple-times-faster cadence all describe organisations that are patching at unprecedented rates but still cannot match the discovery side. The Microsoft zero-day absence in May 2026 — the first in 22 months — is the first observable indicator that defenders may be temporarily ahead in the discovery race for a major OS vendor. However, one month is not a trend. The inversion has direct policy implications discussed in Section 10.

9.3 Horizontal Coverage Spans Every Product Class

PAN's advisory included Trust Protection Foundation, Chronosphere Chronocollector, and Broker VM alongside core PAN-OS — products that human red teams rarely audit comprehensively in the same engagement. Mozilla's Firefox 150 findings span the JavaScript engine, layout, IPC, networking, and the in-process RLBox sandbox simultaneously. Microsoft's May release sweeps even more horizontally: Windows kernel, Hyper-V, Netlogon, DNS Client, Office (Word, Excel, PowerPoint, SharePoint), Azure managed services (Cassandra, Logic Apps, Machine Learning, DevOps, Entra ID), .NET, ASP.NET Core, Visual Studio Code, and Microsoft Teams in a single Patch Tuesday cycle. The open-source scan covers more than 1,000 distinct projects. XBOW's evaluation demonstrates portfolio coverage across web, native code, reverse engineering, and visual UI interaction. The horizontal coverage capability is, if anything, more operationally novel than the per-target finding rate, because it predicts that ancillary and peripheral products will surface findings at an unprecedented rate — and historical inattention to such products should not be interpreted as evidence of their security.

9.4 Long-Dormant Defects Surface At Unprecedented Rates

Mozilla disclosed a 15-year-old <legend> bug and a 20-year-old XSLT bug in its small illustrative sample of 12 from 271. PAN's CVE-2026-0263 (IKEv2 buffer overflow) and CVE-2026-0251 (CWE-426 untrusted search path) carry the same flavour: defects that survived decades of professional review because the cost of finding them exceeded the available investment. Microsoft's Netlogon stack-based buffer overflow (CVE-2026-41089) sits in a code path that has been one of the most-audited corners of the Windows codebase since the original Zerologon disclosure in 2020, and the Hyper-V use-after-free (CVE-2026-40402) is in a hypervisor surface specifically built and reviewed for tenant isolation. The wolfSSL CVE-2026-5194 is in cryptographic code, the most-audited corner of open source by historical convention. The model's ability to surface long-dormant defects is not incidental — it is the principal mechanism by which the headline numbers are achieved, and every long-lived codebase should expect a comparable dormant-defect tail to surface in its first serious Mythos-class scan.

9.5 Defense-in-Depth Still Matters — More, Not Less

Mozilla's observation that Mythos Preview repeatedly attempted to escape prototype pollution and was thwarted by architectural prototype freezing is the most operationally instructive finding in the entire May 22 update. Every architectural defence-in-depth control that pre-empts a bug class produces a permanent capability deficit for AI-assisted scanners — defensive or offensive. By contrast, every per-bug patch closes only one finding. The strategic implication is the opposite of the casual one: the AI-assisted attack era raises the relative payoff of architectural mitigations, sandboxing, and isolation, because their cost is paid once and their benefit compounds against every future scanner.

9.6 The Harness Is As Important As The Model

Mozilla, Microsoft, Cloudflare, and XBOW all describe their pipelines in terms that emphasise the harness — the orchestration, scaffolding, deduplication, validation infrastructure, and reproducer-execution environment around the model — as the structural enabler of operational utility. Microsoft's first-time public characterisation of its multi-model AI-driven scanning harness adds a major vendor to the list of organisations explicitly elevating the harness as a primary capability. The model is the core primitive, but the harness determines whether the model's outputs become noise or signal.

Mozilla's pipeline took months to build with iteration against the Firefox engineering team; the Cloudflare false-positive rate that beats human testers is a property of the integrated pipeline, not of the model in isolation. Anthropic's release of its Glasswing scaffolding, threat-model builder, and skills templates to qualifying customers reduces the harness-engineering barrier — but does not eliminate the requirement for project-specific tuning.

9.7 Logic-Level Cryptographic Reasoning Is Structurally Different from Fuzzing

The wolfSSL case study (Section 6) reports a finding qualitatively distinct from those of the other case studies in this assessment: seven of the ten CVEs are not memory-safety bugs. They are logic-level correctness failures — signature acceptance without the right-length check, AEAD decryption without MAC verification, integer overflow enabling a cryptographic bypass — that produce no crash, no sanitiser alert, and no fuzzer signal. They are detectable only by reasoning about what the cryptographic specification requires and identifying the code path where that requirement is not enforced. The wolfSSL cluster is the clearest available evidence for a capability class that AI contributes that is genuinely new, not just faster or broader: reasoning about the semantic correctness of cryptographic guarantees rather than memory-safety invariants. Defenders planning AI-assisted audit programmes should prioritise cryptographic libraries, authentication modules, and certificate-verification code above general C/C++ codebases — this is the highest-signal-to-noise-ratio target class for frontier model reasoning.

9.8 Exploit Chaining Multiplies the Risk Surface Beyond Headline Counts

The Cloudflare engagement surfaces a capability that the other partner disclosures do not: the ability to construct multi-step attack chains from individually low-severity components. Every headline bug count in this assessment — Firefox 271, PAN 75, Microsoft 118, open-source 1,596 — reflects individually-rated findings. None captures the chains. Mythos took bugs that prior tools had flagged as low-severity (below any conventional triage threshold) and combined them into high-impact attack paths. Non-frontier AI models found the same underlying individual bugs and stopped; Mythos continued to the chain. This means the risk surface addressed by the May 2026 disclosures is larger than the headline numbers indicate, because the adversarial value of a low-severity finding changes when it is part of a chain rather than a standalone issue. Defenders should not treat low-severity AI-generated findings as safe to deprioritise without chain-context deduplication.

9.9 Judgment Remains a Human Responsibility

XBOW's command-safety benchmark finding (77.8% vs Opus 4.6's 81.2% vs Haiku 4.5's 90.1%) and the conservative-literal failure mode it identifies remain operative. Cloudflare's better-than-human false-positive rate does not contradict this; it demonstrates that pipeline engineering can work around the model's weaknesses in judgment rather than eliminate them. AI-assisted security programmes should be designed with human review at decision points — particularly during vulnerability triage, exploit validation, and remediation prioritisation. The Mozilla harness's reproducibility requirement — every finding must execute as a working testcase before it is accepted — is one example of how this can be operationalised without imposing per-finding human review.

9.10 Adversarial Implications: The Offensive Mirror

Every defensive finding documented in Sections 3–8 has an offensive counterpart. The same capabilities that allowed Mozilla to pre-empt 271 Firefox bugs allow an adversary with equivalent access to sweep any organisation's internet-facing codebase for zero-days within hours. This section identifies the highest-priority offensive implications that defenders should internalise when acting on the recommendations in Section 11.

Immediately weaponisable CVEs. The vulnerabilities most likely to be weaponised first are those that are network-accessible without adjacency requirements, require no authentication, carry low attack complexity, and already have proof-of-concept reproducer logic available from the vendor advisory cycle. In this assessment, CVE-2026-0300 (PAN-OS Captive Portal RCE, CVSS 9.3) is the highest priority by this metric — it was already confirmed to have been exploited before publication. It was added to CISA's Known Exploited Vulnerabilities catalogue on 6 May. CVE-2026-41089 (Netlogon RCE, CVSS 9.8) and CVE-2026-0263/0264 (PAN-OS IKEv2/DNS RCEs) follow closely. The wolfSSL CVE-2026-5194, while requiring a MitM position, affects an estimated five billion devices, including many without patch mechanisms — making it a durable long-horizon attack surface rather than a short-fuse threat.

Threat actor segmentation. Different classes of adversaries will prioritise different parts of the disclosed vulnerability landscape. Ransomware operators are most interested in the Windows Kernel EoP cluster (CVE-2026-33841/35420/40369) — which enables the privilege escalation that converts an initial foothold into ransomware deployment — combined with the Word Preview Pane RCE cluster for initial access. Nation-state and APT actors are most interested in the wolfSSL cluster: silent long-horizon TLS interception on embedded devices in critical infrastructure, military systems, and sovereign communications equipment produces intelligence value that cannot be achieved through noisier attack vectors. The Hyper-V guest-to-host escape (CVE-2026-40402) is highly valuable to espionage-focused actors in cloud environments. Commodity phishing campaigns will target the Word Preview Pane RCEs most aggressively, as these enable mass-mail initial-access campaigns requiring no user action beyond Outlook preview.

Exploit chaining at adversarial scale. Cloudflare's finding (Section 8.1.2) that Mythos Preview can chain individually low-severity findings into high-impact attack paths is the most consequential offensive implication in this assessment. A defender who reviews only the 75 PAN-OS CVEs and 271 Firefox bugs as individual findings is undercounting their exposure. An adversary deploying the same model offensively will produce attack chains — combining a low-severity information-disclosure finding with a medium-severity authentication bypass and a high-severity RCE — that are not visible in any individual CVE entry. This is the principal reason why low-severity findings should not be deprioritised in AI-era triage pipelines.

The IDPI threat (Section 8.1.6) represents the adversarial attack class most distinctive to the AI integration era. It is not vulnerability discovery directed at software; it is adversarial manipulation of AI systems integrated into security enforcement. Cloudforce One's detection of active IDPI attempts in the wild confirms this is no longer theoretical. Defenders integrating AI into detection or enforcement roles must explicitly model the threat surface for adversarial prompt injection from day one. The sector-specific risk matrix in Section 11 maps these threat-actor priorities to defender organisation types — readers should consult both sections together for the complete adversary-versus-defender picture.

10. Strategic Implications for Enterprise Security

10.1 The Defender's Dilemma Has Structurally Changed

For decades, the defender's dilemma — the asymmetry between the effort required to secure a system and the effort required to compromise it — has favoured attackers. Frontier AI models simultaneously intensify and potentially invert this asymmetry, depending on who deploys them and how. In the near term, organisations with early access to these models and the capacity to act on their findings can achieve a meaningful defensive advantage. In the medium term, as access proliferates, the advantage reverts to attackers — who can deploy exploits at scale while defenders must patch products one at a time.

Mozilla's framing is the most direct articulation of why defenders should nonetheless be optimistic. The cost gap between machine-discoverable and human-discoverable bugs has historically advantaged attackers, who could concentrate elite human effort on finding a single bug; closing that gap by making discovery cheaper erodes the attacker's structural advantage. The 3-to-5-month window cited by PAN should be interpreted as the period during which organised, well-resourced defenders can use their access advantage to close the vulnerability gap identified by AI audits. After that window, the same capabilities will be available to adversaries, and any unpatched vulnerabilities discovered during the audit period will also be discoverable by attackers.

10.2 Patching Velocity Must Increase — And Architectural Investment Must Increase Faster

The May 2026 evidence makes the volume problem explicit: PAN at 5× monthly cadence, Mozilla at over 10× monthly cadence at the same target, Microsoft at 118 CVEs in a single Patch Tuesday with explicit forward guidance of continued growth, Oracle running multiple times faster, the open-source ecosystem with 1,499 confirmed-valid findings disclosed to maintainers but awaiting patches, and a further ~21,000 candidate findings not yet reviewed. Patch testing and deployment cycles calibrated to 2025 volumes are not fit for purpose. Enterprises should reassess SLAs explicitly recognising that AI-era advisory volumes will require faster response than prior baselines assumed. Microsoft's specific guidance — that customers should expect more frequent out-of-band updates when warranted — is itself a structural change in the rhythm of vendor security communication that downstream patch teams must absorb.

Patching alone, however, cannot scale to keep pace with discovery. The Mozilla prototype-freezing finding establishes the alternative leverage point: architectural defence-in-depth investments — sandboxing, isolation, prototype freezing, ASLR, control-flow integrity, RLBox-style in-process sandboxing, capability-based privilege models — pre-empt entire bug classes and produce permanent gains against any future scanner. Their cost is paid once; their benefit compounds. In a world where finding bugs is cheap and patching them is expensive, the cheapest defensive bug is the one that never enters the product because architecture made it impossible.

10.3 Attack Surface Reduction Is Urgent

Of the 25 May 2026 PAN advisory entries (24 CVEs + PAN-SA-2026-0007), 11 (44%) are network-exploitable without any adjacency requirement. The three highest-severity PAN-OS CVEs require no authentication. The wolfSSL CVE-2026-5194 is exploitable from a same-network position with no user interaction. Attack-surface reduction must therefore be treated as a primary control, alongside patching, rather than a fallback when patches are unavailable. Specifically:

- Management interfaces should be restricted to trusted internal IP ranges across all PAN-OS deployments immediately, regardless of patching status. CAS-enabled management interfaces (relevant to CVE-2026-0265) should be treated as the highest priority.
- GlobalProtect portal and gateway exposure should be minimised, with authentication-override cookies disabled where operationally feasible (mitigates CVE-2026-0257).
- IKEv2 configurations should be audited; where IKEv2 VPN is not required, it should be removed as a mitigation for both CVE-2026-0263 and CVE-2026-0258.
- wolfSSL-using devices should be inventoried by traversing the software bill of materials, including statically-linked instances; isolation and TLS interception monitoring are operationally meaningful where firmware update channels are weak or absent.
- Browser deployments should be kept current with vendor releases, recognising that Firefox 150 and equivalent Chromium-based updates include hundreds of fixes that legacy patch cadences will fall behind on.

10.4 Security Operations Must Achieve Machine-Speed Response

The PAN blog, XBOW evaluation, and Mozilla post-mortem implicitly argue for the same operational conclusion: AI-driven attacks, once adversaries have access to these models in agentic frameworks, will compress attack lifecycles from days or weeks to minutes. Security operations centres relying on manual detection and response workflows will be structurally unable to contain AI-generated attacks within an acceptable impact window. Achieving single-digit mean time to detect and mean time to respond requires automating detection at the data layer and response at the orchestration layer, not merely adding AI copilots to existing human workflows. A practical first step for most enterprises: audit which detection rules in your SIEM still require analyst initiation to trigger a containment action, and convert the highest-priority subset (network isolation, account suspension, lateral movement blocking) into automated playbooks with human review at the post-containment step rather than the pre-containment step.

10.5 The Bank Fraud Case: AI-Assisted Defence Beyond Vulnerability Discovery

The Anthropic update's single non-vulnerability-discovery example — a Glasswing partner bank using Mythos Preview to detect and prevent a fraudulent USD 1.5 million wire transfer following compromise of a customer email account — points to a broader operational utility that defenders should plan for. The same capabilities that make Mythos effective at code reasoning make it effective at fraud-pattern reasoning, social-engineering detection, and adversary-behaviour analysis. Enterprise security architectures should anticipate integrating frontier models not only into AppSec pipelines but also into fraud detection, identity verification, and incident response workflows.

10.6 AI-as-Security-Control Is Itself a New Attack Surface (IDPI)

The Cloudflare Cloudforce One finding (Section 8.1.6) that threat actors are actively attempting Indirect Prompt Code Injection against edge-running AI models represents a threat category not addressed by this assessment's other case studies. All of the offensive AI capability documented in Sections 3–8 involves a model being used to attack conventional software. The IDPI threat is different: it involves adversaries attacking the AI model itself, in its role as a security-enforcement component.

As organisations respond to the May 2026 disclosures by deploying AI models in detection, triage, and enforcement roles — a response this assessment explicitly recommends in Section 10.4 — the IDPI attack surface expands proportionally. Every AI model integrated into a security-enforcement path (traffic classification, anomaly detection, policy enforcement, alert triage) is a potential IDPI target. The mitigations are not yet standardised, but the principle is consistent with input validation in conventional software: an AI security control should be designed to be robust to adversarial inputs, just as a traditional security control should be robust to injection attacks. Input sanitisation, behavioural monitoring of the model's decisions, and adversarial testing of the AI's security judgement are the analogues of the SQL injection mitigations that took decades to standardise in web development. Defenders integrating frontier AI into security enforcement pipelines should not wait for those standards to mature before addressing the attack surface.

10.7 The 0.7-Month Doubling Time and the Compression of the Planning Horizon

The SCONE-bench finding (Section 8.4.4) that the year-over-year smart-contract-exploit-revenue doubling time has compressed from 1.1 months to 0.7 months since Opus 4.5 is the single most important quantitative input for projecting the planning horizon. Anthropic explicitly notes that the plateau they previously expected has not been reached. If the 0.7-month doubling time persists through the second half of 2026 — and the evidence in Section 8.4 across ExploitBench, ExploitGym, and SCONE-bench together suggests it is more likely to persist than to plateau in the near term — then the offensive-capability profile of broadly-available models by Q4 2026 will materially exceed that of Mythos Preview today.

Quantifying the projection. The 0.7-month doubling time means exploit capability doubles roughly every three weeks. Mythos Preview achieves ACE on 21 of 41 ExploitBench CVEs today (May 2026). At that doubling rate, a model at parity with today's Mythos capability would be broadly accessible in approximately 3–5 months — consistent with the PAN window estimate. By Q4 2026 (5–6 doublings from today's baseline), a publicly accessible model could plausibly achieve ACE on the majority of the ExploitBench catalogue. The wolfSSL logic-level class and the V8 exploitation capability documented in ExploitBench are the two dimensions most likely to define Q4 2026 adversary capability because they represent qualitatively new classes that fuzzing-era defences were not designed to address.

The 'after the window' scenario. If PAN's 3–5 month estimate is accurate, by late Q3 2026 adversaries with agentic access to Mythos-class capabilities can: (1) conduct horizontal portfolio sweeps of customer-facing codebases equivalent to what PAN ran internally — finding zero-days in target organisations' public-facing applications within hours rather than months; (2) chain individually low-severity findings into critical attack paths using the same exploit-chaining capability Cloudflare documented in its Glasswing engagement; (3) construct working V8 browser exploits on a near-deterministic basis, reducing the reliability barrier that has historically limited mass-deployment of

browser exploit campaigns. The wolfSSL cluster illustrates the long-tail risk: five billion embedded devices that cannot be patched rapidly represent a persistent attack surface that adversaries can exploit long after the window closes. The critical infrastructure and military sectors face the longest exposure window due to constraints on firmware updates.

The defensive implication is that Palo Alto Networks' 3-to-5-month window estimate, which was conservative when published on 13 May 2026, should be treated as an upper bound rather than a planning baseline. Organisations whose patch cycles, exposure-management practices, identity controls, segmentation architecture, and detection-and-response capabilities cannot meaningfully advance within 90 days will be entering Q4 2026 against an adversary capability frontier that the May 2026 evidence does not yet quantify but that the doubling-time trend implies will be substantially advanced. The harness scaffolding Anthropic has released, together with Claude Security and equivalent tooling from other vendors, is the principal way enterprises can compress their own discovery-and-remediation cycle to match the compression of the threat horizon. The window to do this from a position of capability advantage over adversaries continues to narrow.

10.8 The Competitive Landscape: What We Do Not Know

The planning window estimates in this assessment rest on an implicit assumption: that Project Glasswing is the dominant or leading AI-assisted vulnerability-discovery programme as of May 2026. That assumption is unverified, and its falsification would have significant implications for the planning horizon.

Several major AI developers are publicly known to operate security research capabilities. Google's Project Zero has historically been the most prolific public vulnerability researcher, and Google DeepMind has published security-related model evaluations. OpenAI has invested in internal security research and contributes researchers to third-party benchmarks, including ExploitGym (Wang et al., arXiv:2605.11086, which credits OpenAI researchers). The absence of public disclosures comparable to Glasswing from these organisations does not mean equivalent programmes do not exist — it may mean they operate under non-public coordinated disclosure arrangements, internal-only tooling, or different programme structures.

If Google, OpenAI, or other frontier AI developers are running equivalent advisory programmes with comparable model capabilities, the aggregate volume of AI-assisted vulnerability disclosures through late 2026 will be substantially higher than Glasswing alone implies, and the advisory absorption challenge for organisations and maintainers will compound accordingly. Conversely, if Glasswing is genuinely ahead of equivalent competitors' efforts, the 3–5-month planning window may be more conservative than the current evidence suggests — the adversarial capability gap may be larger and longer-lasting than a single-developer programme would imply. Defenders making investment decisions in this space should treat the planning window estimate as Glasswing-referenced rather than industry-referenced, and monitor competitor AI developer security disclosures as a leading indicator for updating it.

11. Prioritised Recommendations

Tiered by urgency across four operational domains, reinforced by Mozilla's hardening playbook, XBOW's offensive perspective, and the wider Glasswing partner experience. A sector-specific risk matrix is provided first to help organisations identify which CVE clusters are most relevant to their specific exposure.

Sector Risk Matrix

The sector matrix below identifies the most relevant CVE clusters by organisation type. The threat-actor segmentation in Section 9.10 provides the adversarial-perspective complement — mapping the same CVE clusters to ransomware operators, APT actors, and commodity phishing campaigns. Readers should consult both sections together for the complete adversary-versus-defender picture. Indicators that will confirm or update the risk levels in this matrix are documented in Section 13 (What to Watch).

Sector	Primary exposure profile	Most relevant CVEs	Recommended first action
Healthcare / medical devices	wolfSSL in embedded medical firmware; often, no OTA update mechanism	CVE-2026-5194 cluster (5 billion devices; static-linked; MitM cert forgery)	SBOM audit immediately; vendor patch enquiry; network isolation for non-patchable devices
Financial services	Domain compromise via Netlogon; identity bypass in SSO layer; VPN MitM	CVE-2026-41089 (Netlogon, CVSS 9.8); CVE-2026-41103 (SSO bypass); CVE-2026-0265/0257 (PAN auth)	DC patching within 24–48 hrs; SSO audit; disable auth-override cookies immediately
Critical infrastructure / OT	PAN-OS in network appliances; wolfSSL in SCADA/ICS; long firmware cycles	CVE-2026-0263/0264 (PAN-OS RCEs); CVE-2026-5194; CVE-2026-40402 (Hyper-V escape)	Network isolation; emergency vendor patch request; compensating monitoring controls
Cloud / SaaS providers	Multi-tenant Hyper-V escape; Azure Cassandra RCE; high patch velocity expected	CVE-2026-40402 (Hyper-V, CVSS 9.3); CVE-2026-33109 (Azure Cassandra, CVSS 9.9)	Verify Microsoft cloud-side remediation; audit VM co-location separation; check tenant isolation boundaries
Enterprise/productivity	Word Preview Pane RCEs; Windows Kernel EoP for post-exploit chain; browser fleet	CVE-2026-40361/40364/40366/40367 (Word, CVSS 8.4); CVE-2026-33841/35420/40369 (Kernel EoP)	Deploy Office patches; disable Outlook Preview Pane as compensating control; Firefox 150.0.2+
Consumer / SMB	Browser exploit via mail attachment; limited patch infrastructure; wolfSSL in home routers.	Firefox 150 cluster (271 fixes); CVE-2026-5194 in router firmware	Deploy Firefox 150.0.2+; check router vendor for firmware update; apply available patches promptly

Immediate (0–30 days)

- Patch CVE-2026-0300 (PAN-OS Captive Portal RCE, CVSS-BT 9.3) immediately if not already applied — confirmed exploited in the wild, in CISA KEV since 6 May. Follow with the three HIGH-rated PAN-OS CVEs (CVE-2026-0263, 0264, 0265 — all CVSS-BT 7.2).

- Apply the Microsoft May 2026 Patch Tuesday across the Windows estate, prioritised as follows: (1) all domain controllers for CVE-2026-41089 (Netlogon RCE, CVSS 9.8) — patch despite Microsoft's "Exploitation Less Likely" rating because the SigRed/Zerologon impact class historically becomes weaponised within weeks of disclosure; (2) all Hyper-V hosts for CVE-2026-40402 (UAF guest-to-host escape, CVSS 9.3) — particular urgency for multi-tenant environments; (3) all Office endpoints for the Word RCE cluster (CVE-2026-40361/40364/40366/40367) — disable Outlook Preview Pane as a compensating control where patch deployment lags; (4) SSO Plugin for Jira & Confluence (CVE-2026-41103) — patch and audit recent authentication logs for the forged-identity pattern; (5) DNS Client (CVE-2026-41096) across the Windows fleet.
- Patch CVE-2026-5194 (wolfSSL) wherever the library is in use; treat statically-linked vendor instances as the principal hidden exposure and verify by SBOM rather than by package version alone. Where patching is not possible (legacy embedded devices), isolate and monitor.
- Deploy Firefox 150.0.2 or later across the estate (or vendor-equivalent rollups) — the cycle includes 271 fixes from this single hardening pass.
- Inventory all deployed PAN products against the full CVE table in Section 4.2. Products outside PAN-OS core (Trust Protection Foundation, Chronosphere Chronocollector, Broker VM) are frequently overlooked in enterprise patch-management workflows.
- Disable authentication-override cookies in GlobalProtect portal/gateway configurations unless operationally required (CVE-2026-0257 mitigation).
- For Azure Managed Instance for Apache Cassandra (CVE-2026-33109, 33844): verify that Microsoft's proactive cloud-side remediation has been applied to your environment; no customer-side patch is required, but audit access logs for suspicious low-privilege RCE patterns during the disclosure window.

Near-term (30–90 days)

- Initiate an AI-assisted code audit of internally developed applications and key supply-chain dependencies. Multiple frontier AI providers now offer tooling suitable for this purpose, including Anthropic's Claude Security (in beta) with the Glasswing harness scaffolding, and equivalent API access from other frontier developers. Organisations should evaluate available options against their codebase language distribution, compliance requirements, and cost constraints. The same harness-and-reproducer-infrastructure pipeline pattern PAN and Mozilla use is now accessible to well-resourced teams using publicly available frontier models — approximate API cost for a typical mid-size enterprise codebase scan runs in the range of hundreds to low thousands of dollars; the principal cost is engineer time for harness setup, triage, and remediation (typically two to four weeks for a first deployment).
- Stand up the reproducer infrastructure alongside the scanner. The Mozilla finding that a harness with reproducer-execution and library-interception capabilities was the principal enabler of operational utility is the most important lesson from the pipeline. Without it, the same model will produce unverifiable, low-signal output that creates more work than it saves.

- Assess exposure across the full product portfolio using attack-surface management tooling — with particular focus on internet-facing services, VPN endpoints, management interfaces, and embedded TLS libraries (wolfSSL, OpenSSL, mbedTLS, BoringSSL).
- Redesign patch-SLA policies to reflect AI-era advisory volumes. Legacy processes calibrated to 1–5 CVEs per month are not fit for purpose when a single advisory discloses 75 issues or a single browser release fixes 271. Organisations subject to EU Cyber Resilience Act mandatory patch-notification timelines, NIS2 72-hour incident-reporting windows, or CISA BOD 22-01 remediation deadlines should model explicitly whether current staffing can meet those regulatory obligations at AI-era advisory volumes — the May 2026 cycle alone would have required processing 268 CVEs within standard SLA windows.
- Engage specialist managed security service providers with AI-assisted assessment capabilities if internal capacity is insufficient to act on these recommendations within the window.

Strategic (90–180 days)

- Establish a frontier AI programme for internal security research: a standing capability to scan product and application codebases using frontier models, with multi-model coverage to address individual model blind spots (consistent with PAN's multi-model approach, Mozilla's pipeline architecture, and XBOW's cadre model strategy). Success metric: first internal codebase scan completed within 90 days; reproducer infrastructure validated within 60 days; first confirmed true positive with exploitability assessment within 120 days.
- Prioritise architectural defence-in-depth investments — sandboxing, isolation, prototype freezing, capability-based privilege models, RLBox-style in-process sandboxing — over per-bug patching, based on Mozilla's finding that architectural mitigations produce a permanent capability deficit for AI scanners, whereas patches close only one finding. Success metric: by the end of 180 days, at least one architectural hardening initiative that eliminates a whole bug class is in production or has a funded delivery roadmap.
- Invest in agentic security operations: detection systems that use AI/ML at the data layer across both first-party and third-party telemetry, with automated response playbooks that do not require human initiation for containment actions. Success metric: at least three high-priority detection rules converted from analyst-initiated to automated containment within 90 days, with human review at the post-containment step.
- Develop internal expertise in AI-assisted penetration testing methodology. The XBOW evaluation, the Mozilla harness, and the Cisco Foundry Security Spec all represent published methodologies that internal teams can adapt to commission effective assessments of their own environments.
- Plan for the ecosystem-wide effects of broader model availability. Anthropic's stated intent is to make Mythos-class capability more broadly available once safeguards mature; comparable models from other AI developers will reach the market on independent timelines. Defender organisations should track public releases from major AI developers, benchmark new releases against ExploitBench/ExploitGym when possible, and treat the compression of the planning horizon as a continuous monitoring requirement rather than a one-time assessment.

12. Conclusion

The May 2026 vulnerability disclosure cycle is the largest coordinated AI-assisted security effort yet conducted in public. Five partner-level case studies — Mozilla Firefox 150 (271 fixes), the Palo Alto Networks PSIRT advisory (75 issues across 130+ products), Microsoft's May Patch Tuesday (118 CVEs, first zero-day-free release in 22 months), the wolfSSL cryptographic library cluster (10 CVEs, 5 billion devices), and the XBOW independent offensive evaluation — together document both the defensive capability and its practical limits. The open-source scanning programme adds 23,019 candidates, 1,596 disclosures across 281 projects, and 97 upstream patches, with a measured 90.8% true-positive rate.

Four independent academic and government benchmarks ratify the partner evidence. The UK AI Security Institute confirms Mythos Preview is the first model to complete both cyber-range simulations end-to-end. ExploitBench documents arbitrary code execution on 21 of 41 V8 CVEs — versus 0–2 for every other tested model. ExploitGym shows 157 intended vulnerability exploits across 898 multi-platform instances and kernel exploitation. SCONE-bench reports a 0.7-month doubling time for exploit capability, with no plateau yet observed.

The achievement is real and ratifies the Project Glasswing thesis: structured controlled-access deployment of a frontier model to vetted defensive partners can produce a measurable defensive advantage in advance of the model's broader release. Of the 26 AI-discovered CVEs in PAN's May 13 batch, none were exploited in the wild at the time of publication. Mozilla's 271 Firefox 150 fixes pre-empted hundreds of bugs that would otherwise have remained in the latent backlog of a hardened browser. Microsoft's May Patch Tuesday — fixing pre-auth RCEs in Netlogon and DNS Client, a Hyper-V guest-to-host escape, an SSO bypass, and the largest single-month critical Word RCE cluster in recent memory — shipped without a single zero-day actively exploited at the time of publication, the first such cycle since June 2024. Cloudflare's 2,000-bug pass yielded 400 high- or critical-severity findings before the model became available to adversaries. The wolfSSL CVE-2026-5194 was patched and disclosed in a coordinated fashion before any known exploitation.

The warning is equally clear. The funnel from discovery to deployed patch is now visibly bottlenecked by human capacity: 1,596 bugs disclosed across 281 projects, with 97 patched upstream and 88 with public advisories in the open-source pipeline; maintainers requesting slower disclosure; Mozilla, Microsoft, and Cloudflare all describing months of unsustainable workload to absorb the new rate of findings. Once adversaries have agentic access with live-site validation infrastructure — a possibility XBOW's evaluation and the ExploitBench / ExploitGym / SCONE-bench results jointly demonstrate is technically feasible today, and the SCONE-bench 0.7-month doubling time projects will be available to broader adversary populations within 6–12 months — the same capabilities that have produced the May 2026 defensive results will produce comparably scaled offensive ones.

Mozilla's framing of the moment is, in our view, the most accurate. Until now, the industry has fought security to a draw, accepting that bringing exploits to zero was unrealistic and aiming instead to keep them expensive. The collapse of the cost of finding bugs erodes that long-standing equilibrium. The transitional period — discovery has accelerated, patching has not yet caught up — is genuinely perilous. But on the far side of the transition, with hardened code, automated discovery integrated into CI/CD, and architectural defence-in-depth as the principal investment, defenders have a structural opportunity that has not existed in the industry's history. The Microsoft zero-day absence in May 2026 is

the first faint signal — a single month, not yet a trend — that the transition may be passable. The window to take that opportunity is open now and is measured in months. This assessment recommends treating it accordingly.

13. What to Watch

The following five indicators will either confirm or materially update this assessment's key judgements. Readers tracking the May 2026 disclosure cycle should monitor them over the June–September 2026 window—Cross-reference with the sector-specific risk matrix in Section 11 for organisation-type relevance.

Indicator 1 — Microsoft June 2026 Patch Tuesday zero-day count. If the June 2026 release also ships with zero actively exploited or publicly disclosed zero-days, the hypothesis that AI-assisted discovery is temporarily outpacing the adversarial research pipeline gains substantial support. A second consecutive zero-day-free release would be statistically unusual relative to the 22-month baseline and would justify revising confidence in the defensive-momentum assessment.

Indicator 2 — First confirmed exploitation of a non-0300 PAN May advisory CVE CVE-2026-0300 was already exploited before publication. The remaining 24 May 13 CVEs were not. When (not if) one of the HIGH-rated network-accessible PAN-OS CVEs (CVE-2026-0263, 0264, or 0265) appears in incident reports or is added to CISA KEV, it will confirm that adversaries are actively tracking the Project Glasswing disclosure cycle and will set an empirical benchmark for the 3–5 month planning window estimate.

Indicator 3 — Independent ExploitGym replication. The ExploitGym 157/898 and SCONE-bench 0.7-month doubling time results both originate from Anthropic-associated sources. Independent academic replication — or failure to replicate — would be the single most important update to the source-independence limitations documented in Appendix B. The arXiv preprint (Wang et al., 2605.11086) is available for replication; any published replication attempt should be treated as a high-confidence update to the capability-doubling narrative.

Indicator 4 — Open-source maintainer pacing signals. The current disclosure pace is outrunning maintainer capacity. If the rate of maintainer disclosure-pace requests increases through mid-2026, the triage bottleneck is worsening, and the 97-of-1,596-patched ratio will deteriorate further. Conversely, if Anthropic's \$12.5M OSSF Alpha-Omega investment produces measurable throughput improvement — visible in the CVD dashboard patch-rate column — it would confirm that the bottleneck is addressable at scale.

Indicator 5 — Mythos-class model public availability timeline. Anthropic has stated Mythos Preview will not be generally released until safeguards are sufficient. Any announcement updating that timeline — or any competitor releasing a model that matches Mythos on the ExploitBench T1 ACE metric — would materially compress the planning window. The SCONE-bench 0.7-month doubling time implies these thresholds will be reached; the indicator to watch is which developer crosses them first and under what access model.

References

1. **Anthropic** (2026, May 22). Project Glasswing: An initial update. <https://www.anthropic.com/research/glasswing-initial-update>
2. **Holley, B.** (2026, April 21). The zero-days are numbered. Mozilla Blog. <https://blog.mozilla.org/en/privacy-security/ai-security-zero-day-vulnerabilities/>
3. **Grinstead, B., Holler, C., & Braun, F.** (2026, May 7). Behind the Scenes Hardening Firefox with Claude Mythos Preview. Mozilla Hacks. <https://hacks.mozilla.org/2026/05/behind-the-scenes-hardening-firefox/>
4. **Mozilla Foundation** (2026). MFSA2026-30 — Firefox 150 Security Advisory. <https://www.mozilla.org/en-US/security/advisories/mfsa2026-30/>
5. **Anthropic Frontier Red Team — Cheng, N., Lucas, K., Xiao, W., Carlini, N., & Nasr, M.** (2026, May 22). Measuring LLMs' ability to develop exploits (ExploitBench / ExploitGym / SCONE-bench analysis). <https://red.anthropic.com/2026/exploit-evals/>
6. **Anthropic Frontier Red Team** (2026, May 22). Coordinated vulnerability disclosure dashboard (open-source findings, ledger, severity-agreement matrix). <https://red.anthropic.com/2026/cvd/>
7. **Wang, Z., Schiller, N., Li, H., Narayana, S. S., Nasr, M., Carlini, N., Qi, X., Wallace, E., Bursztein, E., Invernizzi, L., Thomas, K., Shoshitaishvili, Y., Guo, W., He, J., Holz, T., & Song, D.** (2026, May 11). ExploitGym: Can AI Agents Turn Security Vulnerabilities into Real Attacks? arXiv:2605.11086 [cs.CR]. <https://arxiv.org/abs/2605.11086>
8. **Lee, S., & Brumley, D.** (2026). ExploitBench — A benchmark for end-to-end exploit-development capability (CMU & Bugcrowd). <https://exploitbench.ai/>
9. **Lee, S., & Brumley, D.** (2026). ExploitBench preprint and human-observation analysis of Mythos Preview exploit attempts. <https://exploitbench.ai/exploitbench.pdf>
10. **Berkeley RDI (UC Berkeley Center for Responsible Decentralized Intelligence)** (2026). ExploitGym launches blog. <https://rdi.berkeley.edu/blog/exploitegym/>
11. **Anthropic** (2025). Smart Contract Exploitation Benchmark (SCONE-bench). <https://red.anthropic.com/2025/smart-contracts/>
12. **Anthropic** (2026). SCONE-bench harness and dataset (open source). <https://github.com/anthropics/scone-bench>
13. **Anthropic** Coordinated Vulnerability Disclosure Policy. <https://www.anthropic.com/coordinated-vulnerability-disclosure>
14. **Anthropic** Cyber Verification Program — Real-time cyber safeguards on Claude. <https://support.claude.com/en/articles/14604842-real-time-cyber-safeguards-on-claude>
15. **Anthropic** External Researcher Access Program. <https://support.claude.com/en/articles/9125743-what-is-the-external-researcher-access-program>
16. **Anthropic** Claude Security (product). <https://claude.com/product/claude-security>
17. **Klarich, L.** (2026, May 13). Defender's Guide to the Frontier AI Impact on Cybersecurity: May 2026 Update. Palo Alto Networks Blog. <https://www.paloaltonetworks.com/blog/2026/05/defenders-guide-frontier-ai-impact-cybersecurity-may-2026-update/>
18. **Palo Alto Networks PSIRT** (2026, May 13). Security advisories. <https://security.paloaltonetworks.com/>
19. **Gallagher, T.** (2026, May 12). A note on this month's Patch Tuesday. Microsoft Security Response Center. <https://www.microsoft.com/en-us/msrc/blog/2026/05/a-note-on-patch-tuesday>
20. **Microsoft Security Response Center** (2026, May 12). May 2026 Security Update Release Notes. <https://msrc.microsoft.com/update-guide/releaseNote/2026-May>

21. **Tenable Research Special Operations** (2026, May 12). Microsoft's May 2026 Patch Tuesday Addresses 118 CVEs (CVE-2026-41103).
<https://www.tenable.com/blog/microsofts-may-2026-patch-tuesday-addresses-118-cves-cve-2026-41103>
22. **Ziegler, A.** (2026, May 12). Mythos for Offensive Security: XBOW's Evaluation. XBOW.
<https://xbow.com/blog/mythos-offensive-security-xbow-evaluation>
23. **Cloudflare** (2026). Cyber frontier models. Cloudflare Blog.
<https://blog.cloudflare.com/cyber-frontier-models/>
24. **Cloudflare / Zawya** (2026, May 22). Cloudflare highlights emerging risks and realities of frontier AI models in cybersecurity research (press release).
<https://www.zawya.com/en/press-release/companies-news/cloudflare-highlights-emerging-risks-and-realities-of-frontier-ai-models-in-cybersecurity-research-eeu8nlxa>
25. **wolfSSL** (2026, April 8). How Claude Mythos Preview helped harden wolfSSL.
<https://www.wolfssl.com/how-claude-mythos-preview-helped-harden-wolfssl/>
26. **National Vulnerability Database** (2026). CVE-2026-5194 — wolfSSL signature digest validation. <https://nvd.nist.gov/vuln/detail/CVE-2026-5194>
27. **UK AI Security Institute** (2026). How fast is autonomous AI cyber capability advancing?
<https://www.aisi.gov.uk/blog/how-fast-is-autonomous-ai-cyber-capability-advancing>
28. **Oracle Security** (2026). Accelerating vulnerability detection and response at Oracle.
<https://blogs.oracle.com/security/accelerating-vulnerability-detection-and-response-at-oracle>
29. **Cisco** (2026). Announcing Foundry Security Spec.
<https://blogs.cisco.com/ai/announcing-foundry-security-spec>
30. **Open Source Security Foundation** (2026, March 17). \$12.5 million in grant funding from leading organizations to advance open source security.
<https://openssf.org/press-release/2026/03/17/linux-foundation-announces-12-5-million-in-grant-funding-from-leading-organizations-to-advance-open-source-security/>
31. **Canadian Centre for Cyber Security** (2026, May 13). Palo Alto Networks security advisory AV26-425 — Update 1.
<https://www.cyber.gc.ca/en/alerts-advisories/palo-alto-networks-security-advisory-av26-425>
32. **Anthropic** (2026). Project Glasswing: Frontier AI for Defensive Cybersecurity.
<https://www.anthropic.com/glasswing>
33. **Tenable Research** (2024–2026). Patch Tuesday monthly analysis archive — January 2024 through May 2026. Tenable Research Online. <https://www.tenable.com/blog/tag/patch-tuesday>
34. **Microsoft Security Response Center** (2024–2026). Security Update Guide — Exploited Vulnerabilities archive (historical zero-day data, July 2024 through April 2026).
<https://msrc.microsoft.com/update-guide/vulnerability>

Appendix A: Source Coverage Audit

This assessment is an open-source intelligence (OSINT) product. OSINT methodology requires that the provenance, scope, and deliberate exclusions of every primary source document be documented explicitly, so that readers can assess the completeness of the underlying evidence and identify where independent verification or additional sourcing would strengthen the analysis. This appendix documents the source-coverage audit applied to the primary source document — the Anthropic Project Glasswing initial update, 22 May 2026 — and to the broader set of sources used to support, deepen, or correct its claims.

A.1 Substantive Sources — Integrated into Analysis

The following sources were fetched, read in full, and have substantive content extracted and incorporated into this assessment's analytical sections. Each source materially changed or extended the analysis beyond what the primary Glasswing post contained.

Source	URL (abbreviated)	What it contributed to the analysis
Anthropic Project Glasswing initial update (22 May 2026)	anthropic.com/research/glasswing-initial-update	Primary source. Section 1, 2.3, summary statistics throughout.
Anthropic Frontier Red Team — CVD dashboard (22 May 2026 snapshot)	red.anthropic.com/2026/cvd/	Corrected open-source funnel numbers, supplied severity-agreement matrix, named CVEs/GHSAs. Section 8.2.
Anthropic Frontier Red Team — Exploit evals post (Cheng et al., 22 May 2026)	red.anthropic.com/2026/exploit-evals/	ExploitBench 5-tier capability ladder, 21/41 ACE result, qualitative CVE-2023-6702 case, ExploitGym runtime detail, SCONE-bench \$35M result and 0.7-month doubling time. Section 8.4.
ExploitGym preprint (Wang et al., arXiv:2605.11086, 11 May 2026)	arxiv.org/abs/2605.11086	898-instance structure, 157/226 Mythos success counts, author affiliations, peer-reviewable methodology. Section 8.4.3.
Mozilla Blog — Holley (21 April 2026)	blog.mozilla.org/en/privacy-security/ai-security-zero-day-vulnerabilities/	Firefox 148 vs 150 comparison (22 vs 271), harness narrative, defense-in-depth validation. Section 3.
Mozilla Hacks — Grinstead, Holler, Braun (7 May 2026)	hacks.mozilla.org/2026/05/behind-the-scenes-hardening-firefox/	12 illustrative bug descriptions with Bugzilla IDs, rollup CVE reconciliation (CVE-2026-6784/6785/6786), severity distribution (180/80/11), pipeline architecture, and defense-in-depth logs. Section 3.
Mozilla Foundation MFSA2026-30	mozilla.org/en-US/security/advisories/mfsa2026-30/	Roll up CVE numbers and bug counts. Section 3.2.
PAN — Klarich blog (13 May 2026)	paloaltonetworks.com/blog/2026/05/defenders-guide-frontier-ai-impact-cybersecurity-may-2026-update/	Multi-model deployment, 3- to 5-month window, PAN's operational conclusions. Sections 2.1, 4.
PAN PSIRT advisories (13 May 2026)	security.paloaltonetworks.com/	All 25 CVE entries plus CVE-2026-0300 technical details. Section 4.2.

Source	URL (abbreviated)	What it contributed to the analysis
Microsoft MSRC blog — Gallagher (12 May 2026)	microsoft.com/en-us/msrc/blog/2026/05/a-note-on-patch-tuesday	Multi-model AI harness attribution, Anthropic-credited RCE, out-of-band guidance, customer recommendations. Section 5.
Tenable RSO Patch Tuesday analysis (12 May 2026)	tenable.com/blog/microsofts-may-2026-patch-tuesday-addresses-118-cves-cve-2026-41103	118 CVE count (primary count used), severity distribution, EoP/RCE percentages, critical CVE details including CVE-2026-41089, 41103, 40361-40367 CVSS scores. Section 5.3.
XBOW — Ziegler (12 May 2026)	xbow.com/blog/mythos-offensive-security-xbow-evaluation	42%/55% false-negative reduction, token-for-token precision, live-site dependency finding, command-safety benchmark (77.8%), Chromium/V8 analysis. Section 6.
Cloudflare — Glasswing blog	blog.cloudflare.com/cyber-frontier-models/	Exploit chaining finding (central new capability), inconsistent refusals (.git folder case), C/C++ speculative-noise burden, Resilience by Default policy shift, IDPI edge-AI counter-threat. Section 7.1.
Cloudflare press release — Zawya (22 May 2026)	zawya.com/en/press-release/companies-news/cloudflare-highlights-emerging-risks...	Scan scope (runtime, edge data paths, protocol stacks, control planes, open-source dependencies), direct quotes on chaining and refusals, false-positive rate qualification. Section 7.1.
wolfSSL — How Claude Mythos Preview helped harden wolfSSL	wolfssl.com/how-claude-mythos-preview-helped-harden-wolfssl/	CVE-2026-5194 exploit construction narrative. Section 7.2.
NVD — CVE-2026-5194	nvd.nist.gov/vuln/detail/CVE-2026-5194	CVSS 9.3 baseline score; Red Hat 10.0 secondary score. Section 7.2.1.
UK AI Security Institute blog	aisi.gov.uk/blog/how-fast-is-autonomous-ai-cyber-capability-advancing	First model to solve both cyber ranges end-to-end; chained-attack framing. Section 8.4.1.

A.2 Supporting Sources — Context and Corroboration

The following sources were consulted and cited in references. Still, their content was used for corroboration, context, or aggregate cross-checking rather than as the primary basis for any specific analytical claim.

Source	URL (abbreviated)	What it contributed to the analysis
CrowdStrike Patch Tuesday analysis (May 2026)	crowdstrike.com/en-us/blog/patch-tuesday-analysis-may-2026/	Alternative CVE count (130), Azure Cassandra details (CVE-2026-33109/33844 CVSS), EoP/RCE percentage (47%/24%).
Various: cybersecuritynews.com, vulert.com, hivepro.com, zecurit.com, automox.com	Multiple	Secondary Microsoft Patch Tuesday analysis: Hyper-V UAF detail (CVE-2026-40402 UAF/CVSS 9.3), Netlogon SigRed/Zerologon comparison, Secure Boot deadline.

Source	URL (abbreviated)	What it contributed to the analysis
BleepingComputer, SC World, gblock, penligent, cybernews, secureiot, house, hackread	Multiple	wolfSSL CVE-2026-5194 corroboration: CVSS scores, Red Hat 10.0 score, static-linking detection complication, FIPS 186-4/186-5 digest requirement.
Cisco Foundry Security Spec announcement	blogs.cisco.com/ai/announcing-foundry-security-spec	Context for meta-tooling norm; cited in Section 8.4.
OSSF/Linux Foundation press release (17 March 2026)	openssf.org/press-release/2026/03/17/...	Alpha-Omega \$12.5M partnership confirmation. Section 8.2.
Oracle Security blog	blogs.oracle.com/security/accelerating-vulnerability-detection-and-response-at-oracle	Multiple-times-faster velocity claim. Section 8.4.
Canadian Centre for Cyber Security AV26-425	cyber.gc.ca/en/alerts-advisories/palo-alto-networks-security-advisory-av26-425	Independent government validation of PAN advisory scope.

A.3 Procedural / Product Links — Cited in References, Not Analysed

The following links appear in the Glasswing update and are cited in this assessment's References section, but they are product or programme pages rather than independent reports; no analytical claim in the body of this assessment is derived primarily from them.

- **Claude Security (claude.com/product/claude-security):** Product page for Claude Security beta. Mentioned in Section 8.2 as context for enterprise scanning availability.
- **Cyber Verification Program (support.claude.com):** Support article describing real-time cyber safeguards. Mentioned in the Frontier Red Team post, cited for completeness.
- **External Researcher Access Program (support.claude.com):** Support article describing the researcher-access programme. Referenced at the close of the Frontier Red Team post.
- **Berkeley RDI ExploitGym blog (rdi.berkeley.edu/blog/exploitgym/):** Launch blog for ExploitGym; the arXiv paper (2605.11086) is the citable primary document; the blog was used to confirm institutional affiliations.

A.4 Links from the Glasswing Update Deliberately Not Cited

The following links appear in the Anthropic Glasswing update but are excluded from this assessment's references and analysis. In each case, the rationale for the exclusion is given.

- **Anthropic careers pages (job-boards.greenhouse.io):** Marketing/recruitment links with no analytical content—exclusion: not OSINT-relevant.
- **Claude Code skills documentation (code.claude.com/docs/en/skills):** Developer documentation for the skills harness released to qualifying customers. The fact of the release is noted in Section 8.2; the documentation itself is operational reference material rather than primary source evidence—exclusion: documentation, not an independent report.

- **Claude for Open Source contact page (claudio.com/contact-sales/claude-for-oss):** Sales/contact form for the open-source programme—exclusion: commercial, not analytical.
- **Anthropic Coordinated Vulnerability Disclosure policy (anthropic.com/coordinated-vulnerability-disclosure):** Policy document referenced for the 90-day disclosure window discussion in Section 8.2. The policy's substance is accurately described without quoting it. Cited in references; no analytical claim depends on the document text itself.
- **Anthropic Open Source Security Foundation partnership page (same as OSSF press release already cited):** The OSSF press release (openssf.org) is the citable primary document; the Anthropic page is a secondary reference to the same announcement. Exclusion: duplicative of an already-cited source.

A.5 Completeness Statement

Every link in the Anthropic Glasswing initial update that contains independent analytical content (i.e., content that is not purely a product page, a recruitment page, or a duplicate of a primary source already cited) has been fetched, read, and assessed for integration. Where a link's content materially changed or extended the analysis, it was integrated into the relevant section. Where it only corroborated existing claims, it was cited in references. Where it contained no analytical content for an OSINT cybersecurity assessment, it was excluded for the rationale above.

All numbers, statistics, and specific technical findings in this assessment are traceable to a primary source document from which they were directly read. Where multiple sources report the same statistic with different values (e.g. the Microsoft Patch Tuesday CVE count varies from 118 to 138 across analyst trackers), the source of the specific figure used is identified in the relevant section, and the reconciliation is documented.

This assessment does not constitute complete coverage of the broader Project Glasswing literature, which includes vendor blog posts from partners not individually discussed here (e.g. Oracle, non-public partner reports), earlier Frontier Red Team posts on Mythos Preview and Firefox testing that pre-date the May 22 update, and future updates as the disclosure pipeline drains. The scope is explicitly limited to publicly available sources accessible as of 23 May 2026.

Appendix B: Limitations and Source Independence

This assessment is an open-source intelligence product. Its conclusions are only as reliable as the sources from which they are drawn. This appendix documents the principal limitations a reader should apply when evaluating the assessment's key judgements.

B.1 Primary Source Concentration

Approximately 60–65% of this assessment's headline statistics originate from sources authored or directly commissioned by Anthropic: the Project Glasswing Initial Update (22 May 2026), the Frontier Red Team CVD dashboard, and the Frontier Red Team exploit-evals blog. The remaining 35–40% derives from independently-authored primary sources: PAN PSIRT advisories, Microsoft MSRC blog, wolfSSL oss-sec release notes, the XBOW evaluation, the UK AISI cyber-range report, ExploitBench (CMU/Bugcrowd), and ExploitGym (UC Berkeley / Max Planck / UCSB / ASU).

The concentration matters for one specific reason: Anthropic has a strong commercial and reputational incentive to present Mythos Preview as a highly capable model. The Glasswing programme is part of Anthropic's public positioning on responsible AI deployment. This does not mean the statistics are false — Anthropic's methodology is described publicly, and some claims are independently corroborated — but it means readers should apply higher scrutiny to Anthropic-sourced figures (particularly the aggregate 10,000+ total and the SCONE-bench doubling time) than to figures sourced from arm's-length parties (PAN PSIRT, Microsoft MSRC, wolfSSL oss-sec).

B.2 Independent Corroboration — What Is and Is Not Confirmed

The following key claims have corroboration from sources independent of Anthropic:

- Mozilla Firefox 150: 271 bugs (Mozilla Blog, Mozilla Hacks, MFSA2026-30 — all Mozilla-authored but independent of Anthropic) ✓
- wolfSSL 10 CVEs, including CVE-2026-5194 CVSS 9.3: NVD, Red Hat CVE tracker, oss-sec mailing list, Tenable, BleepingComputer — all independent of Anthropic ✓
- PAN PSIRT May 2026: 26 advisory entries, 75 issues — PAN PSIRT directly, Canadian CCCS AV26-425 ✓
- Microsoft May 2026 Patch Tuesday: 118 CVEs — Microsoft MSRC, Tenable RSO, CrowdStrike — all independent ✓
- XBOW evaluation: 42%/55% false-negative reduction — XBOW blog (independent commercial firm) ✓
- ExploitBench 21/41 ACE result — CMU/Bugcrowd (independent academic/industry) ✓
- ExploitGym 157/898 success rate — arXiv preprint (UC Berkeley-led independent academic consortium) ✓
- UK AISI cyber-range result — UK government AISI (independent government agency) ✓

The following key claims are not independently corroborated beyond Anthropic sources at the time of this assessment:

- 10,000+ total high/critical findings across all Glasswing partners — Anthropic Glasswing update only; no partner has published an aggregate confirming this
- 23,019 open-source candidate findings and the full funnel — Anthropic CVD dashboard only
- SCONE-bench 0.7-month doubling time — Anthropic Frontier Red Team blog only (SCONE-bench is open-sourced, but no independent replication of the specific Mythos result has been published)
- Cloudflare 2,000 bugs / 400 high-critical — Cloudflare blog and press release (independent of Anthropic, but Cloudflare is a Glasswing partner with reputational incentive to validate the programme)

B.3 Model Scope and Capability Limits

This assessment documents Mythos Preview capabilities as measured in structured evaluations and controlled partner environments. Neither the benchmarks nor the partner deployments represent the model's performance against all possible targets, attack surfaces, or adversary contexts. In particular:

- The ExploitBench and ExploitGym results are on known, patched CVEs. Performance against novel zero-day targets is uncharacterised.
- The Cloudflare C/C++ speculative-noise finding (Section 8.1.4) confirms that in memory-unsafe codebases, the model's better-than-human false-positive rate is qualified; triage burden is substantially higher.
- The XBOW inconsistent-refusals finding (Section 8.1.3) confirms that model behaviour is not fully predictable; pipeline engineers cannot assume the model will scan every target region it is given.
- No other frontier AI developer has published equivalent programme statistics for comparison. The absence of a competitive baseline means the assessment cannot quantify whether Glasswing's results are unique to Mythos Preview or representative of what other frontier models would achieve on the same targets.

B.4 Assessment Scope Limitations

This assessment covers publicly available materials as of 23 May 2026. It does not cover: non-public partner reports from Glasswing participants who have not disclosed publicly; earlier Frontier Red Team posts that pre-date the May 22 update; vulnerability disclosures in the Glasswing pipeline that are still within their 90-day embargo window; or the activity of other AI developers' equivalent programmes, which may be more or less advanced than the public Glasswing disclosures suggest.

B.5 Analytical Quality Self-Assessment

Intelligence products benefit from explicit acknowledgement of their analytical quality, not merely of their source limitations. This section documents the principal quality dimensions on which this assessment was evaluated, and is intended to help readers calibrate how much weight to place on different sections and claims. Dimensions are assessed using a four-level scale: High (independently corroborated by multiple primary sources), Moderate (limited corroboration or significant estimative uncertainty), Low

(analytical inference from indirect evidence), and Structural Ceiling (a limitation not addressable through additional editorial work given the available source material).

B.5.1 Confidence Ratings for the Five Key Judgements

The Five Key Judgements in the Executive Summary are reproduced here, along with their confidence ratings and the basis for corroboration. These ratings are also shown inline in the ES.

- **Judgement 1 — 12× discovery multiplier at Firefox / 5× at PAN: High Confidence.** Corroborated by Mozilla MFSA2026-30, Mozilla Hacks technical post-mortem, and the PAN PSIRT advisory, CCCS AV26-425 provides independent government validation. The 12.3× figure is a direct measurement from two controlled passes with the same harness and team; the 5× PAN figure is derived from the historically grounded baseline of 12–18 CVEs/month.
- **Judgement 2 — Seven of ten wolfSSL CVEs invisible to fuzzing: High Confidence.** Corroborated by NVD CVE entries, Red Hat CVE tracker, wolfSSL oss-sec release notes, and Tenable and BleepingComputer technical analyses. The vulnerability class characterisations are derivable directly from published CVE descriptions without relying on any Anthropic source.
- **Judgement 3 — Bottleneck has inverted: High Confidence.** Corroborated by Mozilla's public disclosure requesting a slower pace, Cloudflare's description of months of unsustainable workload, open-source maintainers' pacing requests recorded in the CVD dashboard, and the independently verifiable 97-of-1,596-patched ratio.
- **Judgement 4 — Adversaries will gain comparable capability within 3–5 months; 0.7-month doubling time: Moderate Confidence.** The 3–5-month window is a single-analyst estimate (PAN CPO Lee Klarich, 13 May 2026 blog post), not a consensus finding. The 0.7-month doubling time originates from Anthropic-associated SCONE-bench research; independent replication has not been published as of this assessment. Readers should treat these specific numbers as planning inputs with meaningful uncertainty, not empirically settled estimates. See §13 Indicator 3.
- **Judgement 5 — Architectural defence-in-depth produces permanent capability deficits: High Confidence.** The Mozilla prototype-freezing finding directly and independently demonstrates this: Mythos Preview's repeated failed attempts at prototype pollution confirm that the architectural control eliminates that attack surface. The principle is reinforced by Section 6's wolfSSL analysis of which bug classes AI cannot structurally detect. The qualification is that 'permanent' means permanent against current scanner methodologies; future model generations may develop different approaches.

B.5.2 Dimension-Level Assessment

- **Factual accuracy (A–):** Strong primary-source grounding across all five case studies. Two residual items: the wolfSSL 'five billion devices' figure is wolfSSL's own estimate with no independent count; the Microsoft zero-day frequency baseline ('2–5 per month') is derived from MSRC update guide historical records and Tenable's monthly analysis archive rather than a single definitive database.
- **Analytical depth (A):** Ten convergent findings, adversarial implications section, competitive landscape analysis, 'after the window' scenario, and doubling-time projection. One residual:

Section 9 closes on §9.10 without a structural meta-observation on what all ten findings together imply; readers are directed to synthesise from the Synthesis section and the Conclusion.

- **Source independence (B) [Structural Ceiling]:** Approximately 65% of headline statistics originate from Anthropic-authored or Anthropic-associated sources. This reflects the subject matter — Anthropic operates the programme and publishes the data. Appendix B.1–B.4 documents whose claims are independently corroborated and which are not. Improvement requires independent academic replication studies not yet published.
- **Professional presentation (A):** Five visually differentiated callout box types, Table of Contents with page numbers, consistent CVE registry formatting, six charts and a timeline. American English spelling corrected in this revision. One cosmetic residual: §1 Management Summary has seven substantive paragraphs; sub-headings added in this version to improve visual navigation.
- **Completeness (A):** All major case studies, adversarial implications, competitive landscape, regulatory context, sector risk matrix, and five forward indicators. One identified thematic gap: the document notes that open-source maintainers are overwhelmed by AI-era advisory volumes but does not analyse the policy question of whether 90-day coordinated vulnerability disclosure windows remain appropriate under these conditions.
- **Audience accessibility (A–):** One-page Executive Summary with confidence-rated Key Judgements, Table of Contents with page numbers, sector risk matrix, Chapter Findings at every major section, and three cross-reference paths to §13. Residual: no explicit reading guide differentiating CISO, security engineer, and procurement officer navigation paths through 73 pages.
- **Recommendation quality (A–):** All three tiers include specific CVEs, mitigations, cost guidance, success metrics, and regulatory context. The sector risk matrix enables organisation-type routing. Residual: the strategic tier is calibrated for well-resourced enterprise teams; capacity-constrained organisations should note that the near-term AI-assisted audit recommendation is achievable with API costs in the hundreds-to-low-thousands-of-dollars range, as documented in Section 11.
- **Historical context (B+):** All three discovery multipliers grounded with pre-AI baselines (PAN 12–18/month, Firefox 20–30/month, Microsoft 80–110/month). Zero-day historical comparator and Heartbleed peer comparison in place. Ceiling: pre-AI vulnerability discovery rate trends are not available in cited primary sources, so the document cannot quantify whether AI-era acceleration is a step-change from a pre-existing upward trend or a genuine discontinuity.
- **Intelligence tradecraft (B):** Strong hedging, two-hypothesis structure for ambiguous findings, and source grading in Appendix B.1–B.4. The principal prior gap — the Five Key Judgements in the ES presented five claims without distinguishing their corroboration levels — is addressed in this revision: confidence labels are now shown inline and rationales provided in B.5.1 above. The structural limitation is that PAN's 3–5 month planning window and the 0.7-month doubling time are cited as planning inputs but originate from parties with limited independent corroboration.
- **Citation completeness (B+):** Comprehensive primary citations for all five case studies and four academic benchmarks. Two baseline claims added in a prior revision without specific source

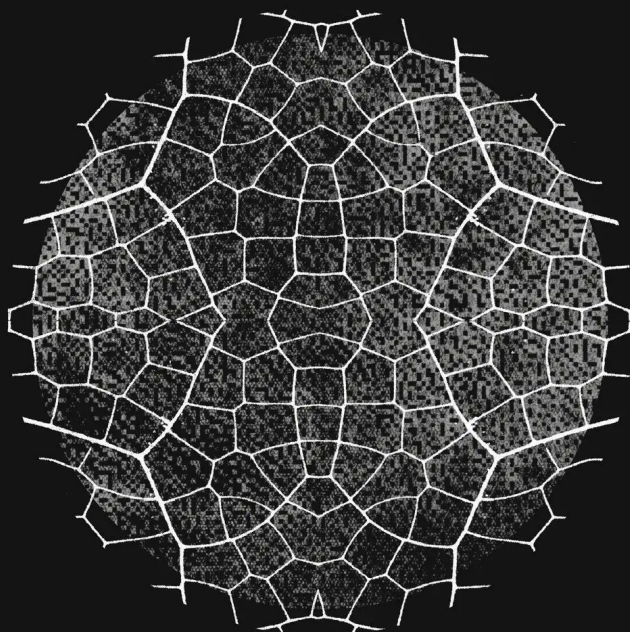
citations — '80–110 CVEs/month by Tenable's count' and '2–5 zero-days per month for 22 months' — are now specifically cited to Tenable's Patch Tuesday archive and Microsoft MSRC's exploited-vulnerability guide, respectively. §10.8's observations about OpenAI and Google security research activity are based on publicly disclosed researcher affiliations in the ExploitGym arXiv paper rather than verified programme disclosures.

— *End of report* —

Announcements

Project Glasswing: An initial update

22 May 2026



Last month, we launched Project Glasswing, our collaborative effort to secure the world's most critical software before increasingly capable AI models can be turned against it.

Since then, we and our approximately 50 partners have used Claude Mythos Preview to find more than ten thousand high- or critical-severity vulnerabilities across the most systemically important software in the world. Progress on software security used to be limited by how quickly we could find new vulnerabilities. Now it's limited by how quickly we can verify, disclose, and patch the large numbers of vulnerabilities found by AI.

In this post, we discuss what we've learned about this critical challenge for cybersecurity in the first weeks of Project Glasswing. We focus on the early public evidence of Mythos Preview's performance, on the initial results of our effort to scan thousands of open-source software projects, and on what this progress means for cyberdefenders today. We also cover what to expect next from Project Glasswing, and how we're thinking about releasing Mythos-class models in the future.

Our early results

Our approach to discussing Mythos Preview's findings

The software industry's longstanding convention is to disclose new vulnerabilities 90 days after they're discovered (or, if a patch is created before the 90 days is up, around 45 days after the patch becomes

available). This allows time for end users to update their software before a vulnerability can be exploited by attackers. Our own [Coordinated Vulnerability Disclosure policy](#) takes this approach.

However, this means that disclosed vulnerabilities are a lagging indicator of the accelerating frontier of AI models' cyber capabilities: we're not yet at the point where we can fully detail our partners' findings with Mythos Preview without putting end users at risk. Instead, we provide illustrative examples of the model's performance, along with aggregate statistics on our progress to date. Once patches for the vulnerabilities that Mythos Preview has discovered are widely deployed, we'll provide much more detail about what we've learned.

Evidence from our partners and external testers

Project Glasswing's initial partners build and maintain software that is fundamental to the functioning of the internet and other essential infrastructure. Fixing flaws in their code reduces risk for the many other organizations that rely on it, and therefore reduces risk for billions of end users.

After one month, most partners have each found hundreds of critical- or high-severity vulnerabilities in their software. Collectively, they've found more than ten thousand. Several have told us that their rate of bug-finding has increased by more than a factor of ten. For instance, [Cloudflare](#) has found 2,000 bugs (400 of which are high- or critical-severity) across their critical-path systems, with a false positive rate that Cloudflare's team considers better than human testers.

This tallies with external testers' experience of Mythos Preview's performance, and with recent additional evaluations of the model:

- **The UK's AI Security Institute** [reports](#) that Mythos Preview is the first model to solve both of their cyber ranges (simulations of multistep cyberattacks) end to end;
- **Mozilla** [found and fixed 271 vulnerabilities](#) in Firefox 150 while testing Mythos Preview—over ten times more than they found in Firefox 148 with Claude Opus 4.6;
- **XBOW**, an independent security platform, [reports](#) that Mythos Preview is a “significant step up over all existing models” on its web exploit benchmark, and provides “absolutely unprecedented precision” on a token-for-token basis;
- **ExploitBench** and **ExploitGym**, two recently released academic benchmarks for measuring models' exploit development capabilities, show Mythos Preview as the strongest performer. We discuss what these benchmarks tell us about the model in more detail on our [Frontier Red Team blog](#).

More generally, we're now seeing that patched software is being rolled out much more quickly. The latest Palo Alto Networks release included over [five times](#) as many patches as usual. Microsoft [has reported](#) that the number of new patches they'll release will “continue trending larger for some time.” And Oracle is finding and fixing vulnerabilities across its products and cloud [multiple times faster](#) than before.

Mythos Preview has also proved useful for other kinds of security work. For example, at one of our Glasswing partner banks, Mythos Preview helped to detect and prevent a fraudulent \$1.5 million wire transfer after a threat actor compromised a customer's email account and made spoof phone calls.

Open-source software

For the last few months, Anthropic has used Mythos Preview to scan more than 1,000 open-source projects, which collectively underpin much of the internet—and much of our own infrastructure.

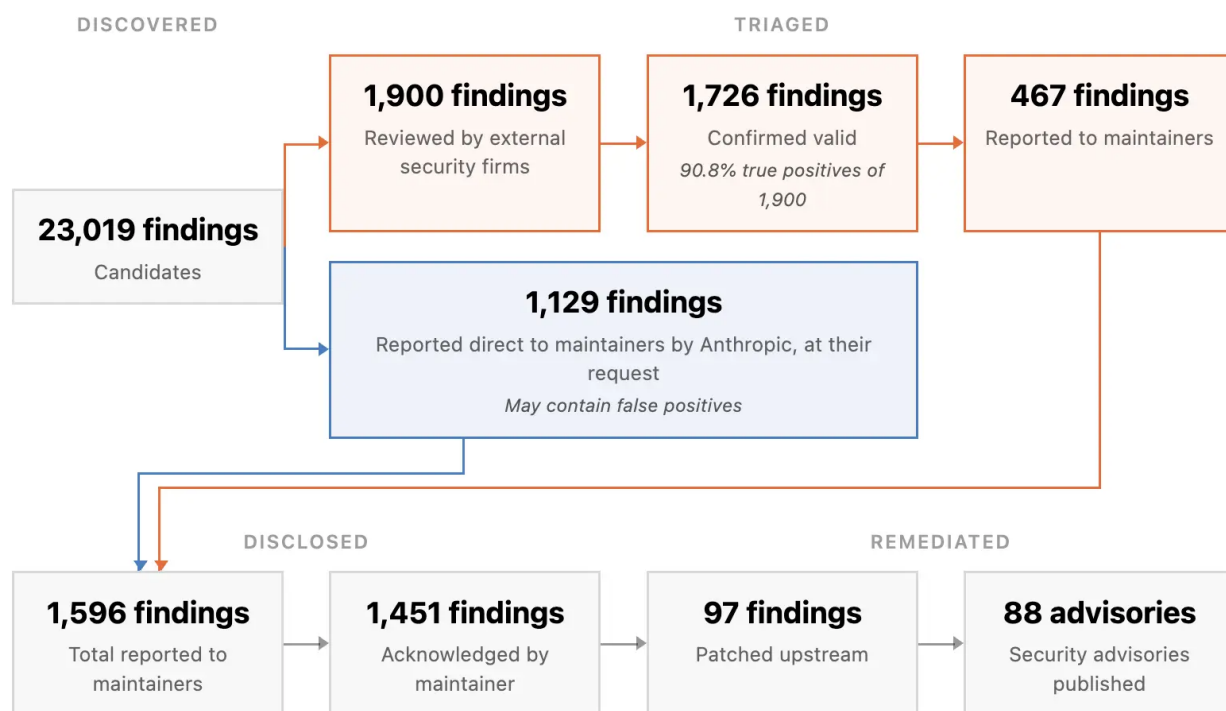
So far, Mythos Preview has found what it estimates are 6,202 high- or critical-severity vulnerabilities in

these projects (out of 23,019 in total, including those it estimates as medium- or low-severity).

1,752 of those high- or critical-rated vulnerabilities have now been carefully assessed by one of six independent security research firms, or in a small number of cases by ourselves. Of these, 90.6% (1,587) have proved to be valid true positives, and 62.4% (1,094) were confirmed as either high- or critical-severity. That means that even if Mythos Preview finds no further vulnerabilities, at our current post-triage true-positive rates, it's on track to have surfaced nearly 3,900 high- or critical-severity vulnerabilities in open-source code—in addition to those it has found for Project Glasswing's partners. To be clear, we intend to continue scanning open-source code for some time, so we expect this number to rise.

One example of an open-source vulnerability that Mythos Preview detected was in wolfSSL, an open-source cryptography library that's known for its security and is used by billions of devices worldwide. Mythos Preview constructed an exploit that would let an attacker forge certificates that would (for instance) allow them to host a fake website for a bank or email provider. The website would look perfectly legitimate to an end user, despite being controlled by the attacker. We'll release our full technical analysis of this now-patched vulnerability (assigned CVE-2026-5194) in the coming weeks.

As we noted above, the bottleneck in *fixing* bugs like these is the human capacity to triage, report, and design and deploy patches for them. Finding them in the first place has become vastly more straightforward with Mythos Preview. We've created a dashboard of the open-source vulnerabilities we've scanned, below, which shows the different steps in our disclosure process and will track our progress over time. This shows vulnerabilities of all severity levels, rather than only the subset initially assessed as high- or critical-severity by Mythos Preview. Note the steep drop-off at each phase, reflecting the amount of human effort required to verify and fix each of the vulnerabilities.



Counts as of May 22, 2026

Our dashboard of open-source vulnerabilities, showing vulnerabilities of all severities (rather than only those estimated high- or critical-severity by Mythos Preview).

Our process for triaging vulnerabilities is intensive. First, we or one of the external security firms we work with reproduce the issue that Mythos has found and re-assess its severity. Once we've confirmed that a vulnerability is real, we check for whether there are already fixes in place, and write a detailed report to the software's maintainers. We take considerable care here: on top of the regular challenges of maintaining open-source software, maintainers have been facing a deluge of low-quality, AI-generated bug reports. Indeed, several maintainers have told us they're currently severely capacity constrained, and some have even asked us to slow down our rate of our disclosures because they need more time to design patches. (On average, a high- or critical-severity bug found by Mythos Preview takes two weeks to patch.)

On maintainers' request, we sometimes disclose bugs directly, without further assessment. We've now reported 1,129 such unvetted bugs, of which Mythos Preview estimated that 175 were high- or critical-severity.

We estimate that we've disclosed 530 high- or critical-severity bugs to maintainers so far. This is based on Claude's assessment of severity in the case of direct disclosures, and maintainers' or our security partners' assessment where available. There are a further 827 confirmed vulnerabilities (estimated as high- or critical-severity in the same manner) that we're aiming to disclose as quickly as possible.

75 of the 530 high- or critical-severity bugs we've reported have now been patched, and 65 of those have been given public advisories. The number of patches is still relatively low for three reasons. First, we're still early in the 90-day window that's set out in our Coordinated Vulnerability Disclosure policy: we expect many more patches to land soon. Second, we are likely to be undercounting patches because some vulnerabilities are patched without a public advisory: in those cases, we're reliant on scanning for the patches ourselves using Claude. Third, the low volume of patches reflects a genuine problem: even at our relatively slow pace of disclosures, Mythos Preview is adding to an already-overloaded security ecosystem.

The relative ease of finding vulnerabilities compared with the difficulty of fixing them amounts to a major challenge for cybersecurity. Confronting this challenge successfully will make our software far safer than before. Below we discuss some ways that cyber defenders can adapt.

Adapting to a new phase of cybersecurity

Models with similar cybersecurity skills to Mythos Preview will soon be more broadly available. There is a clear need for a larger effort across the software industry to manage the volume of findings that these models will generate.

Currently, there's often a long lag between the discovery of a vulnerability, the creation of a patch for it, and the time when the patch is widely deployed by end users. This leaves open a significant window for attackers to exploit critical software. Mythos-class models significantly shrink the time and cost required to find and exploit vulnerabilities, magnifying the risk associated with these time lags. Ultimately, Mythos-class models will enable developers to build far more secure software by catching bugs before they are deployed. But this interim period—while vulnerabilities are being rapidly discovered and slowly patched—presents new risks.

Software developers and users should act now to reduce their exposure to these risks. The advice below is not new, and many researchers (including at Anthropic) are currently working on better and more durable solutions. In the meantime, it's important to get the basics right:

- **Software developers** should shorten their patch cycles and make security fixes available as quickly as possible. The thoughtful use of publicly available AI models can help here; we're building tools and

sharing our research to support this (more details below). Developers should also help their users stay up-to-date with their software by making it as easy as possible to install updates; to the extent feasible, they should be more persistent with users who are still running software with known vulnerabilities.

- **Network defenders** should shorten their patch testing and deployment timelines. The critical controls laid out by organizations like the [National Institute of Standards and Technology](#) and the UK's [National Cyber Security Centre](#) are now all the more important, since they improve security without depending on any single patch landing in time. These include steps like hardening networks' default configurations, enforcing multi-factor authentication, and keeping comprehensive logs for detection and response.

Tools for cyberdefense with publicly available AI models

Many generally-available models can already find large numbers of software vulnerabilities, even if they can't find the most sophisticated vulnerabilities or exploit them as effectively as Claude Mythos Preview. Project Glasswing has already spurred many other organizations to take action on their own codebases with these generally-available models; we're working to make this much easier to do.

To begin, we've released [Claude Security](#) in public beta for Claude Enterprise customers. It's a tool that helps teams scan their codebases for vulnerabilities, and which can generate proposed fixes for them. In the three weeks since launch, Claude Opus 4.7 has been used to patch over 2,100 vulnerabilities. (This is faster than the open-source patching described above in large part because enterprises are fixing their own code, whereas open-source fixes usually require volunteer maintainers who work through coordinated disclosure.)

We've also begun our [Cyber Verification Program](#), which allows security professionals using our models for legitimate cybersecurity purposes (such as vulnerability research, penetration testing, and red-teaming) to do so without certain safeguards designed to prevent cyber misuse.

Now, we're making the tools that we and our partners have used with Mythos Preview available to qualifying customers' security teams on request. Our aim is to make it much easier to get the best performance out of highly capable public models without extensive setup. This release includes:

- The [skills](#) (custom instructions for repeated work) that we and our partners have built and shared;
- A harness that helps Claude map the codebase, spin up scanning subagents, triage its findings, and write reports;
- A threat model builder, which maps a codebase to identify potential targets for attack and prioritizes the model's work accordingly.

Cisco, one of our Project Glasswing partners, has also recently open-sourced its [Foundry Security Spec](#) to help other defenders build an evaluation system similar to the one they use themselves.

Supporting the ecosystem

We've formed a [partnership](#) with the Open Source Security Foundation's Alpha-Omega project, which will support the foundation's efforts to assist maintainers in processing and triaging bug reports. We're also continuing to publish research into how frontier model capabilities can best support cyberdefenders.

We've also supported the development of [ExploitBench](#) and [ExploitGym](#), the two new benchmarks that allow researchers to track frontier AI models' exploit development capabilities over time, as we discuss [here](#). We're supporting the development of other high-quality quantitative benchmarks through our [External Researcher Access Program](#). Finally, [Claude for Open Source](#) supports maintainers and

contributors, and we're committing to scan any open-source package that we adopt ourselves in the future.

What's next for Project Glasswing

The speed of AI progress means that models as capable as Mythos Preview will soon be developed by many different AI companies. At present, no company—including Anthropic—has developed safeguards strong enough to prevent such models from being misused and potentially causing severe harm. That is why we have yet to release Mythos-class models to the public. But it's also why we began Project Glasswing: if a similarly capable model is released *without* such safeguards, it will soon become dramatically cheaper and easier for almost anyone in the world to exploit flawed software.

Glasswing helps the most systemically important cyber defenders gain an asymmetric advantage. However, there is an urgent need for as many organizations as possible to shore up their cyber defenses. We hope that our generally available models, and the new tools, resources, and research we're providing to accompany them, will support those organizations to improve their cybersecurity posture.

Next, we will work with critical partners—including US and allied governments—to expand Project Glasswing to additional partners. And in the near future, once we've developed the far stronger safeguards we need, we look forward to making Mythos-class models available through a general release.

On the far side of these risks, there's an encouraging world available to us: one in which important code is hardened far better than it is today, and in which hacking is far less prevalent. There are many obstacles, but we're nonetheless confident that Project Glasswing can help get us there.



Related content

2028: Two scenarios for global AI leadership

Our views on the AI competition between the US and China.

[Read more](#) →

Teaching Claude why

New research on how we've reduced agentic misalignment.

[Read more](#) →

Natural Language Autoencoders: Turning Claude's thoughts into text

AI models like Claude talk in words but think in numbers. In this study, we train Claude to translate its thoughts into human-readable text.

[Read more](#) →